



INDEPENDENT TECH LAW RESEARCHER  
WAR STUDIES UNIVERSITY STUDENT

WARSAW, POLAND

**ACADEMIC**  
&  
**PROFESSIONAL  
PORTFOLIO**



A Collection of Publications (Writing Samples), Reviews, Conference  
Acceptances, and Supplemental Material

**Wiktor Wilkołaski**

JUNE 8, 2026

# TABLE OF CONTENTS



## PART I: FULL ACADEMIC ARTICLES



1. The “Quantum Paradox” and “Liability Based on Deterministic Risk” . . . . . **4–31**
2. Legal Lacunae - Modern Cyber Threats Targeting International Aviation . . . **32–44**
3. Quantum Cybercrime: Challenges in the Age of Advancing Quantum Computing  
**45–66**

## PART II: CONFERENCE ACCEPTANCES & REVIEWS



4. TILTING Perspectives 2026: Abstract Acceptance & Reviews . . . . . **67–68**
5. TILTING Perspectives 2026: Extended Abstract (The “Quantum Paradox”) . **69–73**
6. TPRC<sub>54</sub> (2026): Paper Acceptance and Reviews . . . . . **74–76**
7. TPRC<sub>54</sub> (2026): Submission and Extended Abstract . . . . . **77–78**
8. SciSec 2025: Paper Acceptance and Reviews . . . . . **79–81**
9. SciSec 2025: Invoice and Conference Schedule . . . . . **82–85**
10. Springer Publishing: Chapter Production Correspondence . . . . . **86**

|            |                                                                                    |               |
|------------|------------------------------------------------------------------------------------|---------------|
| <b>11.</b> | Cybersecurity and Law: Decision and Review Forms . . . . .                         | <b>87–92</b>  |
| <b>12.</b> | IFIP Summer School on Privacy and Identity Management: Acceptance Letter           | <b>93–94</b>  |
| <b>13.</b> | IFIP Summer School on Privacy and Identity Management: Abstract . . . . .          | <b>95–98</b>  |
| <b>14.</b> | Eurocrim2026: Individual Presentation Acceptance . . . . .                         | <b>99–100</b> |
| <b>15.</b> | AI Frontiers in Cybersecurity and Infrastructure Protection: Certificate . . . . . | <b>101</b>    |

## **PART III: PROFESSIONAL & ADDITIONAL DOCUMENTS**



|            |                                                                  |                |
|------------|------------------------------------------------------------------|----------------|
| <b>16.</b> | Professional Internship: Opinion and Certificate (RCL) . . . . . | <b>102–106</b> |
|------------|------------------------------------------------------------------|----------------|

# The “Quantum Paradox” and “Liability Based on Deterministic Risk”

## Examining the Liability for Data Breach, the Duty of Care and Retroactivity in the European Union, United States of America, and People’s Republic of China

Wiktor Wilkołaski\*  
Independent Researcher  
wiktor042004@gmail.com  
ORCID: 0009-0003-7810-9073

### Abstract

The "Harvest Now, Decrypt Later" (HNDL) threat shatters the assumption that encrypted data remains secure now and in the foreseeable future. Threat actors exfiltrate ciphertext today for quantum decryption tomorrow, creating a critical temporal gap in legal liability. This article comparatively analyses post-breach frameworks across the EU, the US, and the PRC. By translating the Mosca Theorem ( $X + Y > Z$ ) into a normative standard of care, the study exposes jurisdictional asymmetries in addressing delayed-injury and technological obsolescence. Demonstrating that the deterministic inevitability of sufficient quantum cryptanalysis creates immediate liability exposure, the paper concludes that relying on legacy encryption could be legally untenable. Consequently, it urges the adoption of crypto-agile architectures and hybrid cryptography schemes as a legally defensible bridge against retroactive enforcement.

**Keywords:** Quantum Computing, GDPR, Data Liability, HNDL, Chinese Cybersecurity Law, Post-Quantum Cryptography, Standard of Care, Retroactive Liability, CRQC, Technological Obsolescence.

## 1 Introduction

The contemporary digital economy operates on the premise that prevailing cryptographic infrastructures are immutable. However, the anticipated transition to Post-Quantum Cryptography (PQC) exposes the fragility of this assumption, as advancements in Quantum Information Science (QIS) are continuously making this claim obsolete.<sup>1</sup>

---

\*Wiktor Wilkołaski is an Independent Researcher based in Warsaw, whose research lies at the intersection of deep tech and European Union, United States and People’s Republic of China law

<sup>1</sup>UNGA Res 78/287 (7 June 2024) UN Doc A/RES/78/287.

Across the European Union (EU), the United States (US), and the People's Republic of China (PRC), statutory regimes assume that currently secure encryption algorithms render exfiltrated ciphertext unintelligible.<sup>2</sup> The materialisation of a Cryptographically Relevant Quantum Computer (CRQC), from the technical perspective, invalidates this premise. Specifically, the “Harvest Now, Decrypt Later” (HNDL) strategy (also as “threat”) introduces a temporal asymmetry in cyber law:<sup>3</sup> Threat actors exfiltrate high-entropy ciphertext encrypted with asymmetric algorithms (e.g., RSA, ECC)( $t_0$ ), retaining the payload until decryption capabilities become available ( $t_1$ ).<sup>4</sup>

This traditional approach creates a gap in establishing legal liability and thereby creating what was named in the title as “Quantum Paradox”. Because the data is stolen today ( $t_0$ ) but decrypted years later ( $t_1$ ), there is a massive gap in legal liability. The paradox lies in the fact that while the data is technically already compromised, traditional law struggles to see an injury because the actual harm is delayed. Consequently, it is uncertain whether current data protection laws would be applied effectively; they create an unpredictable timeline where data controllers cannot foresee when a security breach will turn into a legal violation. Furthermore, existing regulatory safe harbours—which exempt organisations from breach notification mandates and liability if the stolen data was encrypted—completely ignore the delayed-injury mechanics of the “Harvest Now, Decrypt Later” (HNDL) threat.<sup>5</sup>

To address indicated lacunae, this article deploys a functional comparative methodology<sup>6</sup> to interrogate the systemic friction between current provisions on the matter of liability and the deterministic trajectory of quantum cryptanalysis across the EU, the US, and the PRC. This analysis specifically examines how the law should handle the suspension of statutes of limitations and whether companies can use the “state-of-the-art” defence. This issue becomes critical because the actual decryption of data ( $t_1$ ) happens much later than the original theft ( $t_0$ ). By analysing relevant provisions, the inquiry determines whether

---

<sup>2</sup>Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS2 Directive) [2022] OJ 2022 L 333/80; Standing Committee of the National People's Congress, *Cryptography Law of the People's Republic of China* (promulgated 26 October 2019, effective 1 January 2020) art 27.

<sup>3</sup>Cloud Security Alliance, ‘Cloud Security Alliance Sets Countdown Clock to Quantum’ (9 March 2022) <https://cloudsecurityalliance.org/press-releases/2022/03/09/cloud-security-alliance-sets-countdown-clock-to-quantum> accessed 23 March 2026.

<sup>4</sup>Even though asymmetric cryptography is the most vulnerable, developments in quantum information science (QIS) also compromise the security margins of symmetric algorithms; specifically, Grover's algorithm effectively halves the bit-security of symmetric keys (meaning a 128-bit key drops to only 64 bits of actual protection). See Lov K Grover, “A Fast Quantum Mechanical Algorithm for Database Search,” in *Proceedings of the 28th Annual ACM Symposium on Theory of Computing* (1996), 212–219, <https://doi.org/10.1145/237814.237866>; Lily Chen et al., *Report on Post-Quantum Cryptography*, National Institute of Standards and Technology, NISTIR 8105 (2016), 1, <https://doi.org/10.6028/NIST.IR.8105>.

<sup>5</sup>*Spokeo, Inc v Robins* 578 US 330 (2016); *TransUnion LLC v Ramirez* 141 S Ct 2190 (2021).

<sup>6</sup>R Michaels, ‘The Functional Method of Comparative Law’ in M Reimann and R Zimmermann (eds), *The Oxford Handbook of Comparative Law* (OUP 2006); K Zweigert and H Kötz, *Introduction to Comparative Law* (T Weir tr, 3rd rev edn, Clarendon Press 1998).

data controllers retain statutory immunity under legacy encryption safe harbours. The findings demonstrate that jurisdictional divergences in addressing long-tail technological risks expose a critical regulatory lacuna, mandating an immediate doctrinal recalibration toward liability based on deterministic risk to effectively resolve the “Quantum Paradox”.

## 2 Methodology

To substantiate the doctrinal implications of the HNDL, this article executes a comparative legal analysis of liability regimes across three primary jurisdictions. Moving beyond introductory discourse, this research proposes a liability framework for cybersecurity incidents (especially breaches) specific to the quantum era. Rather than executing a strictly technical evaluation, the analysis translates cryptographic inevitabilities into actionable legal constructs. For each jurisdictional model, selected due to its role in the contemporary cyber-threat vector and significance for global data economy, the inquiry isolates and evaluates the primary statutory sources governing post-breach liability.

To systematically interrogate the asymmetries in technological risk allocation, this study deploys the functional comparative methodology, anchored in the classical doctrine of Zweigert and Kötz.<sup>7</sup> Applying the principle of *praesumptio similitudinis*, the scrutinised legal regimes (the EU, the US, and the PRC) confront an identical, borderless technological deficit—the systemic vulnerability of classical cryptographic primitives to the HNDL strategy—yet operationalise fundamentally divergent legal instruments for mitigation. Transcending a static ‘law-in-books’ evaluation, this article employs the Mosca Theorem ( $X + Y > Z$ ) as a *tertium comparationis*. By applying a cryptographic risk metric as a normative benchmark for the standard of care, the analysis facilitates a rigorous evaluation of how disparate jurisdictions conceptualise and penalise delayed harm, effectively reconciling mathematical determinism with jurisdictional ‘law-in-action’ in the quantum era.

Within the European Union, the analysis prioritises the General Data Protection Regulation (GDPR), specifically Article 32 regarding the “state of the art” and the obligation to maintain proportionate security measures, and evaluates its applicability to the CRQC availability horizon. The inquiry examines the enforcement of technical obsolescence through the *Knuddels* precedent, which determined that deploying deprecated encryption constitutes a statutory violation, and the Belgian Data Protection Authority’s (APD) 28/2020 decision, which affirmed that an entity’s organisational scale may influence the severity of the penalty, but does not affect the existence of liability itself. Furthermore, the analysis integrates the Court of Justice of the European Union (CJEU) ruling in *Case C-340/21 (Natsionalna agentsia za prihodite)*, which reverses the *onus probandi*, mandating the data controller to affirmatively demonstrate the adequacy of implemented security

---

<sup>7</sup>Zweigert and Kötz (n 6) 40.

architectures.

In the United States context, the research emphasises Section 5 of the Federal Trade Commission Act and the distinctive jurisprudential reasoning concerning Article III standing. The analysis contrasts the “read and understood” standard articulated by the Third Circuit in *In re Horizon* with the doctrine of “negligent stagnation” established in *Shore v Johnson & Bell* and *Holmes v Elephant Insurance Company*, which legally categorises the failure to continuously upgrade cryptographic security as an actionable omission.

Regarding the People’s Republic of China, the study scrutinises the Personal Information Protection Law (PIPL), the Cybersecurity Law (CSL), the Data Security Law, and corollary administrative provisions, focusing on the strict, often retroactive enforcement of national security mandates. The article reviews critical judicial verdicts and regulatory actions, prominently the *Cyberspace Administration of China v Didi Global* enforcement and the *Sina Weibo* adjudication.

**Paper’s Contribution:** This study provides a rigorous assessment of extant statutory frameworks, judicial determinations, and administrative actions in the context of the accelerated deployment of quantum technologies. The central distinction lies in transposing mathematical formulations—specifically the Mosca Inequality—into the legal domain to serve as a potential determinant of negligence. Moving beyond probabilistic risk models, this study investigates the criteria for establishing a definitive threshold of legal liability. It specifically examines whether the failure of a data controller (referred to as a ‘data processor’ in the PRC), management board, or relevant authorities (e.g., CISO, CTO) to upgrade cryptographic infrastructure constitutes a breach of the standard of care.

Ultimately, these jurisdictional frameworks are synthesised through this deterministic lens to illustrate how the timeline of quantum cryptanalysis precipitates immediate liability exposure. Notably, while the inquiry prioritises quantum technologies due to their immediacy in the threat matrix, the formulated liability framework operates as a technology-agnostic model applicable to emergent computational architectures (e.g., photonic computing). Furthermore, aligning with the temporal urgency of this crisis, the study’s analytical framework is contextualised by the United Nations’ designation of 2025 as the “International Year of Quantum Science and Technology,”<sup>8</sup> affirming the imminent regulatory priority of this technological transition.

---

<sup>8</sup>UNGA Res 78/287 (n 1).

## 3 Technical Background: The Mechanics of Quantum Risk

### 3.1 Scope of Technical Threat Analysis

Presently, the digital economy operates in an era of accelerating development of quantum computing, which will eventually bring challenges for both legal and technical matters, especially in creating non-existent cyber threats or enhancing currently existing ones. Advanced quantum computing may also be able to launch large-scale cryptanalysis, leading to real-time eavesdropping (by simultaneously breaking the session-securing keys). The primary threat to the global cybersecurity ecosystem emanates from organised cybercriminal syndicates and state-sponsored APTs (Advanced Persistent Threats) which, upon acquiring or leasing quantum capabilities or quantum cloud services (via Quantum Computing as a Service), would massively scale up their capacity to commit financial crimes by bypassing any existing encryption on financial networks, raiding banks, or draining cryptocurrency wallets and consequently obtaining currency or value stored in the account. The mentioned cybercrime groups may try to bribe personnel with access to quantum computers and get information about possible backdoors, cryptographic keys, or leak sensitive computational data.

### 3.2 Classical Encryption vs. Shor's Algorithm

Presently, digital security relies on “complex mathematical puzzles” that are virtually impossible for traditional computers to solve in a reasonable timeframe. For the purposes of this paper, “classical encryption” (also “classical cryptography”) shall be defined as the currently most widely used cryptographic primitives that are vulnerable to decryption by a Cryptographically Relevant Quantum Computer (e.g., RSA, ECC, DSA, DH). These classical encryption standards rely on specific mathematical problems that are computationally unsolvable for classical supercomputers. For instance, RSA relies on the difficulty of factoring large integers (the integer factorization problem),<sup>9</sup> while ECC relies on the discrete logarithm problem.

- **Classical Computing Impossibility:** Deriving a private key from a public key using the fastest known classical algorithms would take trillions of years.
- **Cryptographic Collapse:** In 1994, Peter Shor demonstrated that a quantum computer could solve both integer factorization and discrete logarithm problems in

---

<sup>9</sup>RL Rivest, A Shamir and L Adleman, 'A Method for Obtaining Digital Signatures and Public-Key Cryptosystems' (1978) 21(2) Communications of the ACM 120.



polynomial time.<sup>10</sup> Once a stable CRQC is built, it will be able to break current encryption standards in hours or minutes.<sup>11</sup>

### 3.3 The Timeline of “Q-Day”, Stages of HNDL, and Scope of Targeted Data

“Q-Day” (also known as Y2Q)<sup>12</sup> refers to the moment when a Cryptographically Relevant Quantum Computer would become available to use for state actors or (cyber)criminal organisations. To illustrate the significance of “Q-Day” and its non-fictional nature, expert consensus and legal implications are outlined below:

- **Expert Consensus:** While estimates vary, the Global Risk Institute’s annual survey of quantum experts consistently indicates a significant probability (over 50%) of a CRQC emerging within the next 10–15 years.<sup>13</sup> Simultaneously, NIST set the requirement in NIST IR 8547<sup>14</sup> for governmental entities to deprecate the classical encryption standards after 2030 and disallow their use after 2035.
- **Legal Relevance:** In legal terms, this moves the threat from “speculative” to “foreseeable.” Courts generally hold defendants liable for foreseeable risks, even if they are not immediate.

The HNDL, unlike the currently most prevalent cyberthreats, operates in three distinct phases, each presenting unique challenges for current legal frameworks:

1. **Harvesting:** The attacker currently obtains encrypted data (e.g., through leakage, exfiltration etc.). Under current law (e.g., *In re Horizon*), this is often treated as a “low risk” breach because the data is theoretically unreadable.<sup>15</sup>
2. **Storage:** The attacker holds the data in cloud, physical or other types of storage. The data subject suffers no immediate financial loss, creating the “standing” issues seen in US courts (e.g., *Greenstein*).<sup>16</sup>
3. **Decryption:** The attacker uses CRQC computing power to gain access to the data encrypted by classical cryptographic primitives. This may create retroactive liability,

---

<sup>10</sup>PW Shor, ‘Algorithms for quantum computation: discrete logarithms and factoring’ in *Proceedings 35th Annual Symposium on Foundations of Computer Science* (IEEE 1994).

<sup>11</sup>R Babbush et al, ‘Securing Elliptic Curve Cryptocurrencies against Quantum Vulnerabilities’ (2026) <https://quantumai.google/static/site-assets/downloads/cryptocurrency-whitepaper.pdf>.

<sup>12</sup>Cloud Security Alliance (n 3).

<sup>13</sup>M Mosca, ‘Cybersecurity in an Era of Quantum Computers: Will We Be Ready?’ (2018) 16(5) IEEE Security & Privacy 38.

<sup>14</sup>NIST, ‘NIST IR 8547: Transition to Post-Quantum Cryptography’ (US Department of Commerce 2024).

<sup>15</sup>*In re Horizon Healthcare Services Inc Data Breach Litigation* 846 F3d 625 (3d Cir 2017).

<sup>16</sup>*Greenstein v Noblr Reciprocal Exchange* No. 4:21-cv-04537-JSW (ND Cal 2024).

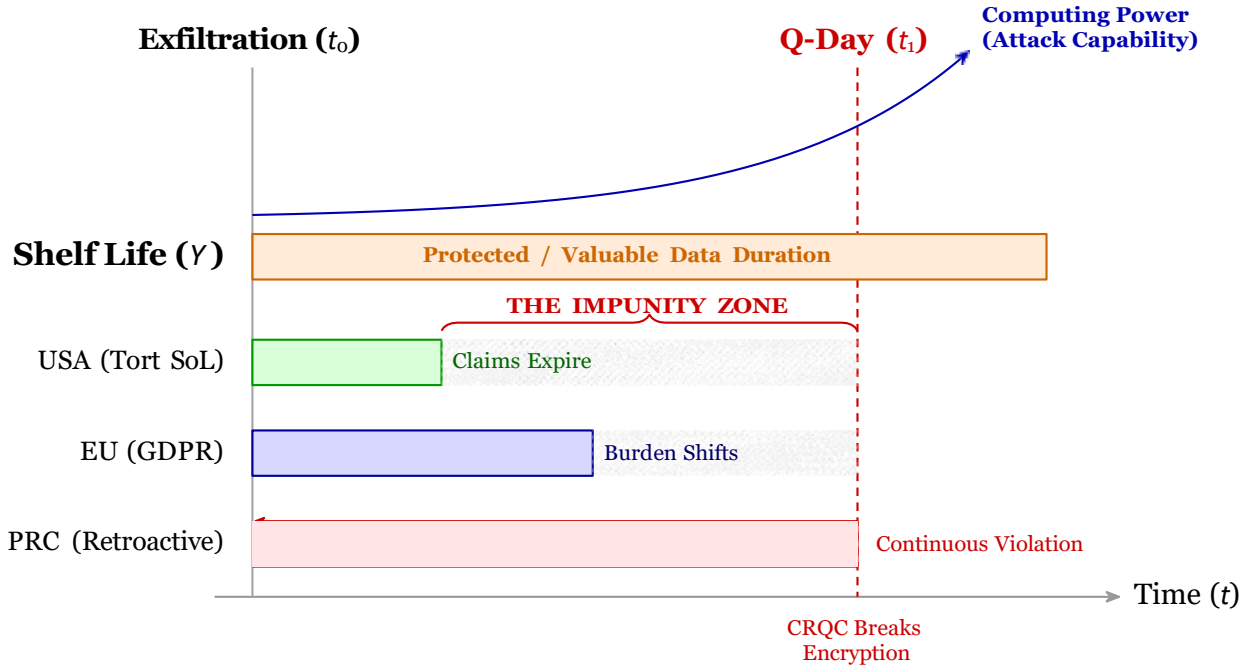


Figure 1: **The “Quantum Paradox” and Statutes of Limitation.** The figure contrasts the rising curve of quantum capability with the fixed statutes of limitations in Western jurisdictions. The paradox is that data stolen today is legally treated as “safe” because it is encrypted, even though its future decryption is already inevitable. The hatched area represents the “Impunity Zone”—a temporal gap where US and EU claims may expire before the data is technically decrypted ( $t_1$ ), whereas the Chinese framework (bottom) maintains continuous liability.

often years after the statute of limitations for the original breach may have arguably expired.

Unlike most currently well-known cyberattacks, which seek immediate monetisation (ransomware) or disruption (DDoS), HNDL is an archival strategy that promotes adversaries’ patience. It targets data with a long value-lifespan ( $Y$ ) that exceeds the timeline to quantum availability ( $Z$ ). This includes:

- **Genomic Data:** Immutable biological markers valid for the subject’s entire lifetime ( $Y \approx 70+$  years).
- **State Secrets/Intelligence:** Classified information (secret/top secret) with retention schedules often exceeding 30 years.
- **Long-Lifecycle Intellectual Property:** Proprietary engineering schematics for infrastructure with multi-decade operational lifespans (e.g., aerospace airframes, nuclear reactor designs).

### 3.4 The Mosca Theorem as a Duty of Care Test

To determine whether negligence occurred, we must assess whether a data controller acted reasonably given the timeline of the threat. One of the possibilities to assess it is the application of Mosca’s inequality (also “Mosca theorem”), which provides the mathematical basis for the assessment of whether the controller was negligent or not. A data controller, according to the theorem, is in a state of risk if:

$$X + Y > Z \quad (1)$$

**Where:**

- X Migration Time:** Time required to update infrastructure to Post-Quantum Cryptography (PQC).
- Y Shelf Life:** Years the data must remain confidential (e.g., genomic data).
- Z Collapse Time:** Time remaining until a CRQC is available.

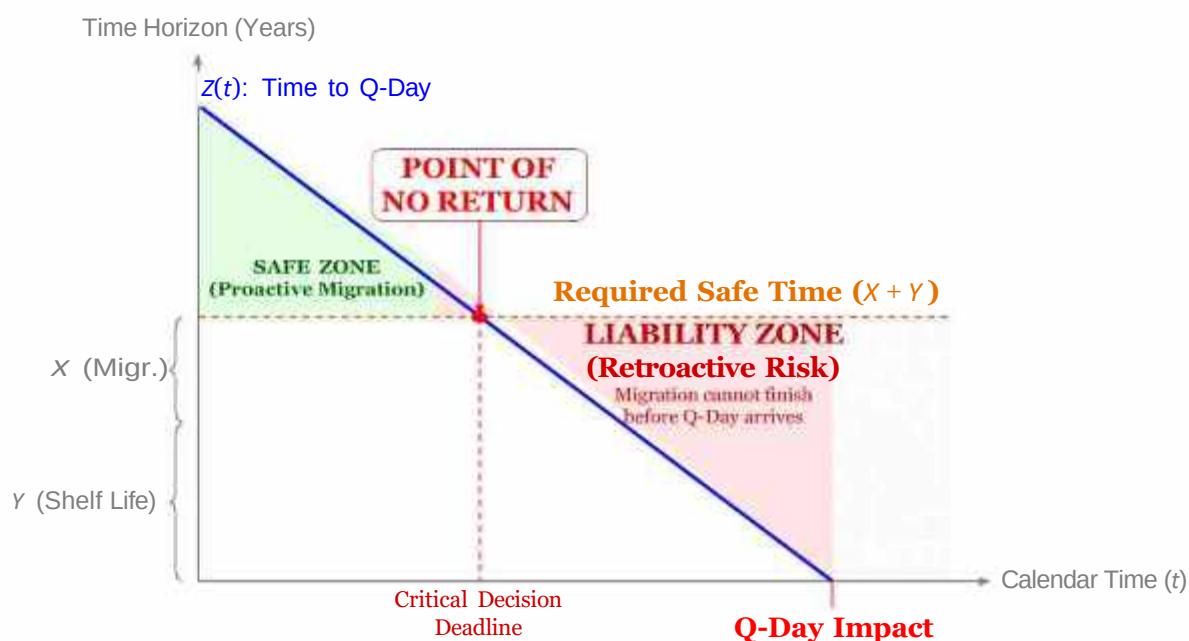


Figure 2: The CISO’s Decision Map (Mosca Inequality Dynamics). The chart demonstrates that the deadline for action is not Q-Day itself, but the “Point of No Return”—the moment when the remaining time to quantum capability ( $Z$ ) falls below the sum of migration time ( $X$ ) and data shelf life ( $Y$ ). Beyond this point, any data collected is mathematically compromised.

However, questions about the applicability to law arise: why should a regulatory body or a judge adopt a mathematical equation as a standard for legal negligence? The answer

lies in the fundamental principles of tort law and risk assessment, such as the American Hand Formula ( $B < PL$ ),<sup>17</sup> which evaluates whether the burden of adequate precautions is less than the probability and gravity of the resulting injury.

If  $X + Y > Z$ , the data is mathematically compromised *today*, even if it has not yet been decrypted,<sup>18</sup> This mathematical certainty establishes the foundation for “liability based on deterministic risk.” Instead of asking if a breach *might* cause harm (a probability, as in the Hand Formula), the Mosca theorem proves that the cryptographic collapse *will* happen (a certainty). From a liability perspective, the Mosca theorem serves as a quantifiable test for foreseeability. Continuing to store data with high  $Y$  values using classical encryption, while the time to quantum arrival ( $Z$ ) is demonstrably decreasing, constitutes a measurable failure to mitigate a foreseeable risk—translating a mathematical vulnerability directly into a breach of the legal Duty of Care.<sup>19</sup>

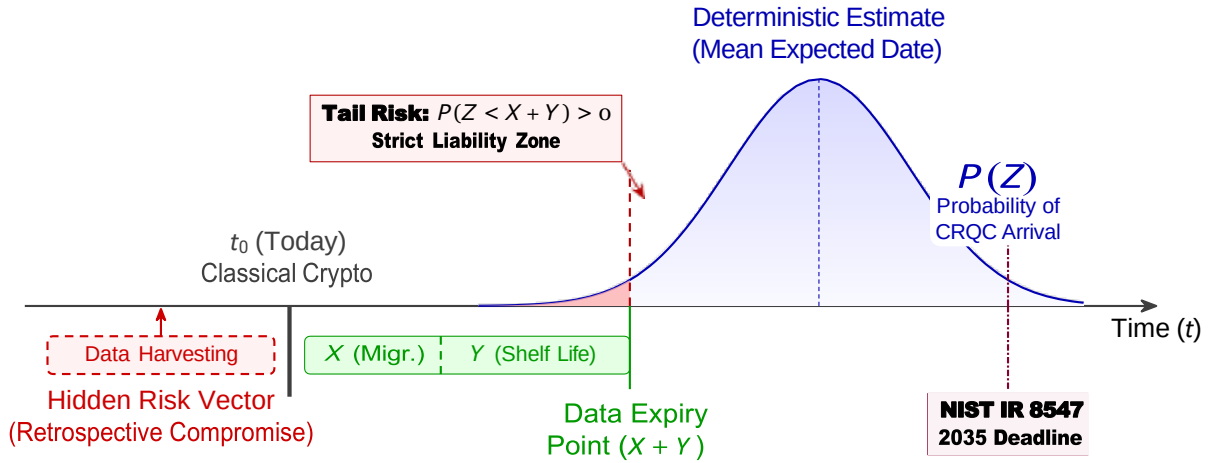


Figure 3: **System Architecture of Cryptographic Negligence** - integrates the probabilistic distribution of CRQC arrival (approx.) with the cryptographic data lifecycle. The vector space  $X + Y$  is bifurcated into active system migration ( $X$ ) and passive data shelf-life ( $Y$ ). The inclusion of the Harvest Now, Decrypt Later (HNDL) block before the baseline  $t_0$  highlights the retrospective compromise of pre-harvested data, which bypasses modern security perimeters. Furthermore, the red intersection zone represents the mathematical materialisation of a legal 'Tail Risk', long before the NIST 2035 federal migration deadline.

From a legal standpoint, the distinction between a deterministic mean and probabilistic tail risk is critical. Relying solely on the “mean” expected arrival date of a CRQC

<sup>17</sup>*United States v Carroll Towing Co* 159 F2d 169 (2d Cir 1947).

<sup>18</sup>Mosca (n 13).

<sup>19</sup>While contemporary scholarship attempts to reduce post-quantum cryptographic obsolescence to a malleable cost-benefit calculus and corporate governance balancing tests (see, eg, D Bender, 'Post-Quantum Negligence: Applying the Learned Hand Formula to Organisational Liability for Quantum Computing Threats' (Working Paper 2026)), this article states that the deterministic temporal asymmetry of the HNDL displaces the juridical relevance of such models. When  $X + Y > Z$ , the cryptographic deficit is an absolute mathematical reality that necessitates strict, architecture-based liability independent of internal business judgments.

ignores the statistical probability of an earlier, “Black Swan” breakthrough. In corporate governance, ignoring this tail risk when managing highly sensitive data (high  $\gamma$ ) is not merely a miscalculated business risk; it may constitute gross negligence. A legally defensible “Duty of Care” requires proactive mitigation based on the full probability distribution, not just the most optimistic scenario.

Paradoxically, while government agencies storing top-secret data are afforded a generous transition window until 2035 (NIST IR 8547), commercial entities processing long-lifespan data ( $\gamma$ ) might face immediate liability under dynamic “state-of-the-art” standards or FTC reasonableness principle long before federal migrations are complete.

To be precise, while the Mosca Theorem ( $X + \gamma > Z$ ) establishes an objective mathematical threshold for cryptographic negligence and a breach of the Duty of Care, its transmutation into actionable legal liability remains strictly jurisdiction-dependent. The theorem effectively satisfies the substantive requirement for a breach of duty; however, as subsequent analysis demonstrates, its operationalisation encounters profound procedural friction in jurisdictions—most notably the United States federal courts—that strictly bifurcate the mathematical materialisation of systemic risk from the juridical materialisation of a legally cognizable injury-in-fact.

## 4 The European Union: GDPR and “State-of-the-Art”

Regarding liability for data breaches and negligence, the foundation of EU data security law lies in Article 32(1) of the GDPR, which mandates that controllers implement technical measures appropriate to the risk, considering “the state of the art.” However, there is no legally binding definition in the entire EU legal system that would explain the meaning of “the state of the art,” which makes it vulnerable to a varying range of interpretations. Therefore, the “state-of-the-art” is defined only in non-binding documents, such as the TeleTrust Guideline.<sup>20</sup>

Therefore, drawing upon the guidelines of the European Union Agency for Cybersecurity (ENISA),<sup>21</sup> Teletrust Guidelines, and current state of the knowledge, paper introduces an assessment methodology, according to which a measure qualifies as “state of the art” only if it satisfies three concurrent criteria:

1. **Scientific Validation:** The underlying algorithms must be accepted by the international cryptographic research community as resistant to all currently known

---

<sup>20</sup>TeleTrust, ‘Guideline “State of the Art” Technical and Organizational Measures (TOMs)’ [https://www.teletrust.de/fileadmin/user\\_upload/2025-09\\_TeleTrust\\_Guideline\\_State\\_of\\_the\\_art\\_in\\_IT\\_security\\_EN.pdf](https://www.teletrust.de/fileadmin/user_upload/2025-09_TeleTrust_Guideline_State_of_the_art_in_IT_security_EN.pdf) (IT Security Association Germany 2025).

<sup>21</sup>Enisa European Cybersecurity Certification Group Sub-group on Cryptography, ‘Agreed Cryptographic Mechanisms’ (2025).

cryptanalytic attacks (including *IND-CCA2* security for public-key schemes);

2. **Availability and Applicability:** The technology must be proven in operational environments rather than being purely theoretical or experimental;
3. **Technological Awareness:** The measure must not rely on primitives classified as “Deprecated” or “Legacy” by standardisation bodies such as ISO/IEC (under the ISO/IEC 18033 series) or NIST (within SP 800-131A Rev. 2 / Rev. 3), regardless of their continued functionality in legacy systems.

Author argues that uniform criteria for examining whether the entity shall be found negligent are necessary to avoid misinterpretations and guarantee the stability of the law. Thus, under this definition, the continued use of theoretically compromised algorithms (e.g., SHA-1 or RSA without padding) constitutes a *de iure* violation of GDPR requirements, as these no longer represent the state of the art. Exact provisions, such as Recital 83, further clarify that encryption is a key mitigation strategy, but only provided that they are effective against currently available methods used to break them. Moreover, Recital 75 expands the definition of “risk” to include “unauthorised reversal of pseudonymisation,” which is what HNDL directly achieves.

#### 4.1 Judicial Precedent: Knuddels.de

The principle that technical obsolescence equals negligence was solidified in the *Knuddels* case, where Knuddels.de suffered a breach exposing the data of 330,000 users. The subsequent investigation conducted by the Baden-Württemberg Data Protection Authority (LfDI) revealed that the company was storing user passwords in plain text. Consequently, the LfDI found Knuddels guilty and imposed a fine of €20,000.<sup>24</sup> While the fine was reduced due to the company’s “exemplary cooperation” and immediate transparency, the legal finding was unequivocal: storing passwords in plain text violated the obligation to ensure data security under Article 32(1)(a).

In the decision, the LfDI held that using no cryptography at all is a violation of the GDPR. However, the same applies to the use of outdated standards when there are secure alternatives. Once PQC standards (e.g., NIST FIPS 203, 204, and 205),<sup>25</sup> are finalised and available, continuing to use classical RSA for long-term data becomes legally indistinguishable from storing passwords in plain text—it is a known, remediable vulnerability. However, the FIPS applies only to US governmental entities, and such

---

<sup>22</sup>ISO/IEC 18033, ‘Information technology—Security techniques—Encryption algorithms’ (2005).

<sup>23</sup>NIST, ‘Transitioning the Use of Cryptographic Algorithms and Key Lengths’ (NIST Special Publication 800-131A Revision 2, 2019).

<sup>24</sup>LfDI Baden-Württemberg, ‘Fine proceedings against Knuddels GmbH & Co KG’ [https://gdprhub.eu/images/5/5f/LfDI\\_BW\\_-\\_O\\_1018-115.pdf](https://gdprhub.eu/images/5/5f/LfDI_BW_-_O_1018-115.pdf) (2018).

<sup>25</sup>NIST, ‘FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard’ (2024); NIST, ‘FIPS 204: Module-Lattice-Based Digital Signature Standard’ (2024); NIST, ‘FIPS 205: Stateless Hash-Based Digital Signature Standard’ (2024).

standards for the investigation of an entity's negligence under the GDPR only fulfill one of the requirements: the potential awareness of the obsolescence.

## 4.2 Strict Liability for SMEs and Non-Profits: The APD 28/2020

The Belgian Data Protection Authority's (APD) Decision 28/2020<sup>26</sup> reinforces the principle that GDPR compliance is mandatory regardless of an entity's size, legal form, or commercial nature. In this case, a non-profit association (*association sans but lucratif*) was found liable for multiple violations, including the failure to respect the right to object and the right to erasure. The defendant attempted to justify its processing by stating its need to seek donors to support its projects, but the APD explicitly ruled that direct marketing rules (Article 21 GDPR) apply to any organisation "acting in a commercial or non-commercial framework".

This decision establishes a critical precedent for smaller entities, demonstrating that:

- **Administrative Constraints are no Defence:** The APD identified the defendant as an association with "limited turnover" (*chiffre d'affaires limité*), yet this did not exempt it from the strict obligations regarding data subject rights.
- **Proportionality Affects the Fine, Not the Duty:** While the entity's financial status was considered to ensure the fine (€1,000) was proportional to its annual accounts, the small scale was not a ground for dismissing the infringement.
- **Absolute Duty to Halt Processing:** The authority emphasised that the defendant failed to stop promotional mailings for five months after the initial objection, proving that even small organisations must be technically capable of immediate compliance.

In addition, the interpretation of APD aligns with the "proportionality" principle inherent in Article 32, which mandates considering the "costs of implementation." Market analysis confirms that the duty of care is economically scalable: migration costs are estimated to consume 2.5% to 5% of an entity's annual IT budget.<sup>27</sup> For large corporations with average IT budgets of 1.1 billion USD, this translates to an annual investment of 27–55 million USD.<sup>28</sup> By tying the investment (X) to a percentage of the budget rather than a fixed sum, the standard respects the resource disparities between SMEs and Very Large Online Platforms while maintaining strict liability for negligence.

---

<sup>26</sup>Belgian Data Protection Authority (APD), Decision 28/2020 (2020), <https://www.autoriteprotectiondonnees.be/index.php/publications/decision-quant-au-fond-n-28-2020.pdf>.

<sup>27</sup>Finacle, 'Cybersecurity 2026' (2026) <https://www.finacle.com/cybersecurity-2026/> accessed 23 March 2026.

<sup>28</sup>Omdia, 'IT opportunity to reach \$8.2 trillion by 2031 amid rising budgets' (2025) <https://omdia.tech.informa.com/pr/2025/feb/omdia-it-opportunity-to-reach-8point2-trillion-dollars-by-2031-amid-rising-budgets> accessed 23 March 2026.



This precedent effectively dismantles the claim that GDPR compliance is too rigorous for entities with smaller revenue or profit and that the exemptions due to that particular reason should be applied. For data controllers storing sensitive data, the duty to implement appropriate measures is definite. The controller’s size and resources only serve as factors in the final penalty amount, rather than providing a “safe harbour” from enforcement.

### 4.3 The Burden of Proof: CJEU Case C-340/21

In 2021, the Court of Justice of the European Union (CJEU) heard a case regarding the burden of proof in data breach litigation (*VB v Natsionalna agentsia za prihodite*, Case C-340/21)<sup>29</sup> that resulted from a cyberattack on the Bulgarian National Revenue Agency (NAP) that exposed personal data of over 6 million people.

The CJEU’s judgment (14 December 2023) established three transformative pillars that directly impact HNDL litigation strategies:

1. **Rejection of Strict Liability:** The Court ruled that the mere occurrence of a data breach is not sufficient to prove a violation of Article 32. A controller is not “strictly liable” just because they were hacked. Despite the lack of strict liability, the controller bears the burden of proving that the security measures implemented were appropriate.
2. **The Reversal of the Burden of Proof Lies with the Controller:** The implications for the HNDL are explicit: in the case of litigation, the plaintiff does not need to hire a cryptographer to prove the obsolescence of the RSA. Conversely, the controller must prove that RSA is still secure. Potentially a controller would have to stand in court and prove that using classical encryption, despite the known HNDL threat and available PQC standards, was an “appropriate” risk decision if the HNDL strategy was applied by the adversaries.
3. **“Fear” as Actionable Non-Material Damage:** By affirming that fear of future misuse is actionable when “well-founded,” the CJEU effectively recognises the initial exfiltration in HNDL scenarios as a compensable injury, given that the eventual quantum decryption of RSA-encrypted data is a deterministic inevitability rather than a speculative risk.

### 4.4 The NIS2 Directive and Personal Liability

In contrast to the GDPR’s corporate-focused administrative fines, the NIS2 Directive (EU 2022/2555) introduces direct, personal accountability for management bodies. Article 20(1) explicitly mandates that management must approve cybersecurity risk-management

---

<sup>29</sup>*VB v Natsionalna agentsia za prihodite*, Case C-340/21, [2023] (ECLI:EU:C:2023:986).



measures and supervise their implementation, establishing what may be termed a fiduciary “Duty of Crypto-Agility.” Furthermore, Article 32(5)(b) allows Member States to temporarily suspend executives from their managerial duties for corporate non-compliance. How does this apply to the “quantum paradox”? Under Article 20(1) of the NIS2 Directive, management bodies bear direct statutory responsibility for overseeing compliance with the risk-management frameworks established in Article 21. Crucially, Article 21(1) legally binds entities to implement security measures that explicitly take into account the “state-of-the-art.” Furthermore, Article 21(2)(h) removes any ambiguity regarding the scope of this obligation by designating “policies and procedures regarding the use of cryptography and, where appropriate, encryption” as a mandatory baseline requirement.

Consequently, if a Board of Directors ignores the harvesting threat (HNDL) and fails to allocate a budget for post-quantum cryptography (PQC) migration despite active NIST standardisation, they are no longer merely risking corporate-level fines. Because Article 21(2)(h) elevates cryptographic policies to a mandatory statutory minimum, such cryptographic stagnation is a direct violation of the strict “state-of-the-art” mandate and a breach of personal oversight duties under Article 20. Under the dual operation of these provisions, the EU framework effectively pierces the corporate veil—aligning closely with the Chinese PIPL model—to hold individual decision-makers personally accountable for failing to address the quantum threat.

## 5 The United States: Statutory Framework and the Quantum Challenge

### 5.1 Statutory Basis and Federal Regulations

Contrary to the comprehensive, pre-emptive regulatory approach of the European Union or the centralised national security apparatus of the People’s Republic of China, the United States (US) data privacy framework remains decentralised. Accordingly, liability for the “Harvest Now, Decrypt Later” (HNDL) threat does not emanate from a singular statutory source, but rather from a fragmented tripartite framework:

- **The Federal Administrative Pillar:** Governed primarily by Section 5 of the Federal Trade Commission Act.<sup>30</sup> The FTC operates *ex post*, utilising the inherently flexible proscription against “unfair or deceptive acts or practices” to enforce dynamic, state-of-the-art security baselines. This allows the Commission to absorb evolving cryptographic standards (e.g., NIST PQC algorithms) as new measures of commercial reasonableness.

---

<sup>30</sup>Federal Trade Commission Act, 15 USC §§ 41–58 (1914).

- **The State Comprehensive Pillar:** Anchored by state-level privacy architectures, most prominently the California Consumer Privacy Act (CCPA) and the California Privacy Rights Act (CPRA). These statutes independently mandate “reasonable security procedures and practices” and introduce statutory damages via a limited private right of action, functionally bypassing Article III federal standing constraints by allowing plaintiffs to pursue claims in state fora based on statutory violations alone.
- **The Sectoral Mandate Pillar:** Characterised by rigid, industry-specific compliance regimes (e.g., HIPAA for protected health information with inherently long confidentiality lifespans, and GLBA for financial institutions), which impose affirmative safeguarding obligations independent of broader consumer protection statutes.

This regulatory patchwork critically encumbers the US legal apparatus. While the FTC constructs the federal administrative baseline for corporate security, the private enforcement of HNDL liability remains bound by profound constitutional constraints.

The foundation of US federal cybersecurity enforcement derives not from dedicated data protection legislation, but from the century-old statutory breadth of Section 5 of the FTC Act,<sup>31</sup> which proscribes “unfair or deceptive acts or practices in or affecting commerce.” Although originally codified to police anti-competitive conduct, this mandate has been administratively repurposed to enforce data safeguarding. The judicial imprimatur for this regulatory expansion was established in *Federal Trade Commission v Wyndham Worldwide Corp*,<sup>32</sup> wherein the United States Court of Appeals for the Third Circuit validated the Commission’s authority to dictate cybersecurity standards through ex post litigation rather than ex ante rulemaking.

In *FTC v Wyndham Worldwide Corp*,<sup>33</sup> the Third Circuit adjudicated a systemic architectural failure that permitted the exfiltration of over 619,000 consumer records and precipitated \$10.6 million in fraudulent charges across three consecutive breaches. The ruling created a critical precedent: demonstrably “unreasonable” cybersecurity practices satisfy the statutory threshold for an unfair practice under Section 5. In particular, the court applied the statutory cost-benefit framework of 15 USC § 45(n), determining that a security posture is legally defective if the probability and expected magnitude of “reasonably unavoidable” harm eclipse the cost of mitigation.<sup>34</sup> While grounded in the statute, this risk assessment structurally mirrors the classic Learned Hand formula ( $B < PL$ ).

Because this “reasonableness” standard is technologically dynamic, it dictates immediate doctrinal consequences for the HNDL threat. As the National Institute of Standards

<sup>31</sup>*Federal Trade Commission Act* (n 30).

<sup>32</sup>*Federal Trade Commission v Wyndham Worldwide Corp* 799 F3d 236 (3d Cir 2015).

<sup>33</sup>*FTC v Wyndham Worldwide Corp* (n 32).

<sup>34</sup>*FTC v Wyndham Worldwide Corp* (n 32) 243–245.

and Technology (NIST) safe-harbour standards mature, the mitigation burden ( $B$ ) demonstrably decreases, while the deterministic probability ( $P$ ) of quantum decryption at  $t_1$  asymptotically approaches certainty. As a result, the jurisprudential burden of quantum migration is now empirically quantifiable. Economic projections indicate that transitioning priority US federal infrastructure will require \$7.1 billion between 2025 and 2035.<sup>35</sup> Concurrently, financial institutions are sequestering up to 5% of their annual IT allocations exclusively for PQC deployment.<sup>36</sup>

While this financial burden ( $B$ ) is substantial, it is legally justified under the Learned Hand formula ( $B < PL$ ). The cost of upgrading to Post-Quantum Cryptography is still vastly lower than the catastrophic liability ( $L$ ) of a systemic cryptographic collapse. Although a standard financial data breach cost an average of \$6.08 million per incident in 2025,<sup>37</sup> an HNDL-driven quantum decryption event is not a standard, isolated breach. Instead, it would instantly expose decades of an entity's most sensitive, accumulated data, pushing the expected liability ( $L$ ) into the billions. Furthermore, because scientific consensus views “Q-Day” as inevitable, the probability of harm ( $P$ ) approaches absolute certainty. As PQC standards mature—steadily making the migration burden ( $B$ ) more manageable—continuing to rely on vulnerable legacy algorithms like RSA-2048 becomes legally indistinguishable from the *Wyndham* case of using default passwords. It ultimately constitutes a known, foreseeable, and readily mitigable vulnerability.

Consequently, if a Board of Directors ignores the harvesting threat (HNDL) and fails to allocate a budget for PQC migration despite active NIST standardisation, they are no longer merely risking severe regulatory enforcement actions, such as twenty-year FTC consent decrees and mandatory architectural restructuring. Because the FTC aggressively targets systemic stagnation in the face of recognised threat vectors, the *Wyndham* precedent effectively weaponizes the FTC's enforcement mandate against entities delaying PQC adoption. This recategorizes the quantum threat from a deferred engineering problem into an immediate, actionable vector for corporate liability, aligning the operational impact of US enforcement with the strict governance expectations observed in the Chinese PIPL model.

## 5.2 The Differing Judiciary Approaches to Standing

While the FTC constructs the administrative baseline for corporate security, private HNDL liability hinges on a plaintiff's capacity to satisfy the rigorous requirements of Article III standing. This constitutional threshold mandates the demonstration of an injury-in-fact

---

<sup>35</sup>Computing Research Association (CRA), '2024-2025 CRA Quad Paper: The Post-Quantum Cryptography Transition: Making Progress, But Still a Long Road Ahead' (2025) [https://cra.org\\_-The-Post-Quantum-Cryptography-Transition\\_-Making-Progress-But-Still-a-Long-Road-Ahead.pdf](https://cra.org_-The-Post-Quantum-Cryptography-Transition_-Making-Progress-But-Still-a-Long-Road-Ahead.pdf) accessed 23 March 2026.

<sup>36</sup>Finacle (n 27).

<sup>37</sup>Finacle (n 27).

that is both “concrete and particularised.” The HNDL methodology—specifically its intermediate “Storage” phase, encompassing the temporal latency between exfiltration ( $t_0$ ) and eventual quantum decryption ( $t_1$ )—engenders a profound jurisprudential paradox. The federal appellate circuits exhibit a deep fracture regarding whether the mere exfiltration of high-entropy ciphertext, absent immediate cryptographic compromise, constitutes an actionable injury. In the quantum context, resolving this jurisdictional friction dictates whether a data controller faces immediate tort liability at  $t_0$ , or retains a de facto statutory immunity shield until the catastrophic realisation of harm on Q-Day.

Moreover, while the FTC establishes regulatory standards, private individuals face a distinct challenge. They must demonstrate a viable cause of action in federal court and must demonstrate an actual, personal, and real harm or harm that is about to occur, while courts are divided on whether the possibility of future harm, e.g., identity theft in a data breach, is sufficient for a cause of action. The Third Circuit has typically been more receptive to claims that damage occurs at a later time and thus allows Harvest Now Decrypt Later cases when the damage does not occur immediately. The case involved the theft of two unencrypted laptops from the Horizon offices that included personal data of more than 839,000 members.<sup>38</sup>

The plaintiffs accused Horizon of violating the Fair Credit Reporting Act (FCRA)<sup>39</sup> by not protecting critical customer data, indicating that Horizon did not encrypt the information. The principal plaintiffs neither claimed actual identity theft nor demonstrated any direct financial losses when they filed the lawsuit, but they claimed that the breach of their right to privacy according to law was the actual injury.

The district court rejected the case because it needed proof of economic loss or real identity theft, but the Third Circuit overruled the decision in the court. The appellate court determined that the unlawful distribution of personal data is a real-world injury, arguing that the emphasis on financial damage was misguided within the framework of the FCRA and various other privacy regulations. It stated that unlawful diffusion of protected data constitutes harm. The court treated unlawful distribution of proprietary data as a distinct nature of breach, rather than the technical errors examined in *Spokeo*,<sup>40</sup> and it established new legal grounds for a tort. The FCRA requires that private injuries be legally punishable only after the data has been transmitted to an external recipient who can read and comprehend it. The Horizon case determined that because the laptops were unencrypted, adversaries would gain instant access to confidential health and financial records. The instantaneous exposure of the data fulfilled the requirements to demonstrate an actual threat.

The Horizon creates a difficult legal dilemma for HNDL cases. The data is

---

<sup>38</sup>*In re Horizon Healthcare Services Inc Data Breach Litigation* (n 15).

<sup>39</sup>Fair Credit Reporting Act, 15 USC § 1681 *et seq.*

<sup>40</sup>*Spokeo* (n 5) 330.

normally encrypted when it is stolen in an HNDL attack. According to the Horizon rule, a thief cannot decipher this data instantly, which may stop legal action. HNDL expects that the information will be decrypted at a later date. The Horizon logic can be used as a plaintiff to prove that the adversary’s intent and ability to decrypt data make the injury inevitable. Dissemination is fulfilled when data is stolen by a sophisticated entity such as a nation-state to be decrypted at a later date. A future cryptographic failure, referred to as Q-Day, connects the dots between encrypted and understood. Thus, the injury is not speculative but delayed. Horizon stressed that the primary loss is the loss of privacy and not just monetary loss. When an adversary permanently records encrypted data, the user loses permanent control over his privacy.

Within this context, the legal standard of “read and understood” becomes “harvested and will be understood,” providing standing before decryption.

### 5.3 Negligent Stagnation Doctrine: *Shore v. Johnson & Bell*

Data breach litigation typically focuses on the concrete consequences of an actual, malicious exfiltration. However, the operative complaint in *Shore v. Johnson & Bell, Ltd.* (2016)<sup>41</sup> may be considered as a pioneer of a novel legal theory regarding cryptographic obsolescence liability in the absolute absence of a verified breach. This strategy, conceptualised here as the “Negligent Stagnation” doctrine, assumes that entities incur sub-constitutional and contractual liability merely by failing to update legacy systems to contemporary security baselines, such as Post-Quantum Cryptography (PQC).

The class-action complaint, filed by a client against a major Chicago law firm, alleged legal malpractice, negligence, and breach of contract. The gravamen of the suit was not that a hacker had weaponised client data, but that the firm’s unpatched information technology infrastructure left sensitive files exposed to the public internet. Specifically, the plaintiffs demonstrated that the firm utilised an obsolete version of the JBoss application server plagued by well-known, unpatched vulnerabilities.<sup>42</sup> Furthermore, the firm operated a mail server running deprecated encryption protocols susceptible to the DROWN<sup>43</sup> and FREAK<sup>44</sup> man-in-the-middle exploits, which allow attackers to force servers into utilising weak, easily compromised cryptographic keys.

The plaintiffs reframed the traditional concept of injury by demanding damages and injunctive relief—including a mandatory third-party security audit—based solely on systemic exposure to risk. They argued that by charging premium attorney fees while

---

<sup>41</sup>*Shore v. Johnson & Bell, Ltd.*, No. 1:16-cv-04363 (ND Ill, 2016).

<sup>42</sup>See *Shore v. Johnson & Bell, Ltd.*, No. 1:16-cv-04363, Doc. 56 (ND Ill, 8 December 2016) (Memorandum Opinion and Order unsealing the case).

<sup>43</sup>MITRE, ‘CVE-2016-0800 (DROWN attack)’ <https://www.cve.org/CVERecord?id=CVE-2016-0800> accessed 23 March 2026.

<sup>44</sup>MITRE, ‘CVE-2015-0204 (FREAK attack)’ <https://www.cve.org/CVERecord?id=CVE-2015-0204> accessed 23 March 2026.

delivering structurally deficient cryptographic protections, the firm overcharged its clients, thereby pocketing an unjust premium for a hollow promise of confidentiality.

Ultimately, the federal court never adjudicated the substantive merits of this economic-harm theory. In late 2016, the plaintiffs voluntarily dismissed the federal lawsuit without prejudice to transition the dispute into private, contractually mandated arbitration.<sup>45</sup> However, the subsequent published order unsealing the case reaffirmed the heavy public interest in exposing such architectural vulnerabilities.<sup>46</sup> The *Shore* complaint remains a critical doctrinal signpost for HNDL; it provides a reason for arguing that maintaining legacy algorithms (like RSA-2048) in the face of available PQC standards constitutes a contemporary breach of the standard of care, independent of whether a quantum computer has yet decrypted the data.

## 5.4 Public Disclosure Mandate: *Holmes v. Elephant Insurance Company*

While the *Shore* complaint attempted to establish pre-breach liability, the United States Court of Appeals for the Fourth Circuit severely constrained post-exfiltration standing in *Holmes v. Elephant Insurance Company*.<sup>47</sup> Decided on 14 October 2025, the case arose from a cyberattack where adversaries weaponised an online quoting platform to exfiltrate the driver’s license numbers of nearly three million individuals.<sup>48</sup> The plaintiffs fell into two distinct classes: those whose stolen data was actively published on the Dark Web, and those whose data was stolen but remained unpublicised in the perpetrators’ private possession.<sup>49</sup>

In a strict application of Article III standing principles, the Fourth Circuit recognised a justiciable injury-in-fact only for the plaintiffs whose data appeared on the Dark Web.<sup>50</sup> The court anchored this injury in the traditional common-law tort of public disclosure of private facts, ruling that for constitutional purposes, the Dark Web constitutes a “public” forum due to its accessibility to a substantial criminal audience.<sup>51</sup> Conversely, the court denied standing to the plaintiffs whose data had not been published, holding that mere exfiltration into a hacker’s private cache does not satisfy the legal threshold of publicity.<sup>52</sup> Crucially, the Fourth Circuit reinforced a rigorous statistical barrier for alternative claims of future injury inherited from the *Beck* precedent,<sup>53</sup> ruling that for potential identity theft to be deemed “imminent,” a plaintiff’s allegations must demonstrate a probability

---

<sup>45</sup>*Shore* (n 41) Doc 56, 1–2.

<sup>46</sup>*Shore* (n 41) 3.

<sup>47</sup>*Holmes v. Elephant Insurance Company*, 23-1782 (4th Cir 2025).

<sup>48</sup>*Holmes* (n 47) 4–5.

<sup>49</sup>*Holmes* (n 47) 5–6.

<sup>50</sup>*Holmes* (n 47) 15–16.

<sup>51</sup>*Holmes* (n 47) 16.

<sup>52</sup>*Holmes* (n 47) 15–16.

<sup>53</sup>*Beck v McDonald* 848 F3d 262 (4th Cir 2017).

of actual future misuse significantly exceeding 33%<sup>54</sup> Without meeting this statistical threshold or providing evidence of public dissemination, the risk remained too speculative to support federal jurisdiction under the *TransUnion* framework.<sup>55</sup>

The *Holmes* public-disclosure mandate erects a formidable barrier for HN DL litigation. In a typical HN DL scenario, foreign intelligence services or state-sponsored adversaries do not dump stolen encrypted data onto commercial Dark Web markets for quick monetisation; instead, they quietly store the exfiltrated ciphertxts in classified data repositories awaiting future decryption ( $t_1$ ). Under the strict logic of *Holmes*, a victim of a loud, public ransomware attack has immediate federal standing, whereas a victim of a silent, highly sophisticated state-sponsored HN DL operation is barred from federal court due to the lack of public exposure. To bypass this anomaly, future HN DL plaintiffs must aggressively argue that exfiltration by a foreign adversary inherently constitutes an alternative form of concrete exposure, or alternatively, steer their claims into state courts to escape federal Article III standing limitations.

## 5.5 The Limits of Mathematical Determinism in Federal Courts

The intersection of the HN DL and Article III jurisprudence exposes a critical limitation of relying solely on mathematical models for legal adjudication. While the Mosca Theorem ( $X + Y > Z$ ) unequivocally demonstrates a breach of the Duty of Care at  $t_0$  because the risk of decryption is mathematically certain, this determinism fails to pierce the procedural shield of Article III standing in federal civil litigation. Conservative judicial doctrines, as articulated in *Spokeo*, *TransUnion*, and affirmed in *Holmes*, necessitate that an injury be “concrete and particularised” rather than statistically inevitable.

A severe dogmatic paradox emerges: a data controller may commit gross cryptographic negligence by retaining legacy algorithms while the time to quantum arrival ( $Z$ ) approaches zero, satisfying the substantive criteria for a breach of duty. However, within the federal civil framework, this mathematical certainty of future decryption ( $t_1$ ) remains classified as a “speculative” or “hypothetical” harm because it fails to clear the explicit numerical and common-law thresholds enforced by the circuits. Until the ciphertxt is physically decrypted, weaponised, or subjected to public disclosure, the federal judiciary strictly insulates the data controller from private tort liability. The Mosca equation, therefore, serves as a potent instrument for regulatory enforcement (e.g., under FTC Section 5), but lacks the jurisdictional efficacy to unilaterally override the constitutional mandate of *injury-in-fact*.

---

<sup>54</sup>*Holmes* (n 47) 24–25.

<sup>55</sup>*TransUnion* (n 5) 413.

## **6 The Retroactivity and Strict Liability in the People's Republic of China**

The People's Republic of China's (PRC) approach is even more distinctive in comparison both of the western jurisdictions described in the paper. When it comes to the measures applied by the PRC, they fundamentally differ in their explicit fusion of commercial regulation and focus on national security. Although the General Data Protection Regulation (GDPR) of the EU prioritises individual privacy rights and the United States focuses on consumer harm and sectoral oversight, China's legal framework views data security as a foundation for achieving a high level of state security.

The distinction among the jurisdictions reviewed is paramount for the analysis of the application of the current legal frameworks to the HNDL. For instance, in the PRC, theft of encrypted data is not merely considered as a lack of compliance or cause for civil liability, but rather as a threat to the national security and sovereignty of the state.

The legislative "triad" (conceptually analogous to the information security "CIA triad") of the legal data protection landscape in the PRC comprises three legal acts: Cybersecurity Law (CSL),<sup>56</sup> Data Security Law (DSL),<sup>57</sup> and Personal Information Protection Law (PIPL),<sup>58</sup> consequently establishing both civil and administrative liability for the breaches. Commercial compliance is enforced through administrative fines, while data security failures involving "important" or "core" data trigger national security protocols, criminal liability, and retroactive enforcement.

### **6.1 The Personal Information Protection Law**

The first legal act that is the foundation for the data protection law in the PRC is the PIPL, often compared in its scope to the GDPR due to its presence of the corresponding mechanisms such as data minimisation, obligatory consent of the data owner, and prioritisation of data owner rights. However, both acts substantially differ in their objective, where the GDPR intended to unify data protection regulations among EU member states, while the PIPL prioritises national security interests.

The enforcement of PIPL is codified in Article 66,<sup>59</sup> which provides competence to the Cyberspace Administration of China (CAC) to impose fines of up to 5% of a company's annual turnover for "serious" violations. The sanction was applied for the first time in

---

<sup>56</sup>Cybersecurity Law of the People's Republic of China (Standing Committee of the National People's Congress 2016).

<sup>57</sup>Data Security Law of the People's Republic of China (Standing Committee of the National People's Congress 2021).

<sup>58</sup>Personal Information Protection Law of the People's Republic of China (Standing Committee of the National People's Congress 2021).

<sup>59</sup>PIPL (n 58).



the *Didi Global* case,<sup>60</sup> setting a precedent that “turnover” is interpreted as total revenue, not just profit or domestic revenue, depending on the scope of the violation. Beyond corporate fines, Article 66 introduces severe personal liability for executives, in contrast to the GDPR, according to which only data controllers can be found guilty of violations. “Persons directly responsible” for data protection failures can be fined up to RMB 1 million and, more critically and simultaneously, be banned from serving as directors, supervisors, or senior managers in related enterprises for a set period.

In the context of HNDL, this personal liability creates a profound risk for Chief Information Security Officers (CISOs). If a CISO decides to retain data encrypted with legacy algorithms (e.g., RSA-2048) despite knowing the harvesting threat, and that decision facilitates a future breach by a foreign adversary, the CISO faces personal administrative sanction. This is because the executive’s failure to adopt “state-of-the-art” or domestic quantum-resistant standards (such as the SM series) under the PRC jurisdiction can, in particular circumstances, be recognised as facilitating foreign intelligence gathering.

## 6.2 The Data Security Law

The second pillar of the PRC’s “data protection triad” is the Data Security Law (DSL), serving differentiating purposes in comparison to the PIPL. While the PIPL objective is to ensure the protection of individual rights, the DSL differs fundamentally: it shifts the focus from the protection of the data owner to the “security and development” of the state. The law mandates a hierarchical protection system based not on privacy, but on the data’s potential impact on national security, distinguishing between core, important, and general data according to Article 21 of the DSL.<sup>61</sup>

The enforcement of the DSL is codified in Articles 45 to 48,<sup>62</sup> which provide competence to relevant sectoral departments or public and national security organs (as in Article 6) to levy fines of up to RMB 10 million and, more severely, order the suspension of business operations or the revocation of licenses. Beyond corporate sanctions, similarly to the PIPL, the DSL codified explicit personal liability for executives but, unlike the PIPL, permits criminal sanctions, especially ones resulting from the Criminal Law of the PRC.<sup>63</sup> Consequently, individuals directly responsible face the dual-sanction mechanism: not only administrative fines but also potential criminal prosecution in the case of “endangering national security.” In the context of HNDL, this transforms the CISO’s technical roadmap into a matter of state security. If a CISO allows “core data” (e.g., energy schematics

---

<sup>60</sup>Cyberspace Administration of China, ‘The relevant person in charge of the Cyberspace Administration of China answered reporters’ questions on the decision to impose administrative penalties related to network security review against Didi Global Co., Ltd. in accordance with the law’ (Regarding the Decision against Didi Global inc.) (2022) [https://www.cac.gov.cn/2022-07/21/c\\_1660021534364976.htm](https://www.cac.gov.cn/2022-07/21/c_1660021534364976.htm) accessed 26 December 2025.

<sup>61</sup>Data Security Law (n 57).

<sup>62</sup>Data Security Law (n 57).

<sup>63</sup>Criminal Law of the People’s Republic of China (National People’s Congress 1979/2020) arts 285–286.

or genomic data) to be stored using classical encryption known to be vulnerable to Shor’s algorithm, they are not merely risking a regulatory fine; they risk being personally responsible for facilitating the subversion of state power. The DSL effectively treats the “decrypt later” phase as a present-day failure of the duty to safeguard the “lifeline” of the national economy.

### **6.3 Judiciary Precedent: The *Didi Global Inc.* Case**

The *Didi Global Inc.* case<sup>64</sup> shall be considered as a precedent for “continuous and retroactive” liability. The Cyberspace Administration of China (CAC) investigation into Didi Global was triggered by the company’s June 2021 Initial Public Offering (IPO) in New York. The central concern for the regulator was that the IPO would put Didi’s extensive mapping and user data under US jurisdiction. The CAC feared that data stored by the company could be obtained by American intelligence agencies via subpoenas or Foreign Intelligence Surveillance Act (FISA).<sup>65</sup> The investigation, concluded in July 2022, found that Didi had committed 16 distinct offenses involving the illegal collection and processing of personal information. The CAC, due to the serious nature of the breach and occurring circumstances, imposed a 5% annual turnover fine on Didi Global.

While the severity of the breaches is not the most interesting aspect of this particular case, it should be mentioned that the CAC penalised Didi for activities relating to data processing dating back to June 2015, which means that a retroactive liability mechanism was applied. To justify this retroactive application, the CAC relied on the “continuous violation” principle codified in Article 36 of the PRC Administrative Penalty Law.<sup>66</sup> This doctrine states that if an illegal act is of a continuous or continuing nature, the statute of limitations (typically when a violation of the law has not been discovered within two years) is counted from the date of the act’s termination due to the continuous violation character. In this particular case, the date was counted from the end of processing of the data involved, which allowed the imposition of sanctions on Didi Global.

### **6.4 Sina Weibo, CII, and the “Three Synchronisations”**

While the US focuses on harm mitigation and the EU on the rights of the data owner, the People’s Republic of China aggressively sanctions the initial phase of the HNDL attack vector: the “Harvest.” For the state regulator, the mass collection of data, whether encrypted or plain text, is not merely a privacy breach but, in particular circumstances, a failure of the Critical Information Infrastructure (CII) protection obligations. The primary

---

<sup>64</sup>Cyberspace Administration of China (n 60).

<sup>65</sup>Foreign Intelligence Surveillance Act of 1978, 50 USC ch 36.

<sup>66</sup>Administrative Penalty Law of the People’s Republic of China (Standing Committee of the National People’s Congress, rev 2021).

example of the approach is the 2020 *Sina Weibo* breach,<sup>67</sup> when approximately 538 million records<sup>68</sup> originating from the social media giant’s services, containing user data were found for sale on the dark web. The findings of the investigation indicated that the data were not obtained through direct exfiltration from the database but through API (Application Programming Interface) scraping and credential stuffing (using stolen credentials to gain access to the part or the entire system), which are the classic techniques used in the data harvesting phase.

To prevent the dissemination of the threat, The Ministry of Industry and Information Technology (MIIT) ordered Weibo’s management to take corrective measures as soon as possible. Significantly, MIIT designated a “duty to prevent harvesting” in effect. The regulatory body rejected the argument that the information was publicly available or that the use of API vulnerabilities to gain access had merely been exploited for illegitimate purposes. Instead, the failure to implement anti-scraping technologies (such as rate limiting, behavioural analysis, and response encryption) was interpreted as a violation of the Cybersecurity Law.

In the HNDL context, this precedent is significant. It implies that permitting data exfiltration ( $t_0$ ) is a punishable security failure in itself, regardless of the strength of the encryption applied to that data. If an adversary successfully scrapes a database of encrypted identifiers, the platform is liable for the architectural failure that permitted the scraping, rendering the “Decrypt Later” timeline ( $t_1$ ) legally irrelevant to the initial liability finding.

For platforms classified as Critical Information Infrastructure (CII), a broad categorisation encompassing finance, energy, transport, and major internet platforms, the specific obligations are governed by the Regulations on the Management of Commercial Cryptography Use in Critical Information Infrastructure.<sup>69</sup> These regulations mandate the administrative principle of the “Three Synchronisations and One Evaluation” (*san tong bu yi ping gu*, 三同步一评估),<sup>70</sup> which requires commercial cryptography to be planned, constructed, and operated in sync with the primary infrastructure, serving as the underlying regulatory mechanism for preventing HNDL attacks.

The principle dictates that cryptography must be:

1. **Synchronously Planned:** Security architecture development must consider the predictable, in reasonable circumstances, future threats.
2. **Synchronously Constructed:** Requirement to use state-certified protocols.

---

<sup>67</sup>Ministry of Industry and Information Technology (MIIT), ‘Administrative Summons regarding Sina Weibo Data Breach’ (2020).

<sup>68</sup>MIIT (n 67) 1.

<sup>69</sup>State Council of the People’s Republic of China, ‘Regulations on the Administration of Commercial Cryptography’ (State Council Order No 760, 2023).

<sup>70</sup>State Cryptography Administration, ‘Interpretation of the Regulations on the Management of Commercial Cryptography Use in Critical Information Infrastructure’ (2025).

3. **Synchronously Operated:** Cryptographic effectiveness must be assessed in real-time alongside system operations.

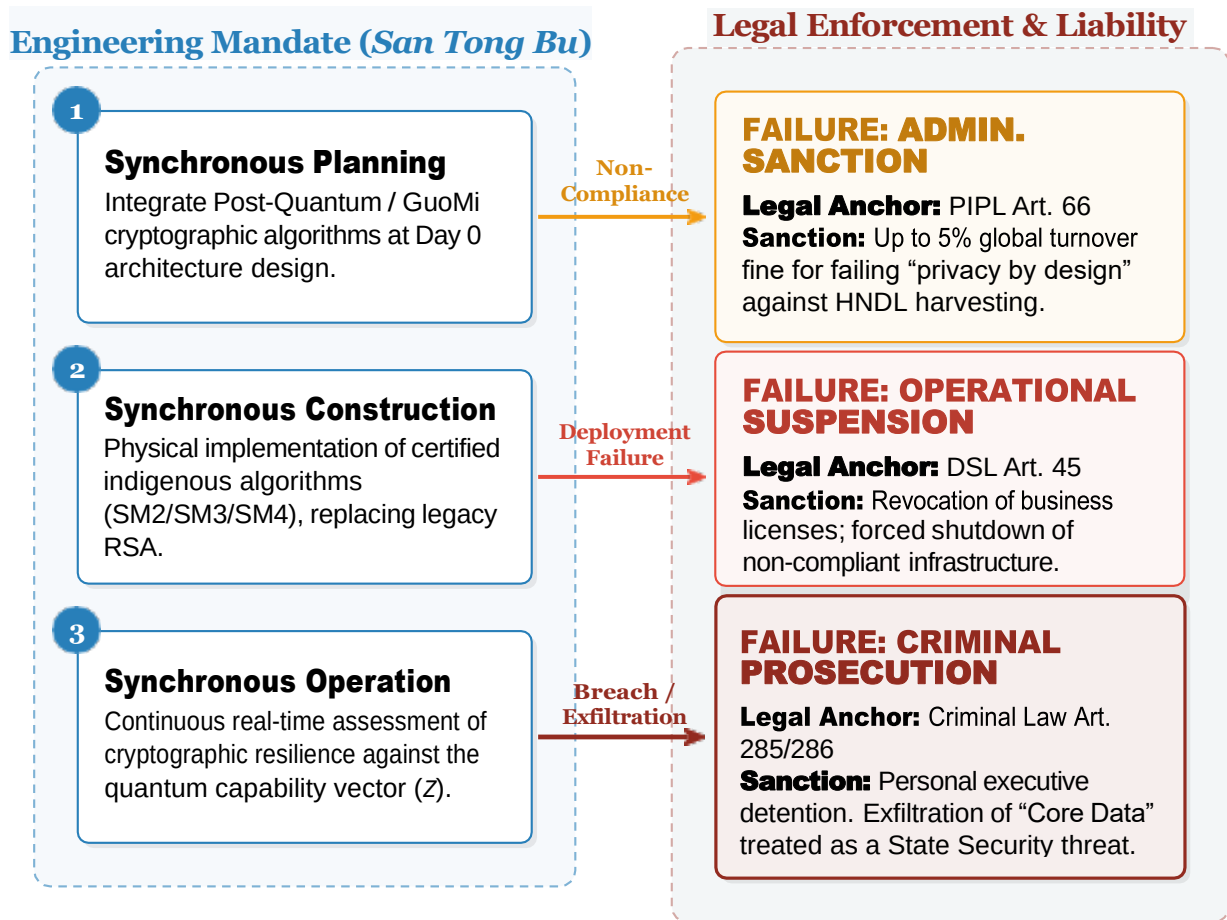


Figure 4: The “Three Synchronisations” (*San Tong Bu*) Liability Mapping. The diagram illustrates the direct legal anchors binding cryptographic engineering mandates to escalating state sanctions. Failure to architecturally preempt the HNDL threat escalates from corporate turnover fines (PIPL) to personal criminal liability (Criminal Law) in the PRC.

The “Three Synchronisations” (*san tong bu*, 三同步) framework—mandating that security defences are planned synchronously, constructed synchronously, and operated synchronously—establishes the legal mechanism for state-mandated adoption of indigenous, cryptographic algorithms, codified as the *GuoMi* (National Secret) standards.<sup>71</sup> Pursuant to the *Cryptography Law of the PRC*, Critical Information Infrastructure (CII) operators are *de facto* compelled to phase out legacy Western algorithms in favour of the State Cryptography Administration (SCA)-certified *SM* series:

- **SM2:** An Elliptic Curve Cryptography (ECC) protocol<sup>72</sup> intended to supplant western cryptographic solutions (especially RSA, Digital Signature Algorithm and DHE).

<sup>71</sup>Cryptography Law of the People’s Republic of China (n 2).

<sup>72</sup>State Cryptography Administration (SCA), ‘Public Key Cryptographic Algorithm SM2 Based on Elliptic Curves’ (GM/T 0003-2012, 2012).

- **SM3**: A cryptographic hash function<sup>73</sup> designed to replace the SHA-256 standard.
- **SM4**: A symmetric-key block cipher<sup>74</sup> deployed as the domestic alternative to AES.

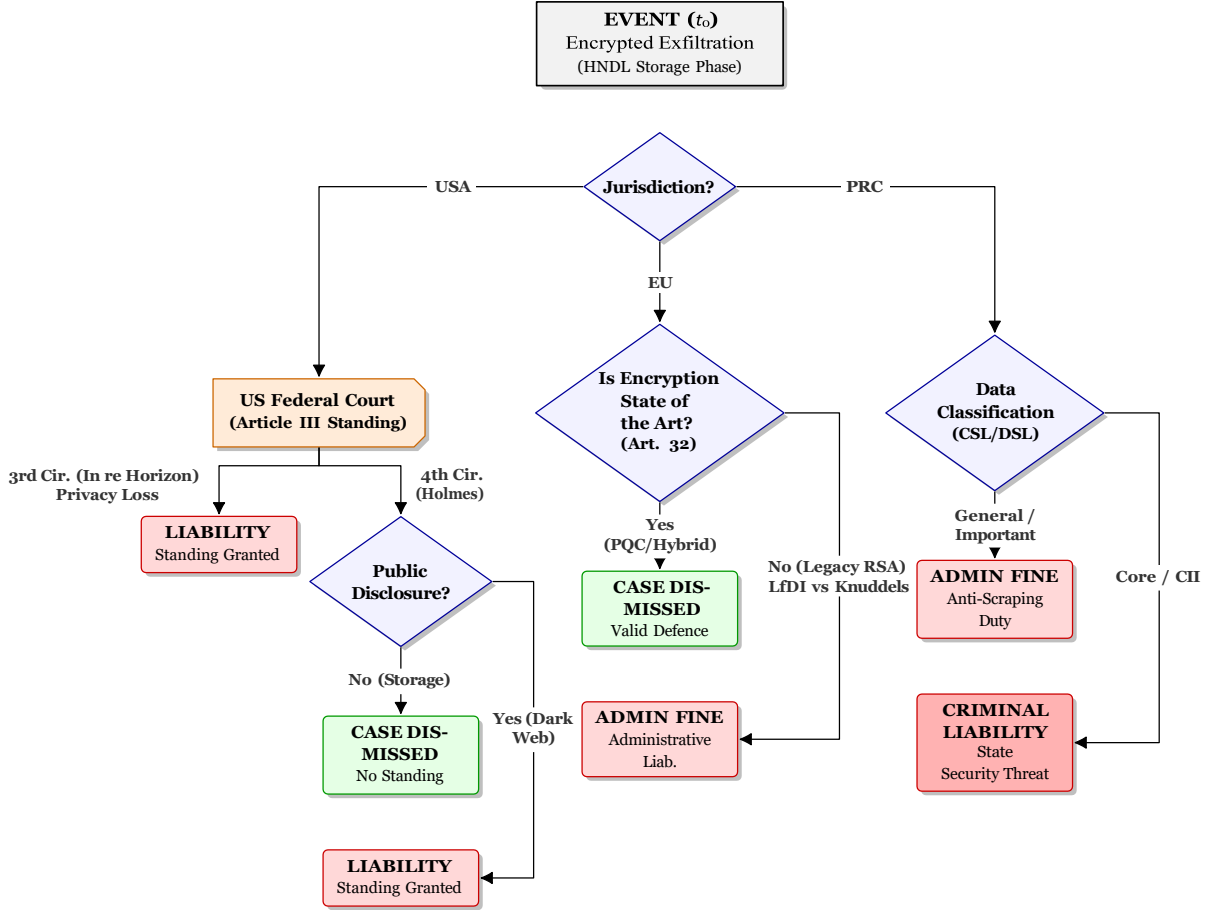


Figure 5: Jurisdictional divergence in legal liability for the “Harvest Now, Decrypt Later” (HNDL) attack at the storage phase ( $t_0$ ). The diagram illustrates the critical Circuit Split in the United States, administrative enforcement in the EU, and the escalation to criminal liability in the PRC.

## 7 Conclusion: Towards a Global Quantum Duty of Care

The ascendancy of the *Harvest Now, Decrypt Later* (HNDL) necessitates a systemic reconfiguration of the ontologies governing data protection liability. Consequently, we must resolve the “Quantum Paradox”—the assumption that encrypted, stolen data is safe simply

<sup>73</sup>SCA, ‘SM3 Cryptographic Hash Algorithm’ (GM/T 0004-2012, 2012).

<sup>74</sup>SCA, ‘SM4 Block Cipher Algorithm’ (GM/T 0002-2012, 2012).

because the harm is delayed. As demonstrated by the application of the Mosca Inequality ( $X + Y > Z$ ), the risk of quantum decryption has transitioned from a speculative future contingency to a present-tense actuarial reality.<sup>75</sup> Once the data shelf life ( $Y$ ), aggregated with the migration latency toward Post-Quantum Cryptography ( $X$ ), exceeds the projected horizon of CRQC availability ( $Z$ ), the underlying ciphertext is effectively compromised at the instant of exfiltration ( $t_0$ ). In this framework, the subsequent decryption ( $t_1$ ) is merely the materialisation of a pre-existing cryptographic deficit.

This comparative inquiry illustrates that while the cryptographic physics of HNDL are universal, the resulting liability regimes suffer from acute normative fragmentation. The European Union, leveraging a dynamic *state-of-the-art* standard and the procedural inversion of the burden of proof, effectively represents a system of immediate, architecture-based liability. The People's Republic of China enforces a stringent, retroactive architectural mandate under the *Three Synchronisations* principle, wherein the failure to pre-emptively mitigate harvesting vulnerabilities constitutes a predicate for state sanction and criminal prosecution. Conversely, the United States presents a systemic paradox. While the Mosca Theorem effectively redefines the objective standard of care for federal administrative bodies (FTC), it lacks the jurisdictional efficacy to override the restrictive *injury-in-fact* requirements of Article III. Consequently, the US judiciary preserves a precarious temporal safe harbour during the storage phase, insulating entities from private tort liability despite mathematical evidence of cryptographic obsolescence.

Such jurisdictional divergence introduces uncertainty about compliance with legal norms in different jurisdictions for data controllers or processors. As visualised in the Legal Risk Heatmap (Fig. 6), the availability of a *statute of limitations* defence or a *due diligence* safe harbour is contingent upon the specific jurisdiction in which the liability trigger is asserted, rather than the objective efficacy of the encryption employed. Furthermore, a profound regulatory irony persists: while classified state data is often afforded decadal protection via sovereign immunity or extended classification cycles, private entities managing long-lifespan data ( $Y$ ) are increasingly scrutinised against a *state-of-the-art* mandate that outpaces the finalisation of federal standards.

Consequently, this paper concludes that the contemporary *Duty of Care* does not mandate an immediate, universal migration to PQC—an objective currently unattainable by standardisation bottlenecks, financial constraints and operational inertia. Instead, to navigate the safe harbours and mitigate systemic sanctions, entities must comply with the principle of *Infrastructural Readiness* that is defined not by the premature adoption of non-finalised primitives, but by the implementation of *Crypto-Agile* architectures. Consequently, by prioritising modularity, data controllers can facilitate the seamless transition to adequately secure cryptographic solutions (*inter alia*, specific PQC algorithms) without precipitating operational disruptions, thereby neutralising the HNDL threat while preserving the stability of the digital economy.

---

<sup>75</sup>M Mosca and M Piani, 'Quantum Threat Timeline Report' (Global Risk Institute 2023).

To operationalise it without violating existing compliance mandates, entities shall consider the deployment of Hybrid Cryptography Schemes (classical asymmetric cryptography (e.g., ECDHE) + standardised PQC algorithm (*inter alia*, ML-KEM)), having regard to the size and technical capabilities of the entity. By implementing a hybrid key exchange, data controllers maintain immediate regulatory compliance with current state-of-the-art certifications while pre-emptively neutralising the HNDL threat, as the decryption process at  $t_1$  would require the adversary to break both cryptographic layers. Major European cybersecurity authorities, including the French Cybersecurity Agency (ANSSI)<sup>76</sup> and the German Federal Office for Information Security (BSI),<sup>77</sup> explicitly mandate this hybrid approach as the legally and technically defensible bridge during the quantum transition, even though such solution is applicable temporarily taking into consideration the potential black swans and exponential development of CRQC.

| Risk Category                                                       | EU (GDPR/NIS2)                                                                                                                                | USA (FTC/Tort)                                                                                                                                      | China (CSL/PIPL)                                                                                                                                      |
|---------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Executive/<br/>Board Exposure</b>                                | <b>MODERATE</b><br><i>NIS2 Supervision</i><br>Executives can be suspended; fines are mostly corporate, but personal duty of care is explicit. | <b>LOW/CONDITIONAL</b><br><i>Caremark Standard</i><br>High bar for personal liability. Requires proving bad faith or complete failure of oversight. | <b>CRITICAL</b><br><i>Dual Punishment</i><br>Direct administrative fines and detention for “persons directly responsible” (PIPL Art. 66).             |
| <b>Liability Trigger<br/>(<math>t_0</math> vs <math>t_1</math>)</b> | <b>HIGH (Immediate)</b><br><i>Knuddels</i><br>Using deprecated encryption (e.g., RSA) is a violation at $t_0$ , regardless of decryption.     | <b>LOW (Delayed)</b><br><i>Concrete Harm Rule</i><br>No standing without injury. Storage of encrypted data ( $t_0$ ) rarely triggers liability.     | <b>CRITICAL (Immediate)</b><br><i>Anti-Scraping Duty</i><br>Failure to prevent exfiltration (harvesting) is penalised immediately ( $t_0$ ).          |
| <b>Retroactive Enforcement</b>                                      | <b>MODERATE</b><br><i>Reversed Burden</i><br>No explicit retroactivity, but Controller must prove past decisions were “state of the art.”     | <b>LOW</b><br><i>Statutes of Limitation</i><br>Strict time bars (1-5 years). Claims likely expire before Q-Day ( $t_1$ ).                           | <b>CRITICAL</b><br><i>Continuous Violation</i><br>Processing liability extends indefinitely; statutes of limitation reset only after data is deleted. |

**Risk Scale:**

Safe Harbour

Conditional

Strict Liability

Figure 6: Legal Risk Heatmap that visualises the exposure of data custodians across jurisdictions. **Red** indicates strict or personal liability; **Yellow** represents conditional liability dependent on judicial interpretation; **Green** indicates current safe harbours regarding HNDL threats.

<sup>76</sup>Agence Nationale de la Sécurité des Systèmes d’Information (ANSSI), ‘ANSSI views on the Post-Quantum Cryptography transition (2023 follow up)’ (2023).

<sup>77</sup>Federal Office for Information Security (BSI), ‘Cryptographic Mechanisms: Recommendations and Key Lengths (BSI TR-02102-1)’ (2026).



# Legal Lacunae - Modern Cyber Threats Targeting International Aviation Beyond the Scope of the Beijing Convention

## Keywords

Beijing Convention, Cybercrime, International Civil Aviation, International Law, Cybersecurity

## Abstract

### Objectives

The 2010 Beijing Convention represents a significant effort to update international aviation law, yet the author argues it remains critically misaligned with the modern cyber threat landscape and is limited by a "post 9/11" paradigm, that prioritizes physical, catastrophic events. The author's contribution is to analyze legal lacunae and propose solutions enabling the prosecution of these out-of-convention-scope criminal acts.

### Methods

The author analyzes the Beijing Convention provisions that may address cybercrimes against international civil aviation. Threat actors currently target the digital integrity of the airline as an enterprise rather than the aircraft or airport. Focusing on data theft, extortion, and operation disruption, these actors exploit ground-based networks rather than flight systems. The author illustrates this gap through two case studies: the 2018 Cathay Pacific data breach and the 2022 Swissport ransomware attack and operational disruption. Both caused massive disruption but fell outside the Convention's jurisdiction inasmuch as they did not physically endanger the aircraft or airport.

### Results

The author identifies a disconnect between "aviation security" (protecting the cockpit) and "airline security" (protecting the digital enterprise assets).

### Conclusions

Consequently, the Convention fails to provide a universal *aut dedere aut judicare* duty for the industry's most prevalent threats. While effective against cyber-hijackings, the narrow scope fails to address how adversaries currently execute their operations.



## Introduction

The 2010 Convention on the Suppression of Unlawful Acts Relating to International Civil Aviation (Beijing Convention, Convention)<sup>1</sup>, represents an international community effort to modernize the legal framework governing aviation security. Adopted under the auspices of the International Civil Aviation Organization (ICAO), with the purpose of addressing the new types of threats jeopardizing international civil aviation, including use of an aircraft as a weapon and cyberattacks against air navigation facilities. The Convention was drafted against the backdrop of the 11 September 2001 attacks<sup>2</sup>, and its material scope is circumscribed by historical contingency.

However, after coming into force in 2018, the threat landscape has undergone a profound transformation, shifting from kinetic or cyber-enabled threats, such as cyber-hijacking, to cyber threats, leading to fundamental misalignment with the contemporary cyber threat landscape. This approach remains legally anchored in a kinetic deterrence model, focusing exclusively on acts resulting in physical destruction and has inadvertently created a vast legal lacuna for the most prevalent and damaging cyber threats of the modern era such as large-scale data breaches targeting passenger information and Denial of Service attacks on ground-based airline infrastructure. Its cybercrime provisions are narrowly tailored to acts that directly "endanger the safety of aircraft in flight," envisioning scenarios such as a remote cyber-hijacking or a direct attack on air traffic control systems intended to cause damage. In contrast to the framework provided by the Beijing Convention, modern adversaries employ attack vectors through cyber measures, such as DoS attack, exfiltration, as contrasted with Convention objective to suppress kinetic acts. Threat actors prefer to compromise the weakest link of the aviation chain, providing the largest attack surface, which are the digital assets of the aviation enterprise.

Although the main objective of the Beijing Convention is to "suppress the unlawful acts relating to international civil aviation [...] and jeopardize the safety and security of persons and property, seriously affect the operation of air services, airports and air navigation", the Convention currently provides no remedy against the expeditiously developing cyber threat landscape targeting international civil aviation.

---

1 International Civil Aviation Organization (ICAO), Convention on the Suppression of Unlawful Acts Relating to International Civil Aviation (Beijing Convention), Doc 9960, Beijing 2010.

2 R. Silver, Conducting Research After the 9/11 Terrorist Attacks: Challenges and Results, „Families, Systems, & Health“ 2004, Vol. 22, No 1, p. 45–51.

## Methodology

This paper examines the provisions and *ratio legis* of the Beijing Convention, that are implicitly addressing cyber threats, especially art. 1 par. 1 (d) and art. 1 par. 2 (b), focused on destroying or damaging air navigation or airport facilities. To show distinctiveness between the modern cyber threat environment facing the aviation industry and Convention scope, the paper provides an analysis of the authoritative reports to illustrate the paradigm shift from kinetic to cyber threats compromising digital assets of airlines.

To substantiate this thesis, the paper analyzes two case studies: the 2018 Cathay Pacific data breach and the 2022 Swissport ransomware attack and disruption of the airline ground services. These cases provide empirical evidence of attacks that, despite their severe impact, fall outside the Convention's scope. Following these case studies, the paper discusses the legal gap resulting from the Convention's misalignment with the current cyber threat landscape, as well as the implications for liability and international cooperation. The paper concludes with recommendations intended to restore the ability of the international civil aviation legal order to address these indicated threats.

The paper serves as an introduction for future considerations regarding international civil aviation law in the domain of suppression of aviation cyberthreats, and more thorough analysis is required.

The author's contribution is disclosing the most prevalent cyberthreats and proving that the provisions of the most recent international civil aviation law instrument are insufficient for preventing dissemination of cyberthreats in the aviation sector and consequently providing robust legal framework for such acts.

## Beijing Convention Provisions

The *ratio legis* of the Beijing Convention remains tethered to the security landscape of the early 2000s. Drafted as a direct countermeasure to the events of September 11, 2001, the Convention's provisions are circumscribed by the historical contingency of that era. The drafters' intent was to address the legal *lacunae* regarding the weaponization of aircraft, a focus that developed a regime tailored to the kinetic threats. Consequently, the resulting legislative intention and formulation of the provisions exhibit a fundamental misalignment with the modern threat landscape, offering remedies for physical sabotage while lacking the requisite elasticity to govern complex landscape of cyber threats.

The paper takes into consideration two Beijing Convention provisions, that implicitly address cybercriminal activities. The first provision, primarily understood to be penalizing cyber illicit activities, is established in Article 1(1)(d), which states that "person commits an offence if



that person unlawfully and intentionally [...] destroys or damages air navigation facilities or interferes with their operation, if any such act is likely to endanger the safety of aircraft in flight” shall face the criminal liability under the jurisdiction of the signatory state. Second regulation is Article 1(2)(b) according to which “Any person commits an offence if that person unlawfully and intentionally [...] destroys or seriously damages the facilities of an airport serving international civil aviation or aircraft not in service located thereon or disrupts the services of the airport” shall be held criminally liable under jurisdiction of the Convention party.

Pursuant to the first provision, there is a necessity to provide a definition of “air navigation facilities”, which are “signals, data, information or systems necessary for the navigation of the aircraft”. Provided definition is highly restrictive, specifically referring to critical operational technology (OT) that enables an aircraft to fly safely, such as the Global Positioning System (GPS), Air Traffic Control (ATC) communications and radar, Instrument Landing Systems (ILS), and other core navigational infrastructure. It does not, by any reasonable interpretation, extend to the broader information technology (IT) infrastructure of an airline, such as passenger reservation systems, customer databases, corporate email servers, or logistics management platforms, are not “air navigation facilities”.

Under the terms of Article 1(2)(b), it shall be outlined that the provision only provides a remedy for crimes against airport facilities, even though airlines, the usual objective of cyberattacks, are falling out of the scope. Also, the perpetrator of the activity must have an intent to destroy or damage facilities or disrupt its services. In case of cyberattack on the airline, there is no possibility to penalize such activity due to the absence of the *mens rea*.

## Shifting Cyberthreat Landscape – From Aircraft and Airport to Digital Enterprise

Authoritative industry and regulatory reports paint a clear picture of this evolution. The European Union Agency for Cybersecurity (ENISA), in its annual Threat Landscape report, consistently identifies the transport sector as a primary target. The dominant threats are not cyber-physical attacks but ransomware, phishing, and the exploitation of software vulnerabilities<sup>3</sup>. The impact of these attacks is overwhelmingly felt in ground systems and data repositories, leading to operational disruptions and data breaches, not in-flight emergencies.<sup>4</sup>

The International Air Transport Association (IATA) endorses this view, stating that the primary cyber threats to the airline industry involve stealing value in data or money and causing disruptions and harm<sup>5</sup>. IATA’s strategic response, the development of a comprehensive

3 ENISA (European Union Agency for Cybersecurity), *ENISA Threat Landscape 2025*, Heraklion 2025.

4 European Union Agency for Cybersecurity (ENISA), *ENISA Threat Landscape 2025*, Athens 2025.

5 IATA, *Aviation Cybersecurity Fact Sheet*, 2025.

Aviation Cybersecurity Strategy, a Security Management System (SeMS) Manual, and Cybersecurity Risk Assessment Guidance Material, reflects an industrial shift towards managing enterprise-level digital risks that are far broader than the narrow scope of the Beijing Convention<sup>6</sup>. However, actions taken by IATA and other relevant bodies should not be considered coincidental. Indeed, credible reports illustrate the crude reality of (cyber)incidents in the aviation industry and how cyberattacks have multiplied in the last few years, with the 530% increase of cyberattacks between 2019 and 2020<sup>7</sup> and about 600% between 2024 and 2025<sup>8</sup>.

A review of these incidents found that 71% of hackers were focused on stealing login credentials to gain access to IT systems, while 25% of attacks were Distributed Denial of Service (DDoS) campaigns aimed at disrupting online services<sup>9</sup>. Humans, the most vulnerable element of cybersecurity system, and software layers of the enterprise, due to offering the broadest threats landscape, are the most common target of cyberattacks, such as phishing, ransomware, and supply chain compromises that exploit vulnerabilities in third-party vendors. Methods mentioned are designed to infiltrate corporate networks and digital enterprise assets, not to interfere with the aircraft navigation and they don't damage or interfere with the operations of the airport, consequently falling out of the scope of the Beijing Convention.

The shifting cyberthreat landscape is the consequence of the application of different attack methods by adversaries, a rational response to the structure of the modern aviation industry. Ground-based systems have become the preferred target for several key reasons, that are the effect of much broader threat landscape. First, airlines are custodians of immense quantities of valuable information, including passenger personal identifiable information (PII), payment card data, passport data and detailed travel itineraries, making them a beneficial target for cybercriminals and a high-value intelligence source for state-sponsored actors<sup>10</sup>. Second the aviation ecosystem is a complex and deeply interconnected web of legacy and modern systems. This includes public-facing booking websites, internal reservation platforms, baggage handling systems, maintenance logs, and a vast network of third-party vendors for services ranging from food services, such as catering, to IT support<sup>11</sup>. The aviation sector can be described as an exemplification of the fundamental asymmetry between offensive and

<sup>6</sup> *ibidem*

<sup>7</sup> L. Florido-Benítez, The types of hackers and cyberattacks in the aviation industry, „Journal of Transportation Security“ 2024, Vol. 17, No 1, p. 1–32.

<sup>8</sup> Thales Group, 2025 Data Threat Report: Sovereignty and Sustainability in a Data-Driven World, Paris 2025, p.7.

<sup>9</sup> *ibidem*

<sup>10</sup> T. Elsner, C. Fuchs, B. Klein, W. Richter, How airlines should manage IT failures and security breaches to improve operational stability, McKinsey & Company, November 2019.

<sup>11</sup> Cockpit Innovation, Safeguarding the Skies: The Rising Battle Against Aviation Cyber Threats, 28 September 2025, <https://www.cockpitinnovation.com/aviation-news/news/safeguarding-the-skies-the-rising-battle-against-aviation-cyber-threats/>, [Accessed: 26 November 2025].



defensive cybersecurity, including their roles in performing their tasks effectively. Attackers need only to find a single weak link in this enterprise digital infrastructure, an unpatched server with existing vulnerability, a single employee falling for a phishing email, a vulnerability in a vendor's code, to gain access to the particular part or whole of the system. On the contrary, defenders must secure the entire, miscellaneous attack surface, including not only the most critical infrastructure, but also ensure the security of third-party vendors.

The Beijing Convention, by focusing exclusively on the most hardened and safety-critical in-flight systems, that are not the main target of the threat actors, completely ignores the currently most vulnerable ground-based system where the overwhelming majority of real-world attacks occur. In reference to criminal aviation law, it provides the provisions unable to respond to the currently emerging and existing threats, but only ones that were prominent in the past.

### **The Cathay Pacific Data Breach – The Unprotected Database**

The Cathay Pacific incident is a premier example of the Convention misalignment. On October 24, 2018, Cathay Pacific announced the discovery of unauthorized access to the personal data of up to 9.4 million passengers of the airline and its subsidiary, Cathay Dragon. The scale of the breach was immense, involving a wide array of sensitive information, including passenger names, nationalities, dates of birth, phone numbers, email addresses, physical addresses, passport numbers, Hong Kong identity card (HKID) numbers, frequent flyer program membership numbers, and historical travel information. Approximately 860,000 passport numbers and 245,000 HKID numbers were accessed, along with 403 expired credit card numbers and 27 credit card numbers without their CVV codes<sup>12</sup>.

Subsequent investigations, especially actions taken by United Kingdom's (UK) Information Commissioner's Office (ICO), revealed that the breach was not a single event but a persistent intrusion undetected for years, beginning as early as October 2014 and continuing until May 2018. The attackers gained access through a series of basic and preventable security failures. These included; unpatched vulnerabilities, lack of proper data safeguards, such as robust encryption systems, and insufficient access controls, such as Multi-Factor Authentication. Even though the airline confirmed that "The IT systems affected are totally separate from its flight operations systems and there is no impact on flight safety"<sup>13</sup>.

The impact of the incident was severe. For the 9.4 million affected passengers, the exfiltration of their personal and travel data created an immense and lasting risk of identity

---

<sup>12</sup> Cathay Pacific, Cathay Pacific announces data security event affecting passenger data, 24 October 2018, Available at: <https://news.cathaypacific.com/cathay-pacific-announces-data-security-event-affecting-passenger-data-250618>, [Accessed: 29 November 2025].  
<sup>13</sup> *ibidem*

theft, sophisticated phishing campaigns, and financial fraud<sup>14</sup>. The theft of detailed travel histories and passport information from a major international airline provides an undeniably useful source of intelligence for state-sponsored actors, who can use such data to track government officials, dissidents, journalists, and intelligence operatives.

For the airline, the consequences were substantial. Cathay Pacific faced a fine of £500,000 from the UK's ICO<sup>15</sup>, the maximum penalty possible under Data Protection Act of 1998, the law in effect before the General Data Protection Regulation (GDPR)<sup>16</sup> was implemented<sup>17</sup>. It needs to be outlined that penalty both maximum and levied on the Cathay Pacific was little in comparison to one resulting from art. 83 par. 5 of the GDPR. The airline also suffered severe reputational damage and a decline in investor confidence, with its share price falling after the announcement. The incident forced the company to invest heavily in overhauling its cybersecurity infrastructure and processes.

However, the Cathay Pacific case is out of the Beijing Convention scope. The breach didn't target the air navigation facilities<sup>18</sup>, but customer relationship management databases, the Active Directory for user authentication, and backup servers. Even though aforementioned system components are crucial for airline operations and its corporate infrastructure, they didn't endanger the aircraft safety according to art. 1(1)(d) or damaged the airport facilities if such act "endangers safety of that airport". Consequently, the persistent data exfiltration, which is undoubtedly jeopardizing the safety of international civil aviation, airlines and their beneficiaries (passengers), falls completely out of the Convention scope.

## The Swissport Ransomware Attack – The Disrupted Ground Services

The Cathay Pacific data breach is not an incident that solely exceeds in its nature the Convention scope. On February 3, 2022, Swissport International, a critical infrastructure operator within the global aviation supply chain, became the target of a sophisticated ransomware attack. Attributed to the "BlackCat" (ALPHV) ransomware group<sup>19</sup>, the attack

14 HKCERT, Security Advisory: Cathay Pacific and Cathay Dragon Passenger Data Breach, 25 October 2018. <https://www.hkcert.org/blog/security-advisory-cathay-pacific-and-cathay-dragon-passenger-data-breach>, [Accessed 25 November 2025].

15 M. Cowley, Cathay Pacific's data breach fine and what companies can learn from it, Integrity360, 13 March 2020, <https://insights.integrity360.com/cathay-pacific-data-breach-fine>, [Accessed: 24 November 2025].

16 European Parliament and the Council, Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, OJ L 119, 2016.

17 Government of the United Kingdom, The Data Protection (Monetary Penalties) (Maximum Penalty and Notices) Regulations 2010, Regulation 2.

18 Explained more thoroughly in the Introduction.

19 L. Abrams, Swissport claims BlackCat ransomware attack, hardly any disruption, „BleepingComputer“, New York 2022.



compromised the company's IT infrastructure, forcing the organization to terminate external connections and take affected servers offline to contain the spread of the malware.

The aforementioned action resulted in the immediate paralysis of digital planning and management systems across a network that serves nearly 300 airports worldwide. Impact on operations was noticeable, because Swissport provides essential ground handling services, including passenger check-in, baggage loading, and aircraft fueling. At Zurich Airport (ZRH) alone, the attack caused confirmed delays for 22 flights<sup>20</sup>. To maintain functionality, ground staff were forced to operate manually, leading to a significant reduction in the airport's throughput efficiency, consequently creating bottlenecks and operational chaos.

However, despite the widespread disruption to schedules and airport logistics, airport officials and Swissport management explicitly confirmed that critical flight safety systems remained unaffected and that at no point was the physical safety of passengers or aircraft compromised<sup>21</sup>.

When the facts of the Swissport incident are analyzed through the legal framework of the Beijing Convention, specifically Article 1(2)(b), the Convention fails to address modern operational sabotage. This provision establishes criminal liability for a person who unlawfully and intentionally "destroys or seriously damages the facilities of an airport... or disrupts the services of the airport." The *actus reus* of the Swissport attack constitutes an offence; by disabling the IT systems required for check-in and baggage handling and successfully and intentionally disrupting the services of the airport. However, the act does not fall under the Beijing Convention scope, by virtue of the fact that offence is only constituted if the act "endangers or is likely to endanger safety at that airport".

While one might argue that massive disruptions indirectly compromise safety through systemic risks such as crew fatigue, such causality is insufficient under the strict framework of international criminal law. Essentially, the prosecution cannot establish the required *mens rea*. Liability requires an intent, either *dolus directus* or *dolus eventualis*, to endanger the safety of an airport. Since threat actors, especially in the ransomware attacks, aim for financial extortion rather than physical harm, proving the encompassing of the secondary safety risks within intent is untenable.

In the case of Swissport, the paralysis of ground services caused significant economic loss, reputational damage, and passenger inconvenience, but it did not create a situation of physical danger to persons at the airport or for the airport facilities. Delay is not an occurrence jeopardizing the safety of the aircraft or the airport.

<sup>20</sup> Reuters, Hacker attack hits airport services provider Swissport with ransomware, London 2022.

<sup>21</sup> Swissport International, Statement regarding IT security incident, Zurich 2022.

## Implications of the Legal Lacunae

The legal lacunae highlighted by the analysis of the Convention and case studies indicate that the Convention legal framework is deficient for current cyberthreat landscape. Misalignment is not merely a scientific curiosity but also brings several consequences.

First, misalignment results in the lack of a universal "extradite or prosecute" framework for the most common types of aviation cybercrime. The Beijing Convention, similarly to the predecessors, including the Hague and Montreal Conventions, establishes a powerful obligation on State Parties to either extradite an alleged offender found in their territory or if the act is under the scope of their jurisdiction, or submit the case to their own authorities for prosecution. Because attacks such as Cathay Pacific and Swissport incidents are not covered by the treaty, there is no such binding international obligation in international civil aviation law. Perpetrators of these crimes can operate with greater impunity, knowing that international legal mechanisms responsible for holding them accountable are scanty or non-existent.

Even though there are international and regional law treaties that would cover by its scope the legal infringements presented in the case studies, not all Beijing Convention parties are parties of these treaties. Budapest Convention (BudConv)<sup>22</sup>, as the first legal mechanism of the Council of Europe (CoE), among their parties include mostly western countries, which excludes from the BudConv scope the biggest stakeholders, such as People's Republic of China and Russian Federation. Even though, as a "successor", UN Convention against cybercrime (HanoiConv, UN Convention)<sup>23</sup> is opened for the signature, there is no certainty which states would ratify and become bound by the treaty, consequently taking on obligations resulting from the UN Convention provisions.

Second, the absence of proper provisions leads to inconsistent and fragmented national responses. The response to aviation cyber incidents depends on national and regional legal regulations regarding cybercrime and data protection<sup>24</sup>. This fragmentation creates legal uncertainty for airlines, hinders cross-border investigations, and results in divergent degrees of protection for passengers worldwide. As some legal analyses have noted, this lack of a harmonized approach complicates liability allocation and enforcement, undermining the goal of a resilient international aviation system<sup>25</sup>.

Finally, the existence of the Beijing Convention may create a false sense of security. Policymakers and the public may incorrectly assume that the topic of "aviation cybercrime" is

22 Council of Europe (CoE), Convention on Cybercrime (Budapest Convention), ETS No. 185, Budapest 2001.

23 United Nations, Comprehensive International Convention on Countering the Use of Information and Communications Technologies for Criminal Purposes (Hanoi Convention), A/79/L.1, Hanoi 2025.

24 Q. Wang, *A Comparative Study of Cybercrime in Criminal Law: China, US, England, Singapore and the Council of Europe*, PhD thesis, Erasmus University Rotterdam, Rotterdam 2016.

25 M.O. Farooqui, A. Sarhan, F. Mustafa, *Aviation Cyber Security in India: Legal Gaps, International Frameworks, and Policy Reforms*, "Yustisia Jurnal Hukum" 2025, vol. 14, no. 2, p. 186–224.



adequately addressed by modern international civil aviation law regulations. Hence, perception may mask the need for a legal instrument that accurately reflects the digital reality of the 21st century, potentially delaying the legal and diplomatic measures required to close the gap.

## Conclusion

This paper demonstrates that the 2010 Beijing Convention, despite its importance as a counter-terrorism instrument, is an anachronistic tool in the fight against modern aviation cybercrime and is narrowly constructed around a "kinetic" paradigm, resulting from the 11 September 2001 attacks. By criminalizing only those cyber acts that target air navigation facilities and are likely to endanger the physical safety of an aircraft in flight, the Convention addresses a narrow scope of threats.

The misalignment, the core thesis of the paper, is substantiated by the clear and growing divergence between the scope of the legal regulations and the measures employed by modern adversaries. The Convention protects the cockpit, a symbol of 20th-century hijacking and terrorism. However, modern adversaries have shifted their focus to the core operations of airlines in the 21st century, especially ones executed by the IT systems. Attacks on these systems, as exemplified by the cases of Cathay Pacific and Swissport, can disrupt airline's operations, compromise millions of people's data, and pose threats to security without triggering the criminalization provisions of the Beijing Convention.

Consequently, legal lacunae appear, undermining international cooperation and the *aut dedere aut judicare* principle for the most common cyber threats directed at the aviation sector. The fundamental challenge for international law, therefore, is to evolve its definition of "aviation security." The concept must be expanded from the narrow protection of the aircraft and the airport to a comprehensive and modern understanding that encompasses the security, integrity, and resilience of the entire digital ecosystem upon which international aviation currently depends. The security of the airline as a digital enterprise is no longer a secondary commercial concern, but a primary component of overall aviation security. Protecting the cockpit is no longer sufficient when the primary targets of the adversaries are the database and the whole digital enterprise.

In order to prevent fragmentation and respond effectively to the current cyberthreat landscape, the International Civil Aviation Organization (ICAO), with its member states, shall initiate a process to develop a new legal instrument. This could take the form of either:

- A Supplementary Protocol to the Beijing Convention: This protocol would specifically address data-centric and operationally disruptive cybercrimes, creating new offences for acts such as the large-scale, intentional theft of passenger data from an airline's systems or the malicious disruption of an airline's core commercial and logistical operations.
- A new Standalone Treaty on Aviation Cybersecurity or treaty serving similar purpose

to Beijing Convention but is prevailing for modern threat landscape: This approach would allow for a more comprehensive and purpose-built framework, addressing not only criminalization but also setting standards for preventative security measures, incident reporting, and international information sharing tailored to the unique aviation environment.

Regardless of the form, this new legal instrument shall address cybercrimes such as large-scale data theft and intentional operational disruption, consequently broadening the scope of international civil aviation law to strengthen the legal framework intended to suppress criminal acts against international civil aviation. Only by taking the necessary measures, including those indicated in this section, can the international community ensure that the legal framework for aviation security is as modern and resilient as the threats it is intended to defeat.

## Literature

- Cathay Pacific, Cathay Pacific announces data security event affecting passenger data, 24 October 2018.
- Cockpit Innovation, Safeguarding the Skies: The Rising Battle Against Aviation Cyber Threats, 28 September 2025.
- Council of Europe (CoE), Convention on Cybercrime (Budapest Convention), ETS No. 185, Budapest 2001.
- M. Cowley, Cathay Pacific's data breach fine and what companies can learn from it, Integrity360, 13 March 2020.
- CybelAngel, Aviation Threat Report 2025: The Rise of Extortion, Paris 2025.
- Data Protection Act 1998, The National Archives of the United Kingdom, London 1998.
- T. Elsner, C. Fuchs, B. Klein, W. Richter, How airlines should manage IT failures and security breaches to improve operational stability, McKinsey & Company, November 2019.
- ENISA 2025 Threat Landscape report highlights EU faces escalating hacktivist attacks and state-aligned cyber threats, „Industrial Cyber“, 3 October 2025.
- European Parliament, Council of the European Union, Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, OJ L 119, 2016.
- European Union Agency for Cybersecurity (ENISA), ENISA Threat Landscape 2024: Transport Sector, Athens 2024.
- European Union Agency for Cybersecurity (ENISA), ENISA Threat Landscape 2025, Heraklion 2025.
- M. O. Farooqui, A. Sarhan, F. Mustafa, Aviation Cyber Security in India: Legal Gaps, International Frameworks, and Policy Reforms, „Yustisia Jurnal Hukum“ 2025, vol. 14, No. 2.
- L. Florido-Benítez, The types of hackers and cyberattacks in the aviation industry, „Journal of Transportation Security“ 2024, Vol. 17, No 1, p. 1–32.
- HKCERT, Security Advisory: Cathay Pacific and Cathay Dragon Passenger Data Breach, 25 October 2018.
- Information Commissioner's Office (ICO), Penalty Notice: Cathay Pacific Airways Limited, Reference: COM0806337, Wilmslow 2020.
- International Air Transport Association (IATA), Aviation Cybersecurity Fact Sheet, 2025.
- International Air Transport Association (IATA), Aviation Cybersecurity Strategy, 2023.
- International Air Transport Association (IATA), Security Management System (SeMS)





- Manual, 7th Edition, Montreal 2024.
- International Civil Aviation Organization (ICAO), Convention on the Suppression of Unlawful Acts Relating to International Civil Aviation (Beijing Convention), Doc 9960, Beijing 2010.
- Reuters, Hacker attack hits airport services provider Swissport with ransomware, London 2022.
- R. Silver, Conducting Research After the 9/11 Terrorist Attacks: Challenges and Results, „Families, Systems, & Health“ 2004, Vol. 22, No 1, p. 45–51.
- Swissport International, Statement regarding IT security incident, Zurich 2022.
- Thales Group, 2025 Data Threat Report: Sovereignty and Sustainability in a Data-Driven World, Paris 2025.
- The Data Protection (Monetary Penalties) (Maximum Penalty and Notices) Regulations 2010, Regulation 2, Government of the United Kingdom.
- United Nations (UN), Comprehensive International Convention on Countering the Use of Information and Communications Technologies for Criminal Purposes (Hanoi Convention), A/79/L.1, Hanoi 2025.
- Q. Wang, A Comparative Study of Cybercrime in Criminal Law: China, US, England, Singapore and the Council of Europe, PhD thesis, Erasmus University Rotterdam, Rotterdam 2016.

CONFIDENTIAL:  
FOR PEER REVIEW ONLY



**Manuscript body**

[Download source file \(78.05 kB\)](#)

CONFIDENTIAL:  
FOR PEER REVIEW ONLY



# Quantum Cybercrime: Challenges in the Age of Advancing Quantum Computing Across the European Union, United States of America, and People's Republic of China

Katarzyna Badźmirowska-Masłowska  and Wiktor Wilkołaski  

War Studies University, 00-910 Warsaw, Poland  
[wiktor042004@gmail.com](mailto:wiktor042004@gmail.com)

**Abstract.** The imminent development in the field of quantum computing threat has the potential to undermine current cryptographic protections, enabling new forms of cyberattack (e.g., 'store now, decrypt later' strategies) and magnifying liability issues for governments, companies, and individuals. The paper examines how existing criminal and civil liability frameworks in the European Union, United States, and China address cybercrime in general and assesses their adequacy in a post-quantum environment. Drawing on legal sources (penal codes, directives, conventions, statutes) and scholarly commentary, this paper compares the substantive offenses (unauthorized access, data interference, misuse of devices, etc.), enforcement mechanisms, and tort-like duties in each legal system. The paper considers the role of encryption-related regulation (export controls, mandatory standards), and corporate accountability rules. The conducted research highlights both commonalities (for example, criminalization of hacking and malware in all systems) and divergences (such as the emphasis of the EU on cross-border cooperation versus the approach of China's cyber sovereignty). Although entities taken into account recognize the core cyber offenses, few legal provisions explicitly contemplate the quantum threat or impose duties to adopt quantum-safe measures. In conclusion, a state of preparedness for the coming era is considered along with recommendations for areas needing reform, such as new statutory duties to upgrade cryptography and enhanced international cooperation.

AQ1

AQ2

**Keywords:** post-quantum cryptography · cybercrime · liability · cyber law · quantum computing

## 1 Introduction

Brisk advances in quantum computing are poised to render many widely used cryptographic systems (Rivest–Shamir–Adleman cryptosystem (RSA), and



Elliptic Curve Cryptography (ECC), etc.). In anticipation, security experts warn that malicious actors could harvest encrypted data now and decrypt it later, or that nation-state adversaries might break current encryption in real time. Recent milestones, such as the enactment of the Cryptography law in 2019 in China [1] and the finalization of its PQC standards in July 2023 by the US National Institute of Standards and Technology (NIST) [2], accentuate the narrowing lacunae for legal adaptation. According to the timeline prepared by Alliance for Telecommunications Industry Solutions, there is a conservative estimate that full-scale quantum computers capable of breaking RSA and ECC are anticipated around 2035, which is also a date when NIST guides the adoption of quantum-resistant encryption [3]. The indicated year 2035 is also estimated by other relevant bodies, including the Global Risk Institute. Post-quantum threats have esoteric legal implications. The advancement of quantum computing will affect the substantive definition of cybercrimes, the obligations of companies and individuals (e.g., the duty to implement quantum-resistant encryption), and the strategies of prosecutors and regulators.

In particular, questions arise about liability: Who can be held responsible when quantum attacks succeed, and under what theory? May legal or natural persons be found negligent for failing to migrate to quantum-resistant systems? Do current legal regulations adequately capture newly feasible attacks? This paper provides a comparative analysis of liability frameworks in the European Union (EU), United States (US, U.S.) and China focusing on cybercrime and encryption in a post-quantum context. It should also be mentioned that this paper does not offer a detailed analysis but rather outlines the contours of the problem, serving as a basis for further discussion.

We emphasize criminal law regulations and note tort or regulatory liability only when it directly intersects cybercrime (such as negligence or data breach suits). We review key legal instruments, Chinese Criminal Law [4] (ChiCri) and Civil Code [5] (CC); the Budapest Convention (BudConv) [6], EU Directive 2013/40/EU (Directive on Attacks against Information Systems) [7], the NIS2 Directive [8], and the Cybersecurity Act [9]; US federal statutes (e.g., the Computer Fraud and Abuse Act (CFAA) [10], Electronic Communications Privacy Act (ECPA) [11], export controls on cryptography). Each approach is presented in turn, followed by a comparative discussion underlining similarities, differences, and the inevitability of amendment in the face of quantum threats. Our aim is to assess the suitability of the aforementioned legal system's for a future in which powerful quantum computers can break classical encryption standards. The paper is a beginning point for research related to legal liability linked to threats posed by quantum computing.

## 2 Methodology

As we mentioned, this paper offers a general overview of the topic through comparative legal analysis, serving as a contribution to ongoing discourse rather than a detailed evaluation. The aforementioned is necessary to take on upcoming legal

challenges related to quantum computing. For each approach (selected for geopolitical and cyber relevance), we identify and examine the primary sources governing cybercrime and related liability. Quantum cybercrime, in general sense, shall be defined as unlawful activity, which characteristic trait is the use of processing power of quantum computing to commit. Currently we are in the age of advancing quantum computing, which will in the future bring challenges for both legal and technical matter, especially in creating non-existing cyber threats or enhancing currently present such as quantum identity theft, permitting threat actor to use quantum Artificial Intelligence (AI) to parse biometric data (faces, fingerprints, voice patterns) from images or recordings with unprecedented accuracy, enabling highly convincing identity fraud or account takeovers, coordinating large-scale, adaptive phishing campaigns with the use of quantum computing making low-rate spam into self-assessing and intelligent scam or using computational power to break currently existing algorithms, which in the future would not be quantum-proof by using “Store Now Decrypt Later” (SNDL) strategies. Advanced quantum computing may also be able to launch large-scale cryptanalysis, leading to real-time eavesdropping (by simultaneously breaking the session securing keys). As a major threat, organized (cyber)crime groups should be outlined that by acquisition or renting of the quantum computer or quantum cloud services would massively scale up their ability to broaden their scope to commit financial crimes by bypassing any existing encryption on financial networks, raid banks, or drain cryptocurrency wallets and consequently obtaining currency or value stored in the account. The mentioned cybercrime groups may try to bribe personnel with access to quantum computers and consequently getting possible backdoors, obtaining cryptographic keys, or leaking sensitive computational information. We consider penal code provisions on computer-related offenses, any specialized cybercrime statutes, and relevant civil or regulatory laws (data protection, cybersecurity, encryption controls). In the EU context, we include directives/regulations - concerning at the matter of advancing technological development, while noting that criminal law is still primarily national. As regards to the Council of the Europe (CoE) we consider Budconv. Secondary sources (law- review articles, government reports, expert commentary) are consulted to clarify statutory interpretation and enforcement. We rely on official translations or EU documents for EU law, and on authoritative analyses for US and Chinese law. Throughout, we pay particular attention to provisions that may be relevant under post-quantum conditions, such as rules on encryption and data-security obligations, even if the statutes predate quantum computing. Finally, a comparative section synthesizes the findings, contrasting how each system construes cyber liability and highlighting potential gaps or conflicts as quantum threats emerge. While doctrinal analysis of conventions, directives and statutes informs our comparative method, recent practitioner roadmaps underscore the practical challenges of full migration. Computing Research Association’s January 2025 Quad Paper warns that, despite NIST’s finalized algorithms, widespread integration across legacy systems may not complete until after 2030 [12].

### 3 The European Union

#### 3.1 Overview of EU Cybercrime Policy

The EU has long pursued cybersecurity and cybercrime through international cooperation (notably the CoE BudConv of 2000) and its own legislative instruments. The BudConv sets model offences and procedural tools, which influence EU and national laws. Under the Convention, signatories must criminalize cybercrimes such as unauthorized access to computer systems, data and system interference, unauthorized interception of communications, misuse of devices and tools, and certain fraud and forgery with the use of computer. It also requires criminal liability for attempts and aiding or abetting in the Article (Art.) 11 and provides for corporate liability (Art. 12). Therefore, EU law often mirrors the Convention's offence structure, supplemented by EU-specific rules where competence allows. As we said, within the EU legal order, primary competence for criminal law remains within competence of Member States. However, the EU has enacted directives mandating uniform definitions for certain crimes and minimum penalties, such as the Directive on attacks against information systems [7]. Cited Directive obliges States to criminalize, at least for non-minor cases, unauthorized access, illegal system interference, illegal data interference (deleting, damaging, deteriorating, altering or suppressing computer data or rendering such data inaccessible), illegal interception of non-public transmission of computer data to or from information system, and related inchoate offences (providing tools, attempts, aiding). For example, Art. 3 requires intentional "access without right" to whole or any part of an information system to be considered a crime. Art. 7 criminalizes production, sale, procurement for use, import, distribution, or otherwise making available tools (malware, passwords), intended for such offences. The member states must impose effective, proportionate, and dissuasive penalties. This Directive ensures a consistent baseline across the EU for common forms of cyber intrusions. While the Directive harmonizes certain aspects of substantive criminal law across the EU, almost all (except Ireland due to lack of ratification of the BudConv) Member States have also aligned their domestic frameworks with the standards set out in the BudConv. This multi-lateral treaty, which predates most EU instruments in the cybercrime domain, serves as the foundational international instrument for addressing offenses committed against or through information systems. The BudConv text provides comprehensive procedural and substantive legal norms, including obligations for the criminalization of illegal access, data and system interference, and misuse of devices, as well as guidelines for international cooperation and investigative powers. Its implementation into national legal systems supplements EU-level obligations by promoting convergence not only within the Union but also with non-EU signatory states, thereby enhancing cross-border enforcement capabilities and legal interoperability in combating cybercrime.

Beyond substantive cybercrimes, the EU has enacted a range of cybersecurity policies. The 2016 Network and Information Security Directive [13] (NIS 1) and its successor NIS 2 focus on the resilience of critical infrastructures. NIS 2, which came into force in January 2023, expands the scope to many sectors (energy,

health, finance, transport, digital services, etc.) and imposes risk-management obligations and incident reporting requirements on operators of essential services. Importantly, NIS2 introduces personal accountability: legal and natural persons can be held liable (fines) for non-compliance with cybersecurity measures. It also requires Member States to criminalize serious breaches. In addition, the EU Cybersecurity Act [9] established a framework for EU-wide cybersecurity certification of ICT products and gave the EU Agency for Cybersecurity (ENISA) a permanent mandate. Although certification is voluntary, according to art. 56 par. 2 of Cybersecurity Act, it aims to raise security standards and increase user trust. None of these instruments explicitly mentions post-quantum threats, but they illustrate a trend toward robust security requirements. The EU also has strong data protection rules under the General Data Protection Regulation [14] (GDPR), which impose strict obligations on data controllers and processors to safeguard personal data. Under GDPR, failure to protect data (e.g., by using strong encryption) can trigger administrative fines and civil liability. This creates *de facto* a duty of care: an organization operating in the EU, that fails to implement “state-of-the-art” encryption and then suffers a quantum-enabled breach, could face enforcement action or lawsuits under GDPR (cf. Court of Justice of the European Union (CJEU), *Schrems II*, C-311/18, on adequacy of data protection standards). Indeed, GDPR Recital 39 exhorts adopting “measures like encryption” to prevent breaches. Also, according to *Schrems II*, the Grand Chamber of the CJEU held, that before transferring personal data, organizations must assess whether the recipient country provides adequate “data protection rules, professional rules and security measures.” This adequacy assessment, detailed in the 13th part of the judgment, ensures that transferred data enjoys protections equivalent to those under EU law. In post-quantum era, the notion of “adequate security measures” may be strongly hard to define, especially with swift quantum computing development. There is room for question whether company, which wouldn’t implement the proper security measures, could be found responsible for not implementing “adequate security measures” even if availability of these measures would be limited. What should be according to these more prioritized: security of natural person data or not overly sanctioning non-complying processors and controllers? Although GDPR is primarily regulatory, it intersects civil liability: for instance, Art. 33 requires notification of personal data breaches (which might include decryptions by quantum adversaries), and Art. 82 provides a private right to claim compensation for damage caused because of incident related to personal data. Therefore, EU law creates both criminal sanctions for cyber intrusions (via the Convention of the CoE and related directives) along with administrative and civil liability for failing to secure systems. Even though tort law is always regulated in the domestic law, the EU can influence its shape.

### 3.2 EU Criminal Liability for Cybercrimes

In practice, EU Member States’ national laws implement the BudConv and the Directive on Attacks against Information Systems. Common offences under EU

cyber crime law include illegal access (black-hat hacking), illegal interception (wiretapping or packet sniffing without consent), and system interference (malware, DDoS, zero-day exploits). Other offences cover the use of illicit devices (e.g. USB drops), IT-related fraud and forgery, and the distribution of child sexual abuse regulated separately by Directive 2011/93/EU [15]. In the matter of financial crimes, including cybercrimes too, as the main legal regulation should be considered Directive (EU) 2019/713 on Combating Fraud and Counterfeiting of Non-Cash Means of Payment [16]. For example, criminalize “unauthorized access” to any computer system or network by defeating security measures. In some countries (e.g., Germany, France), penalties escalate if the intrusion endangers critical infrastructure. Distributed denial-of-service attacks fall under system interference provisions (similar to Art. 4 of BudConv). Notably, the BudConv’s corporate liability provision of Budconv (Art. 12) has influenced some Member States to allow fines and other sanctions on companies that ease these crimes (e.g., failing to stop known malware distribution). EU law also criminalizes preparatory activities: Art. 7 of the Directive (Tools used for committing offences) obliges member states to punish the creation or dissemination of malware or hacking utilities. Art. 8 mandates punishment for attempts and aiding/abetting, ensuring that “inchoate” forms of cybercrime are covered. These provisions, though silent on quantum per se, are broad enough to capture quantum-accelerated hacking once applied.

As cybercrimes cross borders, the EU relies on judicial cooperation. Eurojust (EU Agency for Criminal Justice Cooperation) and the European Cybercrime Centre (EC3) at Europol are main entities delegated to carry out joint investigations [17]. EU Member States have also begun transposing BudConv’s 24/7 network (Art. 35) for swift cross-border preservation of electronic evidence. The EU is also pushing towards international solutions: for instance, a draft United Nations (UN) cybercrime convention [18] will be open for signature from the October 2025 to the 31st of December 2026 [19], but concerns about authoritarian misuse remain. In the meantime, the EU’s approach has been collaborative: in April 2024 the European Commission issued the “Commission Recommendation (EU) 2024/1101 of 11 April 2024 on a Coordinated Implementation Roadmap for the Transition to Post-Quantum Cryptography (PQC)”. Such policy signals suggest that EU legal standards may evolve to impose affirmative duties (e.g. encryption upgrades) – a shift from past law which mainly penalized bad acts. This act also will force taking into consideration new potential threats related to PQC and consequently probable new regulations in the sphere of cybercrimes committed using quantum computing, which would not be known for classical bit computers.

In summary, the EU’s criminal framework for cybercrime is comprehensive and convention-driven, criminalizing hacking, malware, data breaches, and related conduct in accordance with international norms. Civil/regulatory measures (NIS2, GDPR) layer on corporate and managerial liability for security failures. However, this framework was designed for classical threats and generally does not explicitly anticipate quantum capabilities. For example, no EU law



currently penalizes using quantum technology as a measure used in an attack as such; rather, any resulting acts (data theft, etc.) fall under existing offences. Likewise, there is no existing civil obligation to switch to quantum-resistant algorithms. A key question is whether failing to upgrade encryption could itself be treated as negligence or a breach of law in this more dangerous environment (under tort or regulatory liability).

## 4 The United States

### 4.1 Federal Cybercrime Statutes

In the US, cybercrimes are prosecuted under a mix of federal statutes and state laws. The centerpiece is the CFAA, codified at 18 U.S.C. § 1030. The CFAA criminalizes various forms of computer misuse, notably unauthorized access to “protected computers” (which broadly includes federal, bank, and any Internet-connected computer). It covers “trespass”-style hacking even with absence of the extra consequences and punishes aggravated cases (access to obtain or causing damage to governmental or financial information) more severely. In practice, prosecutors use the CFAA for offenses such as hacking into networks, planting malware, or stealing data. The broad language of the CFAA allows liability for any intentional unauthorized access or exceeded authorized access if it “obtained information” or caused damage. Recent case law (e.g. *Van Buren v. US* (2021), where the Supreme Court of The United States held that violating internal policy is not ‘unauthorized access’ under CFAA) [20] has narrowed its scope by distinguishing civil breaches of terms of service from true computer trespass, but the statute remains potent against malicious hackers.

Alongside the CFAA, the ECPA of 1986 [21] and the Wiretap Act [22] prohibit the illegal interception of electronic communications and the unauthorized access to stored communications. In broad terms, the Wiretap Act bans intentional interception of wire, oral, or electronic communications. The 18 U.S.C. §§ 2701–2712 of 1986 [23] (Stored Communications Act) criminalizes unauthorized access to stored emails or other data. Therefore, ECPA complements CFAA by targeting espionage-like activities (sniffing data packets, tapping VoIP, accessing emails in transit). The penalties are severe: individuals can be imprisoned up to five years and fined up to \$250,000 for ECPA violations, and victims may sue for actual and punitive damages. In particular, unlike CFAA, ECPA provides an explicit civil cause of action for privacy violations (see § 2520), making it a tort-like remedy. The US also has statutes criminalizing computer-related fraud and identity theft (e.g. 18 U.S.C. §§ 1028 [24], 1343 [25]) that often apply to cyber schemes. For instance, using a hacked computer to commit wire fraud (transfer of funds, identity fraud) is simultaneously a violation of anti-fraud statutes. But CFAA/ECPA are the core “computer crime” laws. Federal entities (Department of Justice, FBI) and regulatory agencies (e.g. Securities and Exchange Commission (SEC) if financial data is involved) enforce these provisions vigorously [26, 27].

Importantly, the CFAA does not address encryption or quantum explicity. There is no federal obligation for companies to implement specific cryptographic standards. However, US law does regulate encryption in two ways: export controls and law enforcement access. On the export side, strong encryption was long a munition under the International Traffic in Arms Regulations (ITAR), later moved to Commerce's Export Administration Regulations (EAR). Today, EAR (15 C.F.R. § 740.17 and elsewhere) [28] requires exporters of certain encryption products to file notifications or obtain licenses. In practice, most dual-use encryption software, especially "strong" cryptography, is controlled and requires a license exception to export. The Stanford guide notes that "almost all dual-use encryption software... is subject to EAR", and that even publicly available strong crypto must use a License Exception ENC [29] (Encryption Commodities, Software and Technology) to ship it out of the US. These rules reflect the US interest in retaining strategic advantage. However, export controls do not criminalize domestic use of any encryption, quantum, or otherwise; they simply restrict cross-border transfer.

In terms of law enforcement access, the US has no general "key escrow" or backdoor law. The Communications Assistance for Law Enforcement Act [30] (CALEA) mandates telecom carriers to assist in wiretaps, but excludes services such as social media. There have been proposals (and some laws for specific sectors) to require access to encrypted data for authorized agencies, but none currently target end-to-end encryption broadly. Instead, the US government's approach is to push technology vendors to harden systems (e.g., in mandates for federal agencies to adopt PQC) rather than weaken crypto standards.

## 4.2 Liability and Enforcement

Under US law, intentional cyber intrusions are punished as crimes (CFAA, ECPA and others). Criminal penalties under CFAA can range from fines to imprisonment, depending on factors such as intent, loss amount, and criminal record. For example, simple unauthorized access with no harm may be a misdemeanor, whereas causing damage worth more than 5000 dollars or persistent effects can be classified as a felony with up to 10 years or more imprisonment. It is up to the prosecutors to prove intent "to defraud" or "to cause damage" as defined under many subsections. In practice, high-profile prosecutions have targeted denial-of-service attacks, theft of proprietary code, data breaches, and identity theft. The broad scope of CFAA also covers "trespass by code" – e.g., using malware or bypassing passwords. In addition to state criminal liability, US victims can often pursue civil claims after a cyber incident. Although the CFAA itself is primarily criminal, 18 U.S.C. § 1030(g) provides a narrow civil remedy against a person who "causes damage or loss" through a violation, but actual use is rare. More commonly, victims rely on theories of state law, such as negligence, conversion, or breach of privacy. In addition, they may seek a remedy under federal statutes, including laws specifically targeting identity theft. For example, if a company is hacked due to inadequate security, affected customers may sue for negligence or breach of implied contract in some states. The Federal Trade

Commission (FTC) can also penalize companies for failing to “reasonably safeguard” personal data [31], treating it as an unfair practice. Therefore, there is an emerging tort-like duty to protect data and systems, even if not codified. Notably, in threatened post-quantum scenario, a company ignoring known vulnerabilities (e.g. not upgrading to quantum-resistant algorithms) could arguably face liability under these theories if it leads to harm. Some commentators have begun to discuss the notion of cyber negligence related to quantum computing, although no court has squarely addressed the “failing to upgrade encryption” yet. A recent legislative development is the US government’s push for agencies (and, by extension, contractors) to prepare for PQC. For instance, Congress mandated in the 2022 National Defence Authorization Act that federal agencies adopt quantum-resistant encryption by certain deadlines [32]. While not a criminal law, this kind of requirement could create future enforcement triggers (e.g. deeming it a crime or basis for sanctions if a federal system is compromised due to outdated crypto). However, as of now, US cyber law is technology neutral: quantum computers used by criminals would simply make existing statutes easier to apply (an attacker using a quantum computer to break encryption is still “accessing without authorization” or “intercepting communications” if the result is obtaining data). Therefore, the core liabilities (CFAA, ECPA) remain applicable regardless of the technology used by the attacker.

### 4.3 Encryption Controls and Crypto-Specific Regulation

While not punitive, U.S. regulation of encryption is relevant to liability. As noted, the EAR classifies strong cryptography as dual-use: exporters generally must notify the Bureau of Industry and Security (BIS) and may use License Exception ENC for most items. Failure to comply with the EAR rules can lead to civil penalties or criminal charges by the Commerce Department, although such cases are rare (enforcement tends to focus on sanctions violations). US law does not criminalize merely possession or use of weak cryptography domestically. Therefore, in theory, U.S. citizens are free to deploy and even research quantum-resistant algorithms without licensing. This contrasts with places like China (below) that tightly regulate even the internal use of encryption products.

One emerging intersection of law and technology is the Wassenaar Arrangement on Export Controls for Conventional Arms and Dual-Use Goods and Technologies (Wassenaar Arrangement) [33], of which the US is a member. Wassenaar periodically updates the encryption controls. U.S. export rules generally follow those multilateral agreements. In 2014, the U.S. greatly relaxed export controls on mass-market encryption and open-source software, reflecting confidence in the global diffusion of crypto. It is conceivable that a future Wassenaar update (driven by post-quantum concerns) could impose new export restrictions on quantum computing or PQC devices; the US has already begun negotiations to control “quantum computers” as emerging technologies [34]. If adopted, US companies dealing in quantum technology would face new compliance burdens, and exporting a quantum decryption tool without a license may violate export laws. However, no such control is yet in force.

#### 4.4 Tort and Agency Liability

Turning to liability beyond civil law related to actions done with unwilful or willful misconduct, U.S. law recognizes “negligent security” claims in state courts. For instance, a retailer hacked because it used weak encryption might be sued by customers for failure to safeguard data (negligence/breach of implied contract). Some US states have allowed such suits, while others (or federal appeals courts) have been skeptical absent physical harm or a special relationship. But importantly, many US companies (especially public ones) also face regulatory liability: the SEC can fine companies for inadequate cybersecurity disclosures, and Health Insurance Portability and Accountability Act [35] (HIPAA) can impose penalties for breaches in the healthcare sector. These are more analogous to the EU’s administrative sanctions than to criminal law ones. The major technological shift could lead regulators to view the failure to adopt quantum-resistant cryptography as a foreseeable risk and a breach of their responsibilities. This could result in enforced penalties or other regulatory actions in the future. At present, however, U.S. law only hints at this through general duties of care; no statute specifically mandates PQC compliance yet.

### 5 People’s Republic of China

#### 5.1 Chinese Criminal Law and Cyber Offences

China’s approach to cybercrime and encryption is shaped by concerns about state security. The Criminal Law of the People’s Republic of China contains several provisions specifically addressing computer crimes. Art. 285–287, in particular, define the core cyber offences. Art. 285 criminalizes intrusions into protected computer systems, especially those involving state secrets or national defence. It prescribes imprisonment up to 3 years for violating state regulations to intrude into certain networks (state affairs, defence, science). Art. 286 criminalizes interference with computer systems: for example, deleting or altering data causing “abnormal operation”, as which should be classified most of existing cyberattacks or actions such as SQL injection and altering input data to exploit buffer overflows. A malicious act (such as a virus attack) that sabotages a system can result in up to 5 years of imprisonment or more if consequences are serious. Art. 287 covers using computers to commit other crimes (fraud, theft, stealing state secrets, etc.), essentially importing traditional crimes into the digital domain. These provisions have been interpreted broadly: China’s Supreme People’s Court and Ministry of Public Security have clarified that “state regulations” in art. 285–287 include all cyber-related administrative rules, effectively extending coverage to private networks as well [36].

In 2016, China enacted the Cybersecurity Law (CSL) [37], which imposes administrative obligations on network operators (data localization, registration of real names, security assessments) rather than defining new crimes. Offenders violating CSL provisions (e.g. spreading malware) can face criminal punishment under the Penal Code. The CSL also requires critical information infrastructure

operators to undertake security measures; failure may attract penalties, though these are administrative fines or license revocations by regulators, not new criminal offences.

Notably, ChiCri imposes harsh penalties for breaches affecting national security. In practice, cybercrime cases with political implications (espionage, national secrets) are tried under state security provisions. There is also a broad anti-espionage law that could theoretically cover advanced decryption attacks. However, no Chinese criminal statute specifically addresses encryption or quantum technologies. A hacker using a quantum computer to break encryption would simply be prosecuted for “sabotaging” the system or stealing data under Art. 286–287.

## 5.2 Encryption Regulation and Liability

Distinctively, China has solid encryption regulation. In 2019 China enacted the Cryptography Law (CL) [1], effective January 2020, which mandates registration and obtaining certification for encryption products, classifies encryption into “core, ordinary, and commercial,” and frames encryption as a matter of state secrecy. All “core” and “ordinary” encryption (used for state secrets) is itself deemed state secret and strictly controlled. “Commercial” encryption (for general use) can be used to protect data but is subject to import/export licensing and testing. The law therefore regulates Chinese and foreign companies providing encryption technology, but it does not criminalize the mere possession of encryption algorithms by individuals. Instead, unauthorized disclosure or illegal use of encryption keys or backdoors can trigger administrative sanctions by the Cyberspace Administration. As a result, encryption policy in China is top-down and centralized, in contrast to the more liberal US policy.

China’s emerging privacy laws also bear on liability. The Civil Code recognizes personal rights, including privacy and personal information [38]. Art. 1034–1039 of the CC, for example, protect personal data: collection must be lawful and with consent, and violators can be civilly liable for damages. A data breach (whether caused by a quantum-enabled hack or not) can therefore give rise to tort liability. Moreover, the recent Personal Information Protection Law (PIPL, 2021) [39] (similar to the idea of GDPR) imposes data security duties on data processors. While PIPL is civilly liable/regulatory, violation (such as failing to protect data with adequate encryption) can lead to fines and even criminal liability under Art. 282 of ChiCri (illegally obtaining or providing personal data). Therefore, China’s system mixes criminal statutes for outright hacking (Criminal Law) with regulatory liability for data protection failures (in the CSL, PIPL). In theory, a company that neglects to upgrade encryption and causes a breach could be fined or have licenses revoked, or managers held “negligent” under broad national security statutes. However, the threshold for punishing corporate negligence is high, and most enforcement is done via fines, not prison.



### 5.3 Enforcement and Social Context

The enforcement of cybercrime laws in China is carried out by the Public Security Bureau (PSB) and the Ministry of State Security. Historically, China has pursued both domestic hackers and extraditions for overseas offenders. However, foreign victims of Chinese cybercrimes have had limited recourse outside of diplomatic channels. China's focus has been on protecting state systems and combating fraud; it also aggressively prosecutes "rumourmongering" on the Internet as a cyber offense under different laws. The social environment emphasizes collective security. Citizens are expected to follow government censorship and control policies, and companies must cooperate with surveillance. This stands in contrast to Western norms of individual privacy.

In summary, China's criminal framework criminalizes the main cyber offences (hacking, malware, data theft) under Art. 285–287, but with an overlay of state security priorities. Its civil regime adds a layer of data protection responsibility. In the post-quantum context, the critical question is how these laws would apply if encrypted data were stolen en masse. Under current law, a quantum-enabled hack of personal data could be treated as "stealing data" (ChiCri) and as a failure to protect privacy (CC/PIPL). There is no express duty to migrate to new crypto standards, but when considering China's top-down encryption policy and technocratic governance, it can be determined that it is a matter of time that new regulations or standards are issued on quantum-resistant cryptography (indeed, Chinese researchers have already proposed national PQC algorithms). The CL could be interpreted to require the certification of quantum-resistant algorithms once they exist, under the "banner" of national security. Therefore, while the legal framework currently does not mention quantum, its flexible structure (and the Communist Party's direct control) would allow for a brisk legal adaptation, including making PQC compliance mandatory in sensitive sectors.

## 6 Comparative Discussion

In this part entities of international law referred to in the paper (EU with its secondary legal capacity and states: USA, China) are compared across several dimensions: substantive crimes/offences, cryptography rules, tort or civil liabilities, and enforcement/corporate accountability.

In the domain of cybercrime liability, all four systems criminalize unauthorized access, data theft, system interference, and malware (although legal terms vary). The EU (via BudConv and Directive 2013/40) lists the above-mentioned offences. The US CFAA/ECPA cover similar ground (prohibiting unauthorized access and interception). ChiCri has provisions for hacking (Art. 285) and sabotage (Art. 286). Therefore, despite different legal traditions, there is convergence in punishing the classic cyberthreats. Inchoate offences (attempts, aiding) are generally covered as well BudConv Art. 11, EU Dir. Art. 8; US law treats attempt under general principles; China punishes preparation as a form of stage form of crime commitment under Art. 22 for every crime and US in principle doesn't punish preparation without some exceptions, what can be decisive in a

distinction between minor and grave crimes committed in one of these countries or eo ipso including trans-national character of a crime and consequently influence in the context of criminal liability or its lack; all countries also distinct a conspiracy as a type of crime commitment, but there are also differences where, for example, China punishes it only where specific crimes are committed, while the US in relation to all crimes, what can be decisive in specific cases related to quantum computing, especially crimes related to violation of state interest like unauthorized obtaining secret data by using quantum computing as a measure to obtain plaintext from ciphered data. Encryption and quantum-specific rules are where divergence appears. The EU and US have not codified any specific criminal offence for using “quantum computers”. Their approach is technology-neutral: if a perpetrator uses a quantum algorithm, they are still doing illegal access or interception, just easier. The EU has begun recommending the adoption of PQC, but so far this is policy, not law. The US has mandated PQC for government agencies (per the Quantum Computing Cybersecurity Preparedness Act of 2022 (QCCPA)) [32], but this is not a requirement for private actors. In contrast, China’s Cryptography Law and the regulatory apparatus actively control actions related to encryption technology, although not specific to quantum yet. In short, only China has a general statute on encryption as “technology”, but no system punishes the unauthorized possession of quantum computing tools (yet).

In terms of liability, the EU and China impose legal duties on organizations to protect data. The NIS2 and GDPR of the EU require organizations to manage cyber risk and protect personal data; In practice, regulators impose fines for breaches. GDPR explicitly grants a private right to compensation for data subjects. The US lacks a federal data-protection tort, but state laws (ex. California’s Data Breach Notification Law) and the FTC can penalize negligence. China’s PIPL and CC allow victims to sue or regulators to fine companies for personal data breaches. However, criminal liability for neglecting security is rare in all legal systems; most sanctions are administrative or civil. Notably, no jurisdiction has (yet) defined a duty to upgrade encryption specifically in response to quantum threats; this remains a potential regulatory gap.

The EU has a strong cooperative framework (Eurojust/Europol and law harmonization), which in principle simplifies cross-border investigations and enforcement. The US also cooperates with allies (many of whom are BudConv parties), but has seen tensions (e.g., some US criticisms of BudConv’s adequacy). In practice, large-scale cybercrime (including what may become quantum attacks) often involves international networks, so differences here matter. For example, if a quantum-assisted breach in an EU bank traces back to an attacker in non-European country, EU law enforcement has limited measures to prosecute if extradition or cooperation is withheld if country is not a member of EU and not the state which has mechanism of European Arrest Warrant (EAW). Conversely, geopolitically the BudConv means that new bilateral or multilateral coalitions may be needed to hold quantum attackers accountable.

The actors also differ in their social approach. The EU emphasizes privacy and accountability and tends to demand transparency and deployment of safeguards from both governments and companies. US law balances security and business freedom; it strongly protects freedom of speech (hence restrictions on hacking tools are sometimes controversial under the First Amendment). China’s approach is statist and tech-optimistic: the state actively promotes domestic cryptography and is piloting quantum infrastructure (e.g. quantum communications) even as it cracks down on unauthorized cyber behavior. These cultural differences shape enforcement priorities. For instance, China heavily prosecutes financial cyber fraud as a priority, whereas the EU might focus more on data breaches as privacy violations. Table 1 below presents a brief comparison of the discussed entities.

**Table 1.** Comparative Overview of Cybercrime, Negligence Liability and Quantum Readiness in the EU, US, and PRC

| Dimension                                                       | EU                                                                      | US                                                                 | PRC                                                                      |
|-----------------------------------------------------------------|-------------------------------------------------------------------------|--------------------------------------------------------------------|--------------------------------------------------------------------------|
| Cybercrime Laws                                                 | BudConv, NIS2 and related Directives, domestic regulations              | CFAA, ECPA                                                         | Criminal Law; Cybersecurity Law (2016)                                   |
| Current Encryption Regulation                                   | GDPR and NIS2 provisions encourage to use “state-of-the-art” encryption | Export controls (EAR); no private PQC adoption mandate             | Cryptography Law (2019);                                                 |
| Liability for Tort/Negligence and weakness of security measures | (GDPR) Liability for failure to protect data; NIS2 and other Directives | Common law torts; liability dependent on US state, FTC Enforcement | PIPL obligations CC and administrative enforcement                       |
| Accountability for private sector                               | Strong obligations under NIS2; fines and sanctions for non-compliance   | SEC/FTC competence to penalize for non-compliance                  | Obligatory centralized compliance along with regulatory oversight        |
| Demonstrated Approach to international cooperation              | Strong via Eurojust, Europol, and Budconv framework                     | Mixed: multilateral and bilateral agreements; not a Budconv party  | Engaged in multilateral cyber governance forums; prioritizes sovereignty |
| Preparedness for Post-Quantum                                   | EU-level roadmap; soft law approach (2024 PQC Recommendation)           | Federal PQC mandate for agencies (QCCPA, 2022)                     | Active in standardizing; likely to adopt binding PQC regulations         |

None of the systems contains a special “post-quantum” crime and relies on currently existing laws. However, readiness varies. China’s centralized PQC roadmap and security focus make it well-poised to issue and enforce quantum-resistant standards swiftly. The EU and to significant extent the US remain technologically neutral, signaling precaution through policy (EU recommendation, NIST PQC guidelines), but expecting legal standards to evolve. Western regimes are likely to retrofit existing doctrines (e.g. negligence in tort or breach cases) to quantum risks, a reactive posture. All three legal regimes will need to adapt, for example, by creating aggravated offences or duties tailored to the scale of quantum-driven breaches.

## 7 Conclusion

As the quantum era approaches, existing laws provide some coverage against new cyber threats but also reveal gaps and bring challenges. All compared systems (EU, US and PRC) have criminal statutes that would cover quantum-enabled misconduct – for instance, using a quantum computer to break encryption still constitutes unauthorized access or data theft under current law. Nonetheless, key questions remain unanswered. Liability in the post-quantum context is only partially addressed by current statutes; fundamentally new risks may require legal innovation.

The comparison emphasizes some key points. First, convergence on core cyber offences is strong: all systems criminalize the same basic intrusions. This is a foundation for mutual assistance against traditional cybercrime. Second, divergence on responsibility: the EU and China impose broad security duties on organizations, while the U.S. relies more on common law and market incentives. It seems that in the post-quantum era, the EU and China might more easily justify penalties for lack of compliance with new crypto standards, whereas the U.S. might have to develop new regulations or case law to fill the void. Third, enforcement posture: Western democracies prize due process and public debate, whereas PRC prioritize state control. This affects how liability is imposed and contested; for example, a Chinese court may implicitly assume a need to protect state secrets in evaluating quantum-related cases, whereas a US legal system would rather demand narrow application of statutes to any novel facts.

Importantly, quantum computing will dramatically increase the scale of threats. The legal provisions predicated on “individual hackers” may be strained if, say, a single quantum-enabled attack compromises millions of records at once. Many legal systems have provisions for “large-scale” or “organized” attacks, but the thresholds for such designations may need to be revised. The role of the judiciary is to define whether the attack caused damage is of the “large-scale” one and consequently, to shape by judicial interpretations the requirements to recognize a crime as “large-scale”. Jurisprudence should consider whether new categories or aggravated circumstances are warranted – for example, treating the decryption of a national security database with a quantum computer as espionage or always as a “large-scale” or “organized” crime. Corporate duties should

also be clarified: perhaps making it explicitly unlawful for critical infrastructure operators to fail to adopt certified quantum-resistant algorithms after a specified date. Finally, international cooperation and coordination of efforts will be essential. Cyber threats are inherently cross-border, and without cooperation it will be difficult to hold quantum-era cybercriminals accountable. The BudConv provides a model framework, but it is obvious that not all major powers participate. Dialogue among the EU, the US and China on shared quantum-resistant standards and mutual recognition of encryption certifications could harmonize obligations while respecting national sovereignty. Without such coordination, conflicting mandates risk of “splintering” cyberspace. To conclude, neither the EU, US, nor the PRC is entirely unprepared; each has cybercrime laws and emerging attention to post-quantum issues. Yet, all must adapt to upcoming development. Criminal law regulations will mostly catch wrongdoers of any tech capability, but civil/regulatory regimes need updating to make “quantum illiteracy” a legal risk. The balance between security and liberty will be tested. Pivotal questions arise: Should states mandate backdoors in quantum-proof systems? How to ensure privacy when even encrypted communications may soon be significantly more readable? Should use of quantum computers be banned for people not approved by governments or certification bodies? These questions are at the frontier of both law and technology. In our opinion, effective governance will require not only legal fine-tuning but also political will and international cooperation. As recent EU initiatives indicate, proactive harmonizing post-quantum standards and responsibilities is now seen as urgent. For academics, legislators, and policymakers, the task is to refine liability doctrines (criminal, administrative, and civil). For the judiciary, it is crucial to the court’s jurisprudence to define whether any PQC-enabled breach automatically qualifies as “large-scale” or “organized”. Only in this case will legal liability be able to remain a bulwark against the cyber threats supported by quantum computing. In general, we recommend states and organizations adopt explicit statutory duties to upgrade cryptography, especially in critical infrastructure, by the early 2030s, in order to respond proactively to emerging threats.

**Disclosure of Interests.** The authors have no competing interests to declare that are relevant to the content of this article.

## References

1. China Daily, “China passes first cryptography law” (2019)
2. National Institute of Standards and Technology, Report on Post-Quantum Cryptography (NIST IR 8105) (2016)
3. Alliance for Telecommunications Industry Solutions (ATIS): Quantum Technologies and the Cryptographic Threat Timeline: A Strategic Overview. ATIS <https://atis.org/resources/quantum-technologies-and-the-cryptographic-threat-timeline-a-strategic-overview/>. Accessed 27 July 2025
4. The Criminal Law of the People’s Republic of China (Adopted at the Second Session of the Fifth National People’s Congress on July 1, 1979; revised at the



- Fifth Session of the Eighth National People's Congress on March 14, 1997 and promulgated by Order No.83 of the President of the People's Republic of China on March 14, 1997), China (1997)
5. Standing Committee of the National People's Congress. Civil Code of the People's Republic of China (Adopted at the Third Session of the Thirteenth National People's Congress on May 28, 2020; effective January 1, 2021) (2021)
  6. Council of Europe, Convention on Cybercrime (ETS No. 185), Budapest (2001)
  7. EU Directive 2013/40/EU on attacks against information systems (adapting Council Framework Decision 2005/222/JHA). Official Journal L 218/8–18 (2013)
  8. European Parliament and of the Council. Directive (EU) 2022/2555 of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive), OJ L 333, 27 December 2022, pp. 80–152. (2022)
  9. European Parliament and Council: Regulation (EU) 2019/881 of 17 April 2019 on ENISA (the European Union Agency for Cybersecurity) and on information and communications technology cybersecurity certification and repealing Regulation (EU) No 526/2013 (Cybersecurity Act). OJ L 151, 15–69 (2019)
  10. U.S. Congress, U.S. CFAA, 18 U.S.C. §1030. (particularly elements of unauthorized access in subsections (a)(2) – (6).) (1986)
  11. Electronic Communications Privacy Act of 1986, Pub. L. No. 99-508, 100 Stat. 1848 (1986)
  12. Computing Research Association, The Post-Quantum Cryptography Transition—Making Progress But Still a Long Road Ahead, CRA Quad Paper (2025)
  13. European Parliament and of the Council: Directive (EU) 2016/1148 of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union (NIS Directive), OJ L 194, 19 July 2016, p. 1 (2016)
  14. European Parliament and of the Council. Regulation (EU) 2016/679 of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), OJ L 119, 4 May 2016, pp. 1–88 (2016)
  15. Directive 2011/93/EU of the European Parliament and of the Council of 13 December 2011 on combating the sexual abuse and sexual exploitation of children and child pornography, O.J. L 335/1–14 (2011)
  16. Directive (EU) 2019/713 on combating fraud and counterfeiting of non-cash means of payment, O.J. L 123/18–29 (2019)
  17. Council Decision 2002/187/JHA of 28 February 2002 setting up Eurojust with a view to reinforcing the fight against serious crime, OJ L 63, 6 March 2002, pp. 1–13; Regulation (EU) 2016/794 of the European Parliament and of the Council of 11 May 2016 on the European Union Agency for Law Enforcement Cooperation (Europol), establishing the European Cybercrime Centre (EC3), OJ L 135, 24 May 2016, pp. 53–114 (2002)
  18. United Nations General Assembly. United Nations Convention against Cybercrime: Strengthening International Cooperation for Combating Certain Crimes Committed by Means of Information and Communications Technology Systems and for the Sharing of Evidence in Electronic Form of Serious Crimes, adopted 24 December 2024, UN Doc. A/RES/79/460. <https://www.unodc.org/unodc/en/cybercrime/convention/text/convention-full-text.html>. Accessed 30 May 2025
  19. United Nations Office on Drugs and Crime. United Nations Convention against Cybercrime (n.d.). <https://www.unodc.org/unodc/en/cybercrime/convention/home.html>. A30 May ccessed

20. Van Buren v. United States: 593 U.S. 374, 141 S. Ct. 1648, 210 L. Ed. 2d 26 (2021)
21. U.S. Congress: Electronic Communications Privacy Act of 1986, Pub. L. No. 99-508, 100 Stat. 1848, codified as amended at 18 U.S.C. §§2510–2522 (interception provisions) (1986)
22. U.S. Congress: Omnibus Crime Control and Safe Streets Act of 1968, Title III (Wiretap Act), 18 U.S.C. §§2510–2522 (1968)
23. U.S. Congress: Stored Communications Act, 18 U.S.C. §§2701–2712 (1986)
24. U.S. Congress: “Fraud and related activity in connection with identification documents, authentication features, and information,” 18 U.S.C. §1028, U.S. Code Title 18 (1948, as amended)
25. U.S. Congress: “Fraud by wire, radio, or television”, 18 U.S.C. §1343, U.S. Code Title 18 (1948, as amended)
26. Bureau of Industry and Security, U.S. Department of Commerce. License Exception ENC (Encryption commodities, software, and technology), 15 C.F.R. §, vol. 740, p. 17 (2025)
27. U.S. Department of Justice: Justice Department Investigation Leads to Shutdown of Largest Online Darknet Marketplace. Press Release, April 5, 2022. Northern District of California | Justice Department Investigation Leads To Shutdown Of Largest Online Darknet Marketplace | United States Department of Justice. Accessed 25 May 2025
28. U.S. Securities and Exchange Commission. SEC Announces Enforcement Results for Fiscal Year 2024, Press Release 2024-186 (Nov. 22, 2024). SEC.gov | SEC Announces Enforcement Results for Fiscal Year 2024. Accessed 25 May 2025
29. U.S. Department of Commerce: 15 C.F.R. §740.17, “Encryption commodities, software, and technology (ENC), including mass-market encryption exception,” Code of Federal Regulations, Title 15 – Commerce and Foreign Trade
30. U.S. Congress: Communications Assistance for Law Enforcement Act (CALEA), 47 U.S.C. §§1001–1010, U.S. Code Title 47 – Telecommunications (1994)
31. FTC v. Wyndham Worldwide Corp., 799 F.3d 236 (3d Cir. 2015), at 245–46
32. U.S. Congress: Quantum Computing Cybersecurity Preparedness Act, Pub. L. No. 117-260, 136 Stat. 2389 Section 4 (a)(1) (2022)
33. Wassenaar Arrangement on Export Controls for Conventional Arms and Dual-Use Goods and Technologies, Plenary Agreement (28 Nov. 1995; entry into force 1 July 1996)
34. U.S. Department of Commerce, Bureau of Industry and Security: Export Controls for Quantum Computers, Unified Agenda of Regulatory and Deregulatory Actions, Spring 2020 (RIN 0694-AH75) (2019)
35. U.S. Congress: Health Insurance Portability and Accountability Act of 1996, Pub. L. No. 104-191, 110 Stat. 1936 (1996)
36. Supreme People’s Court and Ministry of Public Security, Provisions of the Supreme People’s Court and the Ministry of Public Security on Several Issues Concerning the Application of Law in the Trial of Criminal Cases of Illegal Control of Computer Information Systems, art. 1(d) (promulgated Sept. 14, 2011; effective Dec. 1, 2011) (2011)
37. Standing Committee of the National People’s Congress: Cybersecurity Law of the People’s Republic of China, Presidential Decree No. 53 (adopted Nov. 7, 2016; effective June 1, 2017) (2017)
38. Standing Committee of the National People’s Congress. Civil Code of the People’s Republic of China (Adopted at the Third Session of the Thirteenth National People’s Congress on May 28, 2020; effective January 1, 2021), Art. 1034–1039 (2020)

39. Standing Committee of the National People's Congress. Personal Information Protection Law of the People's Republic of China, Chairman's Order No. 91 (adopted August 20, 2021; effective November 1, 2021) (2021)

# Author Queries

Chapter 19

| Query Refs. | Details Required                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Author's response |
|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------|
| AQ1         | This is to inform you that corresponding author and inserted email address have been identified as per the information available in the Copyright form.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |                   |
| AQ2         | Please be aware that your name and affiliation and if applicable those of your co-author(s) will be published as presented in this proof. If you want to make any changes, please correct the details now. Please note that after publication corrections won't be possible. Due to data protection we standardly publish professional email addresses, but not private ones, even if they have been provided in the manuscript and are visible in this proof. If you or your co-author(s) have a different preference regarding the publication of your mail address(s) please indicate this clearly. If no changes are required for your name(s) and affiliation(s) and if you agree with the handling of email addresses, please respond with "Ok". |                   |



Wiktor Wilkołaski <wiktor042004@gmail.com>

## TILting 2026 notification for paper 96

**Click here to accept all threats** <tilting2026-track-5@easychair.org>

6 marca 2026 10:22

Do: Wiktor Wilkołaski <wiktor042004@gmail.com>

Dear Author,

We are pleased to inform you that the above abstract has been accepted for presentation at the TILting Perspectives 2026 conference! Congratulations :)

Please confirm your participation by registering for the conference on or before April 15 2026. If you do not register by the deadline, we will not be able to include your presentation in the conference program.

Registration: As a speaker, you will shortly receive an email from our Conference Registration Portal "MOMICE" with a registration link. Please use this registration link to register for the conference. If you have not received an email from MOMICE by 20 March 2026, please check your SPAM inbox. If the email has not been received, please notify us via [tilting@tilburguniversity.edu](mailto:tilting@tilburguniversity.edu).

Option to submit full papers: Accepted authors who have registered for the conference have the option of submitting full papers (previously unpublished and based on their accepted abstract) to be considered for publication in a special issue of the Technology and Regulation (TechReg) journal or of the European Journal of Risk Regulation (EJRR). The tentative deadline for submission of the full paper is 5 June, 2026. Please reach out to us at the earliest [tilting@tilburguniversity.edu](mailto:tilting@tilburguniversity.edu) to show your interest in submission and any further questions.

Should you require further information, please contact us via [tilting@tilburguniversity.edu](mailto:tilting@tilburguniversity.edu).

We look forward to meeting you at the conference!

Best wishes,  
TILting 2026 Organization Team

### SUBMISSION: 96

TITLE: The "Quantum Paradox." Examining the Liability for Data Breach, the Duty of Care and Retroactivity in the European Union, United States of America, and People's Republic of China Privacy Frameworks

### ----- REVIEW 1 -----

### SUBMISSION: 96

TITLE: The "Quantum Paradox." Examining the Liability for Data Breach, the Duty of Care and Retroactivity in the European Union, United States of America, and People's Republic of China Privacy Frameworks

### ----- Overall evaluation -----

SCORE: 3 (strong accept)

### ----- TEXT:

The paper presents a rigorous analysis of the emerging legal challenges posed by quantum computing to data protection and cybersecurity and it highlights how quantum threats create unique temporal and liability dilemmas for data controllers and processors.

The comparative approach across the EU, US, and PRC effectively illustrates divergent liability models.

The discussion of cryptographic obsolescence, infrastructural readiness, and the necessity of crypto-agility is both theoretically grounded and practically relevant for global entities.

Overall, the paper combines doctrinal analysis, cross-jurisdictional comparison, and forward-looking legal design to address a pressing and underexplored topic. It represents a substantial contribution to scholarship at the intersection of law, technology, and cybersecurity.

### ----- REVIEW 2 -----



SUBMISSION: 96

TITLE: The "Quantum Paradox." Examining the Liability for Data Breach, the Duty of Care and Retroactivity in the European Union, United States of America, and People's Republic of China Privacy Frameworks

----- Overall evaluation -----

SCORE: 2 (accept)

----- TEXT:

The submitted abstract presents an ambitious and timely examination of liability, duty of care, and retroactivity in data breach regimes in the context of the emerging quantum threat. The paper aligns with the TILT's Perspectives track on cybersecurity, engaging with regulatory frameworks across different jurisdictions (the European Union, the United States, and the People's Republic of China). Moreover, the author demonstrates significant interdisciplinary breadth by integrating cryptographic theory with data protection and cybersecurity legal analysis. Although the topic is not entirely new, what distinguishes this work is the author's effort to translate technological concerns into legal constructs, a contribution that is potentially impactful if more clearly articulated. At present, however, the expected contributions retain some areas of ambiguity, and the overall structure of the argument could benefit from stronger coherence and clearer exposition, particularly i

n light of the high technical complexity of the subject matter. Despite these limitations, the topic is undoubtedly worthy of discussion at the conference and could foster a valuable academic exchange.

# The "Quantum Paradox"

## Examining the Liability for Data Breach, the Duty of Care and Retroactivity in the European Union, United States of America, and People's Republic of China Privacy Frameworks

**Keywords:** *Quantum Computing, GDPR, Data Liability, HNDL, Chinese Cybersecurity Law, Post-Quantum Cryptography, Duty of Care, Mosca Inequality, Crypto-Agility, Cyber-Resilience*

---

### 1 Introduction

The global digital economy operates on the fragile assumption that widely deployed cryptographic primitives, such as RSA and ECC, provide data confidentiality for the foreseeable future. However, the brisk advancement of Quantum Computing, especially the development of the Cryptographically Relevant Quantum Computer (CRQC), would change this state of facts. Specifically, the "Harvest Now, Decrypt Later" (HNDL) and "Trust Now Forge Later" (TNFL) introduce a unique temporal paradox into legal liability frameworks. Adversaries exfiltrate encrypted data ( $t_0$ ) to decrypt it once a CRQC arrives ( $t_1$ ).

This paper addresses a critical legal lacuna: Does the current legal "Duty of Care" protect a data controller/processor who adheres to today's market standards but fails to mitigate a mathematically foreseeable future breach? By comparing the approaches presented by the European Union (EU), the United States (US), and the People's Republic of China (PRC), this paper demonstrates how the quantum threat transforms the character of data retention from a standard compliance practice into a critical liability exposure. The paper argues that the timeline of quantum risk currently creates an immediate liability exposure, redefining the concepts of damage, standing, and negligence.

## 2 Theoretical Framework: The Mosca Inequality as a Legal Test

This paper transposes cryptographic theory into legal doctrine. To objectify the elusive concept of "negligence" in the face of uncertain technological timelines, it applies the Mosca Inequality, a risk management metric, as a binding legal test for the Duty of Care:

$$X + Y > Z$$

Where:

- **X:** The time required to migrate the infrastructure to Post-Quantum Cryptography (PQC).
- **Y:** The retention period or shelf-life of sensitive data (e.g. genomic data, state secrets).
- **Z:** The time remaining until a CRQC is available ("Q-Day").

The Paper argues that if  $X + Y > Z$  the data is effectively compromised at the time of exfiltration ( $t_0$ ), not decryption ( $t_1$ ). Consequently, continuing to store data with long retention periods (e.g., biometric data) (Y) protected with classical encryption constitutes immediate negligence under risk-based legal frameworks.

**Probabilistic Risk Refinement.** Crucially, this paper challenges the reliance on Z as a fixed scalar value. From a risk management perspective, Z behaves as a random variable with a probability distribution. The paper argues that a commercially reasonable Duty of Care cannot rely solely on median predictions of quantum availability (e.g., 15 years), but must account for "tail risk" - the non-negligible statistical probability of a "Black Swan" breakthrough in error correction. Ignoring this tail risk in favor of a "best-case" scenario constitutes a failure of reasonable foresight.

## 3 The European Union: The "State of the Art" and Burden of Proof

Within the EU, this liability is particularly severe under Article 32 of the GDPR, which requires adoption of technical measures appropriate to the risk, considering the "state of the art" (SoTA). This paper interprets Article 32 to require that SoTA be re-conceptualized not as a static checklist of approved algorithms but as a dynamic capability benchmark rooted in Crypto-Agility.

Furthermore, according to Article 32(1) of the GDPR, technical measures must be appropriate to the risk, considering the SoTA. In the absence of a binding definition, this paper provides an understanding of SoTA in the quantum era by synthesizing guidelines from ENISA, TeleTrust, and standardizing bodies to establish three concurrent criteria for cryptographic measures:

1. **Scientific Validation:** Algorithms must be accepted by the research community as resistant to all currently known cryptanalytic attacks, including IND-CCA2.
2. **Availability and Applicability:** Technology must be proven in operational environments rather than being purely theoretical.
3. **Technological Awareness:** Measures must not rely on primitives classified as "Deprecated" or "Legacy" by standardizing bodies such as ISO/IEC, NIST, and State Administration of Cryptography TC260.

**Technological Obsolescence as Negligence.** In the *LfDI Baden-Württemberg v. Knuddels.de* precedent, storing passwords in plain text (unhashed) was deemed a GDPR violation due to the failure to implement "state-of-the-art" security measures. Analogously, the use of classical encryption in the quantum era shall be considered equivalent to storing data in plain text (same applies to using obsolete hashing primitives, such as MD5 or SHA-1).

**Reversal of the Burden of Proof.** Furthermore, the paper analyzes the critical impact of the recent CJEU ruling in *VB v. Natsionalna agentsia za prihodite* (Case C-340/21), which established the reversed burden of proof. The Court ruled that the mere occurrence of a breach does not imply strict liability, but the controller is responsible for demonstrating that their security measures were "appropriate." Regarding quantum threat, the sentence confirmed the requirement for the data controller to demonstrate that the use of classical encryption was an appropriate risk decision despite the known HNDL or TNFL threat. The paper argues that CJEU imposed a *probatio diabolica* on controllers, effectively shifting the EU regime towards a strict liability model for technological stagnation.

**The NIS2 Directive and Executive Accountability.** Beyond the GDPR, the NIS2 Directive (2022/2555) introduces a shift toward personal liability for management bodies in Article 20, consequently establishing personal liability for negligence in overseeing cybersecurity risks. In the quantum context, failure to address these threats could lead to personal administrative fines, aligning the EU regime closer to the Chinese model of strict executive accountability.

## 4 The United States: The Jurisprudential Split on Standing

Unlike the EU's proactive liability regime, the US Article III "standing" doctrine creates a complex circuit split regarding whether the theft of encrypted data constitutes a "concrete injury."

**The Pro-Standing Doctrine (Dissemination).** The Third Circuit, in *In re Horizon Healthcare Services Inc.*, recognized that the unlawful dissemination of private data constitutes an injury in itself, regardless of immediate financial loss. This precedent supports HNDL and TNFL liability, implying that privacy loss occurs in the moment of theft ( $t_0$ ). Furthermore, according to this sentence the "read and understood" standard evolves into "harvested and will be understood."

**The Anti-Standing Doctrine (Public Disclosure).** Conversely, the Fourth Circuit in *Holmes v. Elephant Insurance Company* (2025) introduced a stricter requirement, ruling that data held in "cold storage" by adversaries do not constitute an injury absent public disclosure (e.g., on the Dark Web). The analysis demonstrates that the HNDL and TNFL strategies are uniquely tailored to exploit the Holmes precedent. Because sophisticated states perform operations on data silently rather than publishing it, they create a temporary "safe harbor" for negligent US companies.

**Negligent Stagnation.** In addition, this paper examines the *Shore v. Johnson & Bell* precedent, identifying a doctrine of "Negligent Stagnation." This case suggests that the failure to patch known vulnerabilities

(analogous to failure to migrate to PQC) can constitute a cause of action even without a confirmed breach, defining security obsolescence as a service failure.

## 5 China: Retroactivity and Strict Liability

Comparison of Western approaches with the PRC reveals a third, distinct model rooted in the "Three Synchronizations" principle (San Tong Bu), which requires security architecture to be synchronously planned, constructed, and operated with state-certified cryptography (GuoMi standards).

**Retroactive Enforcement.** The paper analyzes the *Cyberspace Administration of China (CAC) v. Didi Global* case to illustrate the principle of retroactive enforcement. The CAC penalized Didi for data processing activities that preceded current enforcement actions, applying a "continuous violation" doctrine. In the quantum context, failure to implement anti-harvesting measures is treated not merely as a privacy breach but as a national security failure under the DSL and PIPL.

**Liability for Harvesting.** Drawing on the Sina Weibo data breach precedent, the paper accentuates that Chinese regulators interpret failure to prevent data scraping (harvesting) as a violation. In contrast to the focus of the United States on consumer harm, the Chinese model imposes strict personal liability on executives for architectural failures. If a system allows for the "harvesting" of core data, the liability is triggered immediately at  $t_0$ , regardless of whether decryption at  $t_1$  has occurred.

## 6 Conclusion: From Algorithms to Infrastructural Readiness

The paper concludes that the quantum paradox makes classical encryption standards obsolete as a legal defense, classifying them similarly to the use of no safeguard at all. The divergence in liability regimes develops a fragmented compliance landscape for entities operating globally, particularly immediate liability in the EU, procedural hurdles in the US, and strict sanctions and legal requirements in the PRC.

Resolving these issues requires a shift in the legal definition of "Duty of Care." Rather than mandating specific algorithms (which become obsolete), legal frameworks must require "Infrastructural Readiness" (Crypto-Agility), consequently requiring systems to be designed for the replacement, without unnecessary delay, of cryptographic primitives without structural redesign. Crucially, only by prioritizing the agility to transition standards can legal frameworks effectively mitigate the retroactive risks of the quantum era.



## References

- [1] Mosca, M. Cybersecurity in an era of quantum computers: Will we be ready? *IEEE Security & Privacy*, 16(5), 38–41. (2018)
- [2] European Parliament and the Council, Regulation (EU) 2016/679 of the European Parliament and the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC. OJ L 119. (2016)
- [3] LfDI Baden-Württemberg. *Bußgeldverfahren gegen Knuddels GmbH & Co. KG*. (2018)
- [4] Court of Justice of the European Union, Judgment of 14 December 2023, *VB v. Natsionalna agentsia za prihodite* (Case C-340/21). (2023)
- [5] *In re Horizon Healthcare Services Inc. Data Breach Litigation*, 846 F.3d 625 (3d Cir. 2017).
- [6] *Holmes v. Elephant Insurance Company*, No. 23-1782 (4th Cir. 2025).
- [7] *Shore v. Johnson & Bell, Ltd.*, No. 16-cv-4363 (N.D. III. 2017).
- [8] Cyberspace Administration of China. Decision on Administrative Penalty for Didi Global Inc. The relevant person in charge of the Cyberspace Administration of China answered reporters' questions on the decision to impose administrative penalties related to network security review against Didi Global Co., Ltd. in accordance with the law(关于对滴滴全球股份有限公司依法作出网络安全审查相关行政处罚的决定). (2022)
- [9] Ministry of Industry and Information Technology (MIIT). Administrative Summons regarding Sina Weibo Data Breach (网络安全管理局就新浪微博 App 数据泄露问题开展问询约谈). (2020)



Wiktor Wilkołaski <wiktor042004@gmail.com>

---

## TPRC54 Paper Acceptance Invitation

---

TPRC 2026 - Organizers <tprc2026@conftool.com>

6 maja 2026 21:08

Odpowiedź do: tprconference@gmail.com

Do: wiktor042004@gmail.com

CC: k.badzmirowskam131@gmail.com

Dear Wiktor Wilkołaski,

It is my pleasure to inform you that your submission to TPRC54

Quantum Cyberspace Bifurcation. A Comparative Analysis of Regulatory Approaches to Quantum Technologies

has been accepted to be presented during a paper session in the main conference of this fall's TPRC! Congratulations.

The conference will be held Friday, September 25 and Saturday, September 26, 2026 at American University Washington College of Law, Washington, DC.

**Please confirm your participation by emailing Katie Byrne, [kbyrne.tprc@gmail.com](mailto:kbyrne.tprc@gmail.com), no later than Friday, May 18<sup>th</sup>.**

### SINGLE PRESENTATION PER AUTHOR RULE

TPRC allows an author to make only **one** presentation at the conference. If you are the author on more than one accepted paper, you will need to ensure that you are the presenter on only one of them. You will be asked to designate the presenter when you upload the paper in August.

-- Also presentations will be made by only ONE presenter.

### Paper Deadline:

This invitation to participate is conditional on our receipt of a completed paper **no later than August 1, 2026**. Your paper will be uploaded to SSRN as well as through ConfTool. Detailed instructions will be sent to those who confirm participation.

Given our conference participants' expectations to be able to read TPRC papers in advance, papers not received by this deadline will be removed from the program. A preliminary conference program will be available at [www.tprcweb.com](http://www.tprcweb.com). The full program will be available in July with papers linked the first week in August. Information about your session discussion will be emailed in early August.

### Registration:

Registration fees are reduced for authors and co-authors of accepted papers to US\$300 for registrations made before August 15. The registration fee includes conference meals. Registration will be available at [www.tprcweb.com](http://www.tprcweb.com). All those attending, including paper presenters, are responsible for covering their registration and travel expenses.

### Key deadlines:

Confirm participation: May 18, 2026

Submit paper and finalize abstracts: August 1st

Reduced rate registration: register by August 15th.

I look forward to a great conference this fall!

Best Wishes

Madelyn Sanfilippo

Chair, TPRC 2026 Program Committee

please find your review results below.

### Contribution Details

---

ID: 120

Title: Quantum Cyberspace Bifurcation. A Comparative Analysis of Regulatory Approaches to Quantum Technologies

**Review Result of the Program Committee:** This abstract has been accepted. Please upload your full paper now.

### Overview of Reviews

---

Review 1

=====

#### Evaluation of the Contribution

---

|                                            |          |
|--------------------------------------------|----------|
| Analytical Rigor                           | (20%): 6 |
| Theoretical and/or Conceptual Fundamentals | (20%): 6 |
| Policy Significance                        | (10%): 8 |
| Thematic Relevance                         | (20%): 8 |
| Clarity of presentation                    | (10%): 8 |
| Broader Impact                             | (20%): 6 |
| Total points (out of 100)                  | : 68     |

#### Comments for the Authors

---

The paper tackles the important topic of post quantum cryptography governance and its geopolitical stakes. However, the "predictive policy modeling" is underspecified; simulating 2030–2032 scenarios reads as a thought experiment rather than formal modeling. The paper seems to ignore existing private sector led internet governance forums that are actively working on PQC algorithms. Even if just for scoping, I'd like more of a nod to private forums or accountability mechanisms (example: the CA/B Forum and the Browser Root Stores). While helpfully concise, the use of neologisms ("Topological Cyberspace Bifurcation," "Compatibility Trap," "Intra-Western Divergence") provides a dense jargon that undermines accessibility for a policy audience.

-----

Review 2

=====

#### Evaluation of the Contribution

---

|                                            |           |
|--------------------------------------------|-----------|
| Analytical Rigor                           | (20%): 8  |
| Theoretical and/or Conceptual Fundamentals | (20%): 8  |
| Policy Significance                        | (10%): 8  |
| Thematic Relevance                         | (20%): 10 |
| Clarity of presentation                    | (10%): 10 |

Broader Impact (20%): 10  
Total points (out of 100) : 90

#### Comments for the Authors

---

This submission ("Quantum Cyberspace Bifurcation. A Comparative Analysis of Regulatory Approaches to Quantum Technologies") addresses a topic that is very timely and highly relevant.

The abstract is compellingly written and clearly motivated, grounded in an innovative and robust methodology, and promises insightful analysis and findings.

I would encourage the authors to clearly demonstrate how the cybersecurity problems they focus on differ from "conventional" problems, and why/how these differences call for novel regulatory responses and strategies.

-----

#### Review 3

---

##### Evaluation of the Contribution

---

|                                            |          |
|--------------------------------------------|----------|
| Analytical Rigor                           | (20%): 6 |
| Theoretical and/or Conceptual Fundamentals | (20%): 6 |
| Policy Significance                        | (10%): 6 |
| Thematic Relevance                         | (20%): 8 |
| Clarity of presentation                    | (10%): 6 |
| Broader Impact                             | (20%): 6 |
| Total points (out of 100)                  | : 64     |

#### Comments for the Authors

---

The framing of Western innovation vs Eastern control was a little difficult to parse in this context-- it seemed like the argument was just that more authoritarian governments can just require companies to do things so those changes happen faster than in countries that rely on "decentralized private compliance." But that's a pretty well known dynamic, so it was unclear how that applied specifically or uniquely to post-quantum crypto. It would be helpful to understand the nature of the contribution a little more clearly

Your organizers of TPRC 2026 The Research Conference on Communications, Information and Internet Policy.

—  
TPRC 2026 The Research Conference on Communications, Information and Internet Policy  
<https://www.conftool.com/tprc2026/>  
<https://www.tprcweb.com/>



## Contribution Details

Submission Type / Conference Track: Extended Abstracts for Papers

### Quantum Cyberspace Bifurcation. A Comparative Analysis of Regulatory Approaches to Quantum Technologies

120

**Wiktor Wilkołaski** ✉, Katarzyna Badźmirowska-Masłowska ✉

Organization(s): War Studies University in Warsaw, Poland

Submitted by: **Wiktor Wilkołaski** (War Studies University in Warsaw, PL), ID: 1026

Presenting Author: Wilkołaski, Wiktor [wiktor042004@gmail.com](mailto:wiktor042004@gmail.com)

Topics: \* Cybersecurity Policy, \* Geopolitics, Digital Sovereignty, and Tech Regulation, \* Policy and Governance Implications of Emerging Technologies (Open Source, Quantum Computing, Blockchain, Cryptocurrency)

Keywords: Post-Quantum Cryptography (PQC), Topological Cyberspace Bifurcation, Trust Now Forge Later (TNFL), Collingridge Dilemma, Digital Sovereignty

References (Optional): Collingridge, D. (1980). *The Social Control of Technology*. St. Martin's Press.

Court of Justice of the European Union (2020). *Data Protection Commissioner v Facebook Ireland Limited and Maximillian Schrems (Schrems II)*, C-311/18, EU:C:2020:559.

European Data Protection Board (2025). *Draft Guidelines 01/2025 on Pseudonymisation*.

European Union (2024). *Regulation (EU) 2024/2847 (Cyber Resilience Act)*, OJ L 2024/2847.

Mosca, M., & Piani, M. (2025). *Quantum Threat Timeline Report 2024*. Global Risk Institute.

National Institute of Standards and Technology (2024). *Module-Lattice-Based Key-Encapsulation Mechanism Standard (FIPS PUB 203)*.

Standing Committee of the National People's Congress (2019). *Cryptography Law of the People's Republic of China*.

Standing Committee of the National People's Congress (2025). *Decision on Amending the Cybersecurity Law of the People's Republic of China* (effective Jan. 1, 2026).

Government of the Russian Federation (2024). *Passport of the National Project "Data Economy"*.

United States Congress (2025). *Comprehensive Outbound Investment National Security (COINS) Act of 2025*, Pub. L. No. 119-XX.

✓ TPRC recognizes that AI tools can support clear and polished writing, but authors are expected to ensure that all ideas, analysis, and evidence originate from their own work. AI-generated text should be carefully checked for accuracy, and authors remain fully responsible for the originality, rigor, and integrity of their submissions. I have read, understood, and am complying with TPRC's policy on AI and author responsibility for content.

## Abstract

### Research Context and Problem Statement.

As of early 2026, the global transition to Post-Quantum Cryptography (PQC) has evolved from a theoretical imperative to a rigid regulatory mandate. This shift is primarily driven by the immediate exigency of the "Harvest Now, Decrypt Later" (HNDL) threat targeting data confidentiality. However, beyond the risk of decryption, the emergence of Cryptographically Relevant Quantum Computers (CRQCs) introduces a parallel threat to the fundamental integrity of digital infrastructure: "Trust Now, Forge Later" (TNFL). While HNDL compromises secrecy, TNFL targets the authenticity of digital signatures underpinning the global economy. This paper analyzes how four major powers—the United States, the European Union, the People's Republic of China, and the Russian Federation—are navigating these complex threats through the theoretical lens of the Collingridge Dilemma. Furthermore, the paper introduces the concept of 'Topological Cyberspace Bifurcation' to describe a systemic phase transition in global cyber-governance, where the emergence of CRQCs forces the unitary digital commons into two disjoint equilibria: the Western 'Hybrid' model and the Eastern 'Sovereign' model. We argue that this bifurcation precipitates a 'Compatibility Trap'. Specifically, technical incompatibility regarding post-quantum primitives systematically evolves into an insurmountable conflict of laws under Chapter V of the General Data Protection Regulation (GDPR). Under the EDPB Draft Guidelines 01/2025, state-of-the-art encryption serves as a valid supplementary measure only if it mathematically precludes disproportionate state access. Consequently, a multinational entity utilizing Eastern state-mandated cryptography cannot simultaneously satisfy the GDPR's transfer requirements established by the CJEU in *Schrems II* (C-311/18).

### Methodology.

The research applies a comparative legal analysis combined with predictive policy modeling. **Legal Analysis:** We examine primary legislative texts enacted or amended between 2024 and 2026. Key instruments include the US COINS Act of 2025 and Cyber Resilience Act (EU), alongside China's 2026 amendments to the Cybersecurity Law and Russia's National Project "Data Economy". **Predictive Modeling (Stress Testing):** Moving beyond static analysis, the paper stress-tests the resilience of these regulatory frameworks by simulating two high-probability scenarios for the 2030-2032 timeline: a systemic HNDL data breach and a TNFL-enabled espionage incident in the North Sea. The latter dynamically models an attack targeting the network's classical authentication substrate, demonstrating how adversaries bypass the physical QKD layer by forging the legacy PKI 'handshake'.

### Analysis: The Quantum Bifurcation.

The paper identifies a fundamental "Quantum Bifurcation" in global governance, challenging the traditional binary of "Western innovation" vs. "Eastern control."

*The Western "Hybrid" Shift:* We argue that the EU and US are executing a strategy of "legal engineering." They are solidifying non-binding instruments—specifically NIST PQC standards (FIPS 203-205) and EU roadmaps—into hard market requirements via legislation like the EU Cyber Resilience Act (CRA) and the US COINS Act, attempting to resolve the Collingridge Dilemma by fostering private-sector innovation. However, our analysis reveals a critical vulnerability: the reliance on decentralized private compliance creates latency. In the event of an integrity attack (TNFL), the coordination required to update authentication protocols across fragmented markets may prove too slow compared to centralized regimes.

*The Eastern "Sovereign" Model:* In contrast, China and Russia utilize a "preemptive control" model rooted in hard law. China's "Whole Nation System" and Russia's state-owned enterprises (Rosatom, RZnD) integrate regulation directly into the supply chain. These regimes utilize strict requirements to enforce immediate domestic compliance, prioritizing sovereignty.

### **Expected Results and Conclusions.**

The policy simulations reveal a critical strategic trade-off. In the event of a 2032 TNFL incident—where an attacker forges a trusted update for critical infrastructure—the Eastern model ensures a swift, unified mobilization through state command, effectively mitigating the spread of forged credentials. Conversely, the Western model promotes cryptographic agility but faces higher risks of coordination failure among private actors. Furthermore, the analysis of the EuroQCI scenario demonstrates that infrastructure itself is becoming a regulatory tool. The EU's deployment of the EuroQCI creates a de facto regulatory perimeter that binds member states more effectively than traditional directives. Crucially, the research identifies a systemic 'Intra-Western Divergence': while the EU anchors its sovereign defense in physical-layer security through the EuroQCI initiative, the US National Security Agency (NSA) formally decries QKD as inadequate for securing National Security Systems. The aforementioned contradiction creates a fractured regulatory perimeter within the Atlantic alliance. The paper concludes that without trans-bloc harmonization, the digital economy risks fracturing into incompatible "quantum spheres of influence." We offer specific policy recommendations to mitigate these risks, emphasizing the urgent need for cross-border interoperability standards and PKI migration timelines. Only through application of such mechanisms can the "Western" sphere avoid internal fragmentation and effectively counter the existential risks of both HNLF and TNFL.



---

## SciSec 2025 notification for paper 55

---

SciSec 2025 <scisec2025@easychair.org>

1 lipca 2025 12:38

Do: Wiktor Wilkołaski <wiktor042004@gmail.com>

Dear Authors:

We are pleased to inform you that your submission #55 has been accepted for presentation at SciSec 2025 and will appear in the conference proceedings.

\*Title: Quantum Cybercrime: Challenges in the Age of Advancing Quantum Computing Across the European Union, United States of America, and People's Republic of China

\*Authors: Wiktor Wilkołaski, Katarzyna Badźmirowska-Masłowska

This year, we received a total of 66 submissions. Of these, 20 papers were accepted, giving an acceptance rate of 30.3%.

Please log in to the submission site to view the reviewers' comments and any additional information related to your submission.

Thank you for submitting your work to SciSec 2025. We look forward to your participation in the conference, which will take place in Wuhan, China on August 15-17.

Best regards,

- SciSec 2025 Program Chairs

Debiao He, Moti Yung, Jun Zhao

SUBMISSION: 55

TITLE: Quantum Cybercrime: Challenges in the Age of Advancing Quantum Computing Across the European Union, United States of America, and People's Republic of China

----- REVIEW 1 -----

SUBMISSION: 55

TITLE: Quantum Cybercrime: Challenges in the Age of Advancing Quantum Computing Across the European Union, United States of America, and People's Republic of China

AUTHORS: Wiktor Wilkołaski and Katarzyna Badźmirowska-Masłowska

----- Overall evaluation -----

SCORE: 0 (borderline paper)

---- TEXT:

This paper provides a detailed comparative legal analysis of how these three major jurisdictions handle cybercrime, with a focus on their preparedness for quantum computing threats. Here's a concise breakdown of the key insights:

Strengths:

- The paper addresses an urgent and underexplored intersection of quantum computing and cyber law, making it highly relevant as real-world quantum computing capabilities advance.

- The comparison between three major geopolitical actors is well-structured and insightful, helping readers understand the divergence in cryptographic governance and enforcement.

- The legal frameworks are summarized clearly and concisely, making the paper accessible to both legal and technical readers.

Weakness:

- The paper is largely theoretical and policy-oriented; it does not analyze actual or simulated incidents (e.g., data breaches where STDL might apply).

- Some sections describing the quantum threat are technically imprecise or outdated, such as the timeline for RSA-2048

compromise and assumptions about algorithm availability. The role of quantum-resistant cryptography under current NIST standardization (e.g., Kyber, Dilithium) could be explained in more depth.

----- REVIEW 2 -----

SUBMISSION: 55

TITLE: Quantum Cybercrime: Challenges in the Age of Advancing Quantum Computing Across the European Union, United States of America, and People's Republic of China

AUTHORS: Wiktor Wilkołaski and Katarzyna Badźmirowska-Masłowska

----- Overall evaluation -----

SCORE: 0 (borderline paper)

----- TEXT:

Summary:

This paper offers a comparative legal analysis of how the European Union, the United States, and China address cybercrime liability in the emerging context of quantum computing. The authors examine criminal and regulatory frameworks, focusing on encryption-related obligations, tort liability, and enforcement mechanisms. The discussion highlights legal gaps and calls for reforms to prepare for post-quantum threats.

Strengths:

This paper gives the structured comparison of cybercrime laws and liability frameworks across the EU, US, and China, which gives a broad international perspective that is valuable for policy-making and legal scholarship.

The manuscript is well-sourced with citations from legislation, treaties, and policy documents. The discussion on possible regulatory gaps (e.g. lack of duties to adopt PQC) and policy implications for each jurisdiction is thoughtful and realistic. The paper highlights important areas where current laws fail to anticipate quantum-enhanced threats, such as quantum-accelerated decryption and identity theft.

Weaknesses:

The manuscript requires significant proofreading. An awkward phrasing reduce readability and academic quality, i.e. in Section 6, "In this part these three components three different subjects of international law (EU with its secondary legal capacity and states", "these three components three different subjects" make confusing and redundant.

Meanwhile, this paper summarizes existing laws but offers limited theoretical innovation or concrete legal proposals.

Cryptographic aspects are mentioned but not sufficiently explored, reducing appeal to interdisciplinary readers.

In addition, it would be good to insert figure/table that can summarize the comparative discussion.

Overall evaluation of the paper:

Borderline. This paper addresses an important topic with good comparative insight, but requires revision in structure (meanwhile consider a more concrete framework or model for legal adaptation to quantum threats) to be suitable for publication.

----- REVIEW 3 -----

SUBMISSION: 55

TITLE: Quantum Cybercrime: Challenges in the Age of Advancing Quantum Computing Across the European Union, United States of America, and People's Republic of China

AUTHORS: Wiktor Wilkołaski and Katarzyna Badźmirowska-Masłowska

----- Overall evaluation -----

SCORE: 1 (weak accept)

----- TEXT:

This paper analyzes the adequacy of the legal systems of European Union (EU), United States (US), and China in a post-quantum environment and discusses the potential need for legal reform to address new quantum-enabled threats. The paper compares different legal approaches, particularly focusing on encryption-related regulations and corporate accountability. It also highlights areas where current laws may be insufficient to handle quantum computing's impact on cybercrime.

Strengths:

1. This paper provides a comprehensive introduction and comparison of the cybercrime liability frameworks of the EU, the United States, and China, and explains from a global perspective how these systems deal with cybercrime in the post-quantum era. The analysis of the existing legal framework is strengthened by case law and legislative examples.

2. This paper provides an insightful and timely discussion of the current legislative gaps and the need for reform in the context of emerging quantum threats.

#### Weaknesses:

1. Although the paper discusses the threat of quantum computing to existing encryption technologies, the discussion of how quantum computing specifically affects these technologies is relatively brief. For example, it could be supplemented with a detailed introduction to quantum attack methods and quantum attack scenarios.

2. Although the article proposes reform suggestions for the challenges posed by quantum computing, these suggestions are relatively general and a more in-depth discussion is recommended.

3. Can a comparison chart be added to the comparison discussion section to illustrate the comparison results more intuitively and clearly?

4. In page 12, does the paper mention "all four systems" referring to the EU, U.S., China, and Russia? The paper then mentions "RusCri" (Russia's cybercrime law) without a clear explanation in the previous text. But the entire paper basically discusses the EU, U.S., and China. Is this a typo?

5. The paper has some typos, which are listed below:  
page 13: "the EUand China" -> the EU and China

**Day 1 August 15, 2025 (Wuhan, Friday, Wuhan Lin Konggang Exhibition Hotel (Wuhuan Sports Center Branch))**

14:00 – 20:00 *Registration*

**Day 2 August 16, 2025 (Wuhan, Saturday, Wuhan Lin Konggang Exhibition Hotel (Wuhuan Sports Center Branch))**

08:30 – 08:40 *Welcome from General Chairs and PC Chairs*

08:40 – 09:10 *Keynote Speech: Professor Xiaofeng Chen* (陈晓峰教授)

09:10 – 09:40 *Keynote Speech: Professor Yi Deng* (邓焱教授)

09:40 – 09:50 *Conference Group Photo & Coffee break*

09:50 – 10:20 *Keynote Speech: Professor Jin Li* (李进教授)

10:20 – 10:50 *Keynote Speech: Professor Man Ho Allen Au*

10:50 – 11:20 *Keynote Speech: Professor Zheli Liu* (刘哲理教授)

11:20 – 11:50 *Keynote Speech: Professor Jian Shen* (沈剑教授)

12:00 – 14:00 *Lunch Break*

14:00 – 14:20 *A Personalized Fuzzy Method Based on Local Differential Privacy for Location Data Publication*

*Dan Lu, Zexiu Qin, Jing Li, Yan Wang and Degang Sun*

14:20 – 14:40 *Cryptanalysis of the PUF-Enabled UAV-Ground Station and UAV-UAV Authentication Mechanism*

*Sijia Li, Hua Guo, Jiarong Huo and Jianwei Liu*

14:40 – 15:00 *Estimation of the Bounds for the Leading Term of a Double-Base Chain*

*Tingyu Xing, Wei Yu, Kunpeng Wang, Song Tian and Bin Wang*

15:00 – 15:20 *LRF-KDTL: Lightweight RF Fingerprint Identification based on Knowledge Distillation and Transfer Learning*

*Yang Jie, Zhang Shunliang and Ren Teng*

15:20 – 15:30 *Coffee break*

15:30 – 15:50 *Designing Steganographic Codes Based on PAC codes to Enhance Steganographic Security in Short-Cover Scenarios*

*Xiaoshi Wang, Haocheng Fu, Yun Cao and Yingnan Zhang*

15:50 – 16:10 Faster and smaller variants of binSIDH and terSIDH

*Bin Wang, Wei Yu, Kunpeng Wang, Song Tian and Tingyu Xing*

16:10 – 16:30 Securing Unique Digital Name Spaces: A Comparative Risk and Strategy Analysis for Domains and Social Media

*Thomas Fritzler and Michael Massoth*

16:30 – 16:50 Better Safe Than Sorry: Case Study on Marginal Utility of Technical Cybersecurity Measures in Healthcare

*Marie Soukupova*

16:50 – 17:10 Quantum Cybercrime: Challenges in the Age of Advancing Quantum Computing Across the European Union, United States of America, and People's Republic of China

*Wiktor Wilkołaski and Katarzyna Badźmirowska-Masłowska*

17:10 – 17:30 Binary Code Similarity Detection: A Comprehensive Review

*Ting Su, Man Chen, Hua Cheng and Zhen Y*

17:30 – 17:40 **Awards Ceremony**

18:00 – 20:00 **Welcome Reception**

**Day 3 August 17, 2025 (Wuhan, GMT+8, Sunday, Wuhan Lin Konggang Exhibition Hotel (Wuhuan Sports Center Branch))**

08:30 – 09:00 *Keynote Speech: Professor Jianwei Liu (刘建伟教授)*

09:00 – 09:30 *Keynote Speech: Professor Youliang Tian (田有亮教授)*

09:30 – 09:40 *Coffee break*

09:40 – 10:10 *Keynote Speech: Professor Deqing Zou (邹德清教授)*

10:10 – 10:40 *Keynote Speech: Professor Liehuang Zhu (祝烈煌教授)*

10:40 – 11:10 *Keynote Speech: Professor Tianqing Zhu (朱天清教授)*

11:10 – 11:30 LLM-Augmented Semantic Analysis for Hidden Web Interface Discovery in IoT Devices

*Qing Yao, Zhanwei Song, Zhi Li, Fengshi Zhang, Yongle Chen and Limin Sun*

11:30 – 11:50 A Privacy-Preserving and Byzantine-Resilient Federated Learning scheme in VANETs



*Jiahui Hou, Gang Shen and Shaohua Liu*

12:00 – 14:00 *Lunch Break*

14:00 – 14:20 MDA-FQ: A Multidimensional Privacy-Preserving Data Aggregation Scheme with Function Query for Smart Grid

*Zhixin Zeng, Zuxin Yu, Yuanjun Xia, Changsong Yang and Huadong Liu*

14:20 – 14:40 The Multiplicity of Cybersecurities. On divergent Understandings of a Contested Term

*Rainer Rehak*

14:40 – 15:00 Does ChatGPT Consistently Return Secure Cryptographic API Code?

*Thien Ngo Le, Guannan Liu and Chuan Yue*

15:00 – 15:20 Efficient Adversarial Learning-based Profiled Side-channel Analysis via Source Encoder Freezing and Randomized Multilinear Mapping

*Siliang Suo, Di Li, Yuxuan Du, Chun Li and Zheng Gong*

15:20 – 15:30 *Coffee break*

15:30 – 15:50 Design and Implementation of an Agentic AI Security Framework

*Niharika Jain and Isha Karn*

15:50 – 16:10 Large Language Model-Enhanced Malware Dynamic Detection Method

*Weize Zhang, Qiuyun Wang, Shuwei Wang, Zhengwei Jiang, Ximin Huang, Xiao Chen and Fangli Ren*

16:10 – 16:30 A Novel Dynamic Pricing Method Based on Reinforcement Learning

*Zhuoqun Li, Yanni Han, Wen Zhang and Han Jiang*

16:30 – 16:50 Intell-dragonfly: A Cybersecurity Attack Surface Generation Engine Based On Artificial Intelligence-generated Content Technology

*Lvyang Zhang, Xingchen Wu, Yang Zhao, Jiaqi Li, Qin Qiu, Yang Yu and Lidong Zhai*

17:00 – 18:30 ***Coffee Break and End of Conference***



Wiktor Wilkołaski <wiktor042004@gmail.com>

---

## Your chapter in [978-981-95-4676-3, scisec 2025, 16211, 558, schedule for paper approval (681824\_1\_En, Chapter 19)]

---

rasu.m@straive.com <rasu.m@straive.com>

2 czerwca 2026 12:31

Do: wiktor042004@gmail.com

CC: rasu.m@straive.com

Dear Authors,

My name is Rasu M and I am a production supervisor at **Straive** who will be handling the production of the book, **Science of Cyber Security**, on behalf of Springer. I will be your main production contact and will oversee the production of the text of your chapter from manuscript to final print and online files.

We refer to your paper "**Quantum Cybercrime: Challenges in the Age of Advancing Quantum Computing Across the European Union, United States of America, and People's Republic of China**", due to appear in Volume **16211** of the **Lecture Notes in Computer Science** series. The files for this volume have been sent to the typesetters and on **June 02, 2026**, a proof of your paper will be made available to you via a web interface. You will be alerted to this via e-mail and will be given 72 hours to check your paper. Sundays are not included in this time calculation, so please take note of this if it affects you. Please check your email, the two days before/after the date indicated above, as the schedule may change slightly.

I look forward to working with you on the production of this book. Please feel free to contact me if you have any questions or concerns.

Best Regards,

Rasu M

Production Supervisor - Books Production

[www.springernature.com](http://www.springernature.com)

Straive | 7th Floor, Block-C | Hardy Tower | Ramanujan IT City | [Rajiv Gandhi Salai \(OMR\)](#) | [Taramani](#) | [Chennai](#) | [India-600 113](#)

M +91 (0) 9080166840

[rasu.m@straive.com](mailto:rasu.m@straive.com)

...

🔗 **Straive** is a service provider of **Springer Nature**

Decision: **accept without changes**

---

March 23, 2026

CAL-00046-2025-01

Legal Lacunae - Modern Cyber Threats Targeting International Aviation Beyond the Scope of the Beijing Convention

Dear Mr. Wilkołaski,

I am pleased to inform you that your manuscript, entitled: Legal Lacunae - Modern Cyber Threats Targeting International Aviation Beyond the Scope of the Beijing Convention, has been accepted for publication in our journal.

Thank you for submitting your work to us.

Kind regards,  
Editor-In-Chief  
Cybersecurity and Law

**Review 1** (accept without changes):

#### **Originality and Contribution to the Field**

**Does the manuscript offer new findings, theoretical insights, or original perspectives?**

Yes

#### **Comment**

#### **Title**

• **Is the title accurate, clear and specific?**

Yes

#### **Comment**

#### **Keywords**

**Do the keywords sufficiently characterize the content of the article?**

Yes

#### **Comment**

#### **Abstract**

**Does the abstract concisely summarise the main argument, research methods, key**

**findings, and conclusions?**

Yes

**Comment****Introduction**

**Does the introduction clearly establish the research problem and explain its significance within the field?**

Yes

**Comment****Literature Review and Theoretical Framework**

**Is the literature up-to-date, relevant, and accurately summarised?**

Yes

**Comment****Methodology**

**Is the research method clearly described and sufficiently detailed to ensure replicability or transparency?**

Yes

**Comment****Results and Interpretation**

**Are the results clearly presented and logically organized?**

Yes

**Comment****Discussion**

**Are the findings interpreted accurately?**

Yes

**Comment**

## Conclusion and Implications

**Are the conclusions clearly stated and supported by the data and analysis?**

Yes

**Comment**

## Writing and Structure

**Is the paper well-organised, coherent, and easy to follow?**

Yes

**Comment**

**Do you have any ethical concerns related to this study (e.g. inappropriate self-citation, undisclosed use of AI tools, data fabrication, or fault in data collection and analysis)?**

No

**Comment**

**Is the language of the article appropriate for academic work?**

Yes

**Level of attractiveness of the article (level of presentation of the problem)**

International level

**Is the illustrative material (tables, charts, other graphic forms) necessary, sufficient, appropriately selected, and of good quality?**

Yes

The article provides an interesting analysis. The objectives of the study are clearly stated. The discussion is written in correct language. Relevant academic literature has been used. The conclusions are clearly formulated.

**Review 2** (accept without changes):

## Originality and Contribution to the Field

**Does the manuscript offer new findings, theoretical insights, or original perspectives?**

Yes

**Comment**



**Title**

• Is the title accurate, clear and specific?

Yes

**Comment****Keywords**

Do the keywords sufficiently characterize the content of the article?

Yes

**Comment****Abstract**

Does the abstract concisely summarise the main argument, research methods, key findings, and conclusions?

Yes

**Comment****Introduction**

Does the introduction clearly establish the research problem and explain its significance within the field?

Yes

**Comment****Literature Review and Theoretical Framework**

Is the literature up-to-date, relevant, and accurately summarised?

Yes

**Comment****Methodology**

Is the research method clearly described and sufficiently detailed to ensure replicability or transparency?

Yes

**Comment****Results and Interpretation****Are the results clearly presented and logically organized?**

Yes

**Comment****Discussion****Are the findings interpreted accurately?**

Yes

**Comment****Conclusion and Implications****Are the conclusions clearly stated and supported by the data and analysis?**

Yes

**Comment****Writing and Structure****Is the paper well-organised, coherent, and easy to follow?**

Yes

**Comment****Do you have any ethical concerns related to this study (e.g. inappropriate self-citation, undisclosed use of AI tools, data fabrication, or fault in data collection and analysis)?**

No

**Comment****Is the language of the article appropriate for academic work?**

Yes

**Level of attractiveness of the article (level of presentation of the problem)**

International level

**Is the illustrative material (tables, charts, other graphic forms) necessary, sufficient, appropriately selected, and of good quality?**

Yes

Accepted without changes

## [IFIPSC26] Notification for your paper submitted to IFIP Summer School on Privacy and Identity Management

1 wiadomość

IFIPSC2026 <ifipsc2026@easychair.org>

8 czerwca 2026 17:07

Do: Wiktor Wilkołaski <wiktor042004@gmail.com>

Dear Wiktor,  
many thanks for submitting your abstract to this year's IFIP Summer School on Privacy and Identity Management.  
We are glad to inform you that your proposal entitled

#3: Reconstructing Liability in Distributed Architectures: The Revised Product Liability Directive vs. Federated Machine Learning

has been accepted for presentation at the summer school in Leuven on August 10-14, 2026. You can find the reviews below.

As the event is planned as a purely physical event, you are required to confirm your participation within two weeks of receiving this notification (i.e., June 22), via email to Laura Drechsler <laura.drechsler@kuleuven.be> and Stefan Schiffner <stefan.schiffner@h-brs.de>, with the message subject starting with "[IFIPSC26]". Please do not forget to mention the paper ID and title in your confirmation.

The next steps are then summarized below:

- All information regarding registration for the summer school can be found here: <https://ifip-summerschool.github.io/registration/>. Please be reminded that the early-bird fee is only applicable until June 19.
- Please submit a full version of your paper by updating your submission on EasyChair by July 31, following Springer's LNCS format. Note that this version will only be made available to participants of the school.
- Each paper will be assigned about 30min at the summer school. Please keep your presentation to 15-20min, such that there is sufficient time for questions and discussions.
- Post-proceedings of the school will be published within Springer's IFIP AICT series. For this, an updated version of the paper can be submitted until September 25, which will then undergo an in-depth peer-review process by at least 3 reviewers.
- Acceptance notifications will be communicated by mid November, and in case of acceptance the camera-ready version is due by mid December. Publication of the proceedings can then be expected in Spring 2027. All dates can also be found online: [https://ifip-summerschool.github.io/important\\_dates/](https://ifip-summerschool.github.io/important_dates/)

In case of questions, please do not hesitate to get in touch!

We are looking forward to meeting you in Leuven,

Stephan Krenn  
(on behalf of the organizing committee)

----- REVIEWS -----

SUBMISSION: 3

TITLE: Reconstructing Liability in Distributed Architectures: The Revised Product Liability Directive vs. Federated Machine Learning

----- REVIEW 1 -----

SUBMISSION: 3

TITLE: Reconstructing Liability in Distributed Architectures: The Revised Product Liability Directive vs. Federated Machine Learning

----- Overall evaluation -----

SCORE: 2 (accept)

----- TEXT:

This abstract is really well-written and gets straight to the point. It does a great job of explaining a complex problem, specifically how new EU liability laws clash with the way decentralized AI systems actually work. It is impressive because it doesn't just complain about the problem but actually suggests a clear, three-part system to fix it.

The logic is easy to follow and the argument is convincing, which makes it useful for both lawyers and tech experts. There are a few typos where words are smashed together, but once those are cleaned up, it's in great shape. It is a professional and complicated piece of work that seems promising.

Please make sure that it is in scope of the IFIP, so at the conference itself, make sure to link it to the overarching theme properly.



# Reconstructing Liability in Distributed Architectures: The Revised Product Liability Directive vs. Federated Learning

No Author Given

No Institute Given

**Abstract.** The Revised Product Liability Directive precipitates structural conflicts when applied to distributed data architectures. While the classification of software as an actionable product constitutes established law, the evidentiary presumptions codified in Article 10(4) collapse against privacy-preserving computational frameworks. This research isolates Federated Learning (FL) within high-risk credit evaluation systems to demonstrate how decentralized training environments vitiate the Directive’s causal logic. In FL architectures, central providers (manufacturers under the PLD) distribute a global model while local nodes (operated by deployers under the AI Act) compute localized weights, denying the provider access to post-deployment training data. Consequently, the aggressive evidentiary disclosure mandates of Article 9(1) force providers into an untenable legal posture. To resolve this systemic deadlock between ex-post liability frameworks and ex-ante privacy regulations, this study proposes a Differentiated Liability Taxonomy *de lege ferenda*. This trinary framework directly calibrates Article 10 fault presumptions against quantifiable vectors of architectural control. Implementing this taxonomy as a legislative update or regulatory guideline secures exacting remedial mechanisms for algorithmic harm while preventing the arbitrary penalization of decentralized computational topologies.

**Keywords:** Directive (EU) 2024/2853 · AI Act · Federated Learning · Burden of Proof · Evidentiary Presumptions · Credit Scoring.

## 1 Post-Enactment Doctrinal Discrepancies

The promulgated Directive (EU) 2024/2853 (Revised PLD) explicitly categorizes software, which functionally encompasses AI models, as products under Article 4(1) [1] and Recital 13. While this statutory expansion resolved the initial accountability void regarding static, centralized software, contemporary analysis faces a severe structural impasse regarding decentralized topologies [7]. This friction is formally recognized within European policy assessments, which identify the inherent opacity, complexity, and limited predictability of AI systems as primary barriers to effective liability enforcement under existing frameworks [5].

The legal lacuna resides not in the definitional parameters of a defect under Article 7, but within the intersection of strict liability mandates and privacy-preserving computational architectures. Specifically, Federated Learning (FL)

architectures—increasingly deployed in cross-institutional credit scoring architectures to reconcile data utility with strict privacy regimes [9]—are decoupling the global algorithmic architecture ( $W_{global}$ ) from localized training data [6]. Within this topology, a central entity distributes a baseline model to local nodes managed by entities such as retail banks, which compute local weight updates ( $W_{local}$ ) without ever transmitting raw, proprietary financial data back to the central server. This isolation forces a direct conflict with the Revised PLD’s assumption of manufacturer control over post-deployment software modifications under Article 11(2) in conjunction with Article 4(5) [1].

## 2 The Evidentiary Deficit in Distributed Architectures

The mismatch precipitated by the Revised PLD manifests fundamentally in its evidentiary mechanics when applied to distributed systems. Article 9(1) empowers national courts to order the defendant to disclose relevant evidence that is “at its disposal” [1].

In centralized architectures, retaining such telemetry constitutes standard practice; failing to disclose it legitimately precipitates a rebuttable presumption of defectiveness under Article 10(2)(a) [1,4]. However, in FL architectures, the central entity remains architecturally blind to local data inputs. Because the local training data structurally evades the entity’s infrastructure, it genuinely falls outside the scope of “at its disposal.” Yet, this opacity triggers a more severe “trap”. Assuming the claimant demonstrates a *prima facie* likelihood of defectiveness, they will invoke Article 10(4). This statutory mechanism triggers a presumption of defectiveness and causality whenever claimants encounter excessive evidentiary hurdles precipitated by “technical or scientific complexity” [1]. Consequently, this imposes an unmitigated strict liability vector upon the manufacturer for localized anomalies, as the distributed architecture cryptographically precludes them from exfiltrating the localized data necessary to vitiate the Article 10(4) presumption.

## 3 Tort Liability vs. Ex-Ante Compliance

This evidentiary deficit exposes a systemic tension between ex-post remedial mechanisms and the ex-ante regulatory framework established by Regulation (EU) 2024/1689 (AI Act) [2], highlighting the critical need for robust ex-ante justification architectures [8]. It is critical to precisely delineate the subjective scopes of these acts: the entity developing the FL framework acts as the “manufacturer” under the PLD and the “provider” (Art. 3(3)) under the AI Act, whereas the entities operating these local nodes act as “deployers” (Art. 3(4)). The AI Act dictates stringent data governance (Art. 10) and logging mechanisms (Art. 12) for high-risk systems (Annex III, point 5(b)) [2].

Pursuant to Article 26(6) of the AI Act, the obligation to maintain logs defaults to the deployer if the logs remain under their control. By executing an FL system that complies with the AI Act’s decentralized data governance and

GDPR’s data minimization principles (Art. 5(1)(c) GDPR), the manufacturer willfully surrenders access to post-deployment telemetry. The manufacturer is trapped in a statutory deadlock: engineering the system for maximum AI Act compliance legally vitiates their evidentiary capacity to mount a defense under the Revised PLD. Without access to local logs held by the deployer, the manufacturer cannot establish the Article 11(1)(c) exemption (proving that the probable defect did not exist at the time the model was placed on the market or that it emerged post-deployment).

## 4 Operationalizing the Differentiated Liability Taxonomy (Lex Ferenda)

To resolve this systemic conflict, relying solely on judicial interpretation is insufficient, as national courts are bound by the statutory wording of Article 10 presumptions. Therefore, this paper introduces a legislative or regulatory integration of a Differentiated Liability Taxonomy. This *lex ferenda* framework supersedes the binary application of Article 10, proposing a trinary legal assessment calibrated against the manufacturer’s cryptographically verified access matrix.

### 4.1 Tier 1: Full Telemetric Control ( $C_{full}$ )

Applicable to centralized architectures. The manufacturer retains complete visibility over inputs and outputs. Article 9 disclosure orders and Article 10(4) burden-of-proof reversals apply unmitigated, aligning with advanced strict liability principles [1].

### 4.2 Tier 2: Asymmetric Federated Control ( $C_{federated}$ )

Applicable to FL architectures where the manufacturer controls  $W_{global}$  but deployers control training vectors. To prevent the unjust shifting of strict liability onto the manufacturer for deployer-induced errors, the taxonomy proposes a formalized mechanism for exculpation and recourse. The deployer must supply a cryptographic attestation of data integrity to the manufacturer. If the manufacturer can demonstrate through this mechanism that local data poisoning occurred, it activates the Article 11(1)(c) liability exemption, classifying the intervention as a post-deployment external alteration. Furthermore, this mechanism solidifies the manufacturer’s right of recourse against the deployer under national tort or contract law.

### 4.3 Tier 3: Fully Decentralized Environments ( $C_{decentralized}$ )

Applicable to permissionless, multi-agent autonomous systems where the manufacturer possesses zero ex-post intervention capacity. The taxonomy structurally

precludes the application of Article 10(4) against the initial manufacturer, classifying the opacity as an inherent technological reality. This gives effect to the Article 11(1)(a) or (c) exemptions based on demonstrably zero architectural control.

## 5 Systemic Resolution

Directive (EU) 2024/2853 constitutes a strict mechanism for algorithmic accountability; however, its evidentiary presumptions are in structural incompatibility with privacy-preserving architectures. The implementation of the Differentiated Liability Taxonomy *de lege ferenda* resolves this lacuna. By calibrating legal presumptions directly to verifiable control limits, the taxonomy secures consumer remediation while ensuring manufacturers are not penalized for deploying privacy-compliant architectures and have viable avenues for recourse against the deploying entities.

## References

1. European Union: Directive (EU) 2024/2853 of the European Parliament and of the Council of 23 October 2024 on liability for defective products and repealing Council Directive 85/374/EEC. OJ L, 2024/2853, 18.11.2024.
2. European Union: Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act). OJ L, 2024/1689, 12.07.2024.
3. European Economic Community: Council Directive 85/374/EEC of 25 July 1985 on the approximation of the laws, regulations and administrative provisions of the Member States concerning liability for defective products. OJ L 210, 7.8.1985.
4. Li, S., Faure, M.: The Revised Product Liability Directive: A Law and Economics Analysis. *Journal of European Tort Law* **15**(2), 140–171 (2024).
5. European Parliamentary Research Service (EPRS): Proposal for a directive on adapting non-contractual civil liability rules to artificial intelligence. European Parliament (2024).
6. McMahan, B., Moore, E., Ramage, D., Hampson, S., & y Arcas, B. A.: Communication-efficient learning of deep networks from decentralized data. In: *Proceedings of the 20th International Conference on Artificial Intelligence and Statistics (AISTATS)*. PMLR (2017).
7. Woisetschläger, H., Mertel, S., Krönke, C., Mayer, R., & Jacobsen, H.-A.: Federated Learning and AI Regulation in the European Union: Who is Responsible? - An Interdisciplinary Analysis. *arXiv preprint arXiv:2407.08105* (2024).
8. Malgieri, G., Pasquale, F.: Licensing high-risk artificial intelligence: Toward ex ante justification for a disruptive technology. *Computer Law & Security Review* Volume 52 (2024).
9. Lee, C.-M., Fernández, J.-D., & Menci, S.-P.: Federated Learning for Credit Risk Assessment. *Proceedings of the 56th Hawaii International Conference on System Sciences (HICSS)*, (2023).

---

## Eurocrim2026 Individual Submission Acceptance Letter

1 wiadomość

European Society of Criminology <DO\_NOT\_REPLY@allacademic.com>

18 maja 2026 21:51

Odpowiedź do: abstracts.eurocrim2026@uw.edu.pl

Do: k.badzmirowskam@gmail.com

CC: wiktorwilkolaski73@gmail.com

Dear authors Katarzyna Badźmirowska-Masłowska, War Studies University, Faculty of Law and Administration, Warsaw Poland; Wiktor Wilkołaski, War Studies University; ,

It is our pleasure to inform you that your abstract for an individual presentation with the title *The UN Convention against cybercrime. The legal challenges and dilemmas* has been accepted for oral presentation at the 26th Annual Conference of the European Society of Criminology Eurocrim2026, which will take place in Warsaw, 9-12 September 2026.

You can **confirm your presence** at the conference by registering until the early bird deadline, which is June 1st and will not be extended.

Please note that only the papers with at least one author who is fully registered until June 1st will be included in the program. The paper can be presented by one or more authors. Anyone (presenting / non-presenting author) will need a valid registration to access the conference venue.

This year one person could only register one paper as a primary author (bar an exemption granted pre-submission by the organizers). **If you have submitted multiple papers as primary author without authorized to do so by the organizers, all but one of your papers will have to be withdrawn.** If in one of the papers you are a primary author of is in a pre-arranged panel, your other papers will be automatically deleted by the organizers (to minimize the risk of a pre-arranged panel being dissolved). If none of your affected papers are in a pre-arranged panel, or if you are listed as primary author in multiple pre-arranged panels, the decision as to which to withdraw will be yours. Please contact the Abstract Management team ([abstracts.eurocrim2026@uw.edu.pl](mailto:abstracts.eurocrim2026@uw.edu.pl)) regarding this decision.

In order to register for the conference, please visit the European Society of Criminology [website](http://www.esc-eurocrim.org/index.php/conferences/registration) (<http://www.esc-eurocrim.org/index.php/conferences/registration>).

Please feel free to contact us if you have any questions:

1. If your question concerns the **registration**, please contact the European Society of Criminology via email to [secretariat@esc-eurocrim.org](mailto:secretariat@esc-eurocrim.org) or fax to +41 21 692 46 45.
2. If the question concerns your **submission(s)**, write to the Abstract Management team at [abstracts.eurocrim2026@uw.edu.pl](mailto:abstracts.eurocrim2026@uw.edu.pl). Please mind: the scheduling will take place in July, and the program will be published as soon as this is concluded. Therefore, we will not be able to answer any question before that about the programme. However, the structure of the program will be made available earlier on the conference website. Link to the submission platform: <https://convention2.allacademic.com/one/esc/esc26/>
3. If the question concerns **accommodation, travel, letter of invitation for a visa application**, and other issues, please contact the local organizers directly at [eurocrim@uw.edu.pl](mailto:eurocrim@uw.edu.pl).

**Please keep in mind that presenting authors should be able to attend the whole conference since we cannot honour requests for a specific day or time, due to a very high number of submissions.**

Please keep an eye on our website ([www.eurocrim2026.com](http://www.eurocrim2026.com)) and the social media Twitter page (@esc\_eurocrim) to see the key dates of the conference and updates on the program release.

We are looking forward to seeing you in Warsaw!

Kind regards,

Eurocrim2026 Warsaw Organizers





# CERTIFICATE

OF PARTICIPATION  
INTERNATIONAL CONFERENCE  
**AI Frontiers in Cybersecurity and Infrastructure Protection**  
Warsaw, 22 May 2025 (virtual)



THE DOCTORAL  
SCHOOL OF WAR  
STUDIES UNIVERSITY

## Wiktor Wilkoński

presented a speech: *Towards Quantum-Resilient Systems: Introducing the AI-Enhanced Cryptographic Agility Framework (AI-ECAF) Empowered by Post-Quantum Cryptography*

**dr hab. Dorota Domalewska**

DIRECTOR OF THE DOCTORAL SCHOOL  
EDITOR-IN-CHIEF OF 'SECURITY AND  
DEFENCE QUARTERLY'



## Opinia

**Podczas praktyki zawodowej student zapoznał się z następującymi zagadnieniami związanymi z kierunkiem jego studiów:**

W trakcie odbywania praktyki zawodowej w Departamencie Informatyzacji i Systemów Informacji o Prawie Rządowego Centrum Legislacji Pan Wiktor Wilkołaski szczegółowo zapoznał się z przebiegiem rządowego procesu legislacyjnego, zarówno od strony regulaminowej, jak i praktycznej, a także z rolą, zadaniami i pozycją Rządowego Centrum Legislacji w tym procesie. W ramach toczących się prac był zaangażowany w analizę projektów dokumentów rządowych pod względem prawnym, formalnym i redakcyjnym na różnych etapach prac legislacyjnych. Był zaangażowany w szczególności w analizę projektu ustawy o zmianie ustawy o krajowym systemie cyberbezpieczeństwa (UC32) oraz ustawy o systemach sztucznej inteligencji (UC71). Praktykant uczestniczył w posiedzeniach komisji prawnych rozpatrujących projekty aktów wykonawczych: projektu rozporządzenia Ministra Cyfryzacji w sprawie reklamacji usługi komunikacji elektronicznej lub usługi fakultatywnego obciążania rachunku (WPL MC 11) oraz projektu rozporządzenia Rady Ministrów zmieniające rozporządzenie w sprawie zakresu danych i wykazu rejestrów publicznych oraz systemów teleinformatycznych podmiotów publicznych, z których użytkownik aplikacji mObywatel może pobrać dane (RDER1). Brał także udział w spotkaniach z przedstawicielami Ministerstwa Cyfryzacji.

Praktykant zapoznał się z warsztatem pracy legislatora, z uwzględnieniem wykorzystania publicznych systemów informacji o prawie i posługiwania się szablonem projektu aktu prawnego, oraz z przykładami stosowania w praktyce mających odniesienie do procesu prawodawczego przepisów Konstytucji, Regulaminu pracy Rady Ministrów oraz Zasad techniki prawodawczej.

DYREKTOR  
Departamentu Informatyzacji  
i Systemów Informacji o Prawie  
  
Krzysztof Wilkołaski

Podpis

pieczęć Rządowego Centrum Legislacji

Warszawa, dnia 07.08.2025r.

## ZAŚWIADCZENIE O ODBYCIU PRAKTYKI ZAWODOWEJ

Zaświadczam, że Pan **Wiktor Wilkoński**  
urodzony dnia 22 kwietnia 2004 r.  
student Akademii Sztuki Wojennej w Warszawie  
odbył w Rządowym Centrum Legislacji praktykę zawodową w okresie  
od 08 lipca 2025 r. do 07 sierpnia 2025 r.,  
w liczbie godzin 180.

Ocena praktyki: celująca

DYREKTOR  
Departamentu Informacji  
i Systemów Informacji w Prawie

Podpis

# Government Legislation Center Internship Opinion

*Own translation for recruitment purposes*

## OPINION

During the professional internship, the student became familiar with the following issues related to his field of study:

During the professional internship in the Department of Informatization and Legal Information Systems of the Government Legislation Centre, Mr. Wiktor Wilkołaski became thoroughly familiar with the course of the government legislative process, both from the regulatory and practical perspectives, as well as with the role, tasks, and position of the Government Legislation Centre in this process. As part of the ongoing work, he was involved in the legal, formal, and editorial analysis of draft government documents at various stages of legislative work. He was particularly involved in the analysis of the draft act amending the act on the national cybersecurity system (UC32) and the act on artificial intelligence systems (UC71). The intern participated in the meetings of legal committees considering drafts of executive acts: the draft regulation of the Minister of Digital Affairs regarding complaints about electronic communication services or optional billing services (WPL MC 11) and the draft regulation of the Council of Ministers amending the regulation on the scope of data and the list of public registers and IT systems of public entities from which a user of the mObywatel application can download data (RDER1). He also took part in meetings with representatives of the Ministry of Digital Affairs.

The intern became acquainted with the legislator's workshop, including the use of public legal information systems and the use of a draft legal act template, as well as with examples of practical application of the provisions of the Constitution, the Rules of Procedure of the Council of Ministers, and the Principles of Legislative Technique relevant to the legislative process.

DIRECTOR  
of the Department of Informatization  
and Legal Information Systems

Krzysztof Madej  
(Signature)

**GOVERNMENT LEGISLATION CENTRE**

ul. Krucza 36/Wspólna 6

00-522 Warszawa

NIP 526-23-88-150 REGON 016179067

(stamp of the Government Legislation Centre)

Warsaw, 01.08.2025

**CERTIFICATE  
OF COMPLETION OF PROFESSIONAL INTERNSHIP**

I hereby certify that Mr. **Wiktor Wilkołaski**  
born on April 22, 2004,  
student of the War Studies University in Warsaw  
completed a professional internship at the Government Legislation Centre in the period  
from July 08, 2025, to August 07, 2025,  
amounting to **180** hours.

**Internship grade: excellent**

DIRECTOR  
of the Department of Informatization  
and Legal Information Systems

Krzysztof Madej  
(Signature)